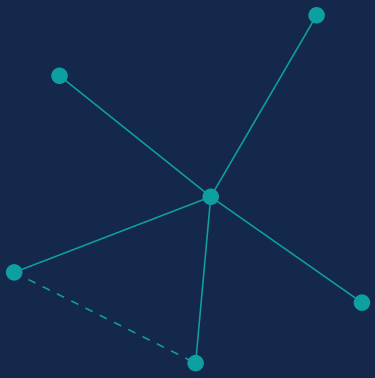


NETZWERK VERSTEHEN

# Band 8

# NETZWERK-SICHERHEIT

## Firewalls, VLANs, VPN und Zero Trust

Eugen Becker

**Netzwerk verstehen, Band 8**
Netzwerksicherheit: Firewalls, VLANs, VPN und Zero Trust

Autor: Eugen Becker

Erste Ausgabe

Dieses Buch ist urheberrechtlich geschützt. Die Verwendung der Inhalte außerhalb der gesetzlichen Grenzen bedarf der Zustimmung des Autors.

Die Angaben in diesem Buch wurden sorgfältig geprüft. Netzwerkgeräte, Betriebssysteme und Werkzeuge entwickeln sich weiter. Prüfe bei Konfigurationsfragen immer die Dokumentation deines Herstellers oder Betriebssystems. Analysiere Netzwerkverkehr nur in Netzen, für die du die Verantwortung trägst oder eine ausdrückliche Erlaubnis besitzt.

# Vorwort

Die ersten sieben Bände dieser Reihe haben gezeigt, wie Netzwerke aufgebaut sind, wie Daten fließen und wie man Störungen findet. Ein funktionierendes Netz ist aber nicht automatisch ein sicheres Netz. Wer Kabel verlegt, Switches konfiguriert und ein WLAN in Betrieb nimmt, hat Verbindungen geschaffen, die auch für Unbefugte erreichbar sind, wenn niemand sie schützt.

Dieser Band behandelt die Sicherheit des gesamten Netzes. Er beginnt mit den Grundbegriffen und den Schutzzielen, geht über typische Bedrohungen und die Werkzeuge der Abwehr, nämlich Firewalls, Segmentierung, VPN und Zugriffskontrolle, und endet bei Konzepten für ganze Unternehmen. Dabei geht es immer um Abwehr. Angriffe werden so weit erklärt, wie es für das Erkennen und Abwehren nötig ist.

Die Konfigurationsbeispiele für WireGuard und IPsec verwenden ausschließlich Testwerte. Schlüssel, Adressen und Zugangsdaten in diesem Buch sind Platzhalter und dürfen nicht in einem produktiven Netz verwendet werden. Praktische Übungen sind nur in eigenen Laborumgebungen oder mit ausdrücklicher Genehmigung vorgesehen.

Der Band baut auf den Grundlagen der Bände 1 bis 3 auf, besonders auf den Schichten, den Ports und den Transportprotokollen. Die Sicherheit des WLAN aus Band 7 wird hier in das Gesamtbild eingeordnet. Rechtliche Hinweise dienen der Orientierung und ersetzen keine Rechtsberatung.

Eugen Becker

# Inhaltsverzeichnis

**Vorwort** . . . . . **iii**

**1 Grundlagen der Netzwerksicherheit** . . . . . **1**

1.1 Was bedeutet IT-Sicherheit? . . . . . 1
1.2 Warum ist Netzwerksicherheit wichtig? . . . . . 1
1.3 Schutzziele der Informationssicherheit . . . . . 2
1.4 Sicherheitsrisiken in privaten und geschäftlichen Netzwerken . . . . . 2
1.5 Bedrohung, Schwachstelle und Risiko . . . . . 3
1.6 Angriffsfläche und Sicherheitslücke . . . . . 3
1.7 Defense in Depth . . . . . 3
1.8 Security by Design . . . . . 4
1.9 Sicherheitsrichtlinien und organisatorische Maßnahmen . . . . . 4
1.10 Rolle des Netzwerkadministrators . . . . . 5

**2 Bedrohungen und Angriffsmethoden** . . . . . **7**

2.1 Vorbemerkung zur Darstellung . . . . . 7
2.2 Malware und Ransomware . . . . . 8
2.3 Phishing und Social Engineering . . . . . 9
2.4 Man-in-the-Middle-Angriffe . . . . . 10
2.5 ARP-Spoofing . . . . . 11
2.6 DNS-Spoofing . . . . . 12
2.7 IP-Spoofing . . . . . 13
2.8 DoS- und DDoS-Angriffe . . . . . 14
2.9 Brute-Force und Passwortangriffe . . . . . 14
2.10 Rogue Devices und Rogue Access Points . . . . . 15
2.11 Insider-Bedrohungen . . . . . 16
2.12 Unsichere Netzwerkdienste . . . . . 17
2.13 Fehlkonfigurationen . . . . . 18
2.14 Veraltete Firmware und Software . . . . . 19
2.15 Lieferkettenrisiken . . . . . 19

**3 Firewalls verstehen** . . . . . **22**

3.1 Was ist eine Firewall? . . . 22
3.2 Aufgaben und Funktionsweise . . . 22
3.3 Paketfilter . . . 23
3.4 Stateless Filtering . . . 23
3.5 Stateful Inspection . . . 23
3.6 Application Layer Gateway . . . 24
3.7 Next-Generation-Firewall . . . 24
3.8 Host-basierte und netzwerkbasierte Firewalls . . . 25
3.9 Hardware- und Software-Firewalls . . . 25
3.10 Eingehender und ausgehender Datenverkehr . . . 25
3.11 Firewall-Regeln . . . 26
3.12 Allow- und Deny-Regeln . . . 27
3.13 Default Deny . . . 27
3.14 Regelreihenfolge . . . 27
3.15 Logging und Monitoring . . . 27
3.16 NAT und Firewall . . . 28
3.17 DMZ-Konzepte . . . 28
3.18 Typische Firewall-Fehler . . . 29

**4 Netzwerksegmentierung und VLAN-Sicherheit . . . 31**
4.1 Warum Netzwerke segmentiert werden . . . 31
4.2 Broadcast-Domänen . . . 31
4.3 VLAN-Grundlagen . . . 32
4.4 Access- und Trunk-Ports . . . 32
4.5 IEEE 802.1Q und VLAN-Tagging . . . 32
4.6 Native VLAN . . . 33
4.7 Inter-VLAN-Routing . . . 33
4.8 Layer-3-Switching . . . 33
4.9 Trennung von Benutzer- und Servernetzwerken . . . 34
4.10 Gastnetzwerke . . . 34
4.11 Management-VLAN . . . 35
4.12 IoT-Netzwerke . . . 35
4.13 DMZ . . . 35
4.14 Sicherheitszonen . . . 35
4.15 ACLs . . . 35
4.16 Kommunikation zwischen VLANs kontrollieren . . . 36
4.17 Beispielunternehmen: Segmentierung im Mittelstand . . . 36
4.18 Typische Segmentierungsfehler . . . 38
4.19 VLAN-Hopping und Schutzmaßnahmen . . . 38

**5 VPN verstehen . . . 40**
5.1 Was ist ein Virtual Private Network? . . . 40
5.2 Warum werden VPNs eingesetzt? . . . 40

5.3 Tunnelprinzip . . . 41
5.4 Verschlüsselung und Authentifizierung . . . 41
5.5 Tunneling-Protokolle . . . 42
5.6 Site-to-Site-VPN . . . 42
5.7 Remote-Access-VPN . . . 42
5.8 Client-to-Site-VPN . . . 43
5.9 Split Tunneling und Full Tunneling . . . 43
5.10 VPN-Gateways und VPN-Clients . . . 43
5.11 Routing durch VPN-Tunnel . . . 44
5.12 DNS im VPN . . . 44
5.13 MTU und typische VPN-Probleme . . . 44
5.14 VPN-Sicherheit . . . 45
5.15 Vor- und Nachteile verschiedener VPN-Varianten . . . 45

**6 WireGuard in der Praxis . . . 47**
6.1 Was ist WireGuard? . . . 47
6.2 Architektur und Funktionsprinzip . . . 47
6.3 Public- und Private-Keys . . . 48
6.4 Peers . . . 48
6.5 AllowedIPs . . . 48
6.6 Endpoint . . . 49
6.7 PersistentKeepalive . . . 49
6.8 Handshake . . . 49
6.9 Verschlüsselung . . . 49
6.10 WireGuard unter Linux . . . 50
6.11 Installation und Grundkonfiguration . . . 50
6.12 Konfiguration eines Server-Peers . . . 50
6.13 Konfiguration eines Client-Peers . . . 51
6.14 Site-to-Site-Verbindungen . . . 51
6.15 Routing durch den Tunnel . . . 52
6.16 Firewall-Regeln für WireGuard . . . 52
6.17 Schlüsselverwaltung . . . 52
6.18 Fehleranalyse . . . 52
6.19 Sicherheits-Best-Practices . . . 53

**7 IPsec verstehen . . . 54**
7.1 Was ist IPsec? . . . 54
7.2 Einsatzgebiete . . . 54
7.3 AH und ESP . . . 55
7.4 Transportmodus . . . 55
7.5 Tunnelmodus . . . 55
7.6 IKE und IKEv2 . . . 56
7.7 Security Associations . . . 56

7.8 Authentifizierung . . . 57
7.9 Verschlüsselungsalgorithmen . . . 57
7.10 Integritätsschutz . . . 57
7.11 Diffie-Hellman-Schlüsselaustausch . . . 58
7.12 Site-to-Site-IPsec . . . 58
7.13 Remote-Access-IPsec . . . 58
7.14 NAT-Traversal . . . 58
7.15 IPsec und Firewall . . . 59
7.16 IPsec unter Linux . . . 59
7.17 Typische Fehler und deren Diagnose . . . 60
7.18 Vergleich mit WireGuard . . . 61

**8 Zero Trust verstehen . . . 63**
8.1 Was bedeutet Zero Trust? . . . 63
8.2 Warum klassische Netzwerkgrenzen nicht reichen . . . 63
8.3 Grundprinzipien . . . 64
8.4 Never Trust, Always Verify . . . 64
8.5 Least Privilege . . . 64
8.6 Continuous Verification . . . 65
8.7 Identitätsbasierte Zugriffskontrolle . . . 65
8.8 Geräteidentität . . . 65
8.9 Benutzeridentität und Multi-Faktor-Authentifizierung . . . 65
8.10 Mikrosegmentierung . . . 66
8.11 Policy Enforcement . . . 66
8.12 Conditional Access . . . 67
8.13 Zero-Trust-Architektur . . . 67
8.14 Zero Trust und VPN . . . 67
8.15 Zero Trust im Unternehmen . . . 68
8.16 Typische Fehlinterpretationen . . . 68
8.17 Grenzen und Herausforderungen . . . 68
8.18 Schrittweiser Übergang: Ein Beispiel . . . 69

**9 Zugriffskontrolle und Authentifizierung . . . 71**
9.1 Authentifizierung und Autorisierung . . . 71
9.2 Identitäts- und Zugriffsmanagement . . . 71
9.3 Benutzerkonten und Gruppen . . . 72
9.4 Rollenbasierte Zugriffskontrolle . . . 72
9.5 Attributbasierte Zugriffskontrolle . . . 72
9.6 Least Privilege . . . 73
9.7 Passwortsicherheit . . . 73
9.8 Multi-Faktor-Authentifizierung . . . 73
9.9 Zertifikate und Public-Key-Infrastruktur . . . 74
9.10 RADIUS . . . 74

9.11 TACACS+ . . . 74
9.12 IEEE 802.1X . . . 75
9.13 Network Access Control . . . 75
9.14 Geräteauthentifizierung . . . 75
9.15 Rechteverwaltung und regelmäßige Überprüfung . . . 75
9.15.1 Unterschiede anhand eines Unternehmensbeispiels . . . 76

**10 Netzwerkgeräte und Dienste absichern . . . 78**
10.1 Warum Netzwerkgeräte besonders geschützt werden müssen . . . 78
10.2 Sichere Grundkonfiguration von Routern . . . 78
10.3 Switch-Hardening . . . 79
10.4 Port Security . . . 79
10.5 DHCP Snooping . . . 79
10.6 Dynamic ARP Inspection . . . 80
10.7 IP Source Guard . . . 80
10.8 BPDU Guard . . . 80
10.9 Firewall-Hardening . . . 81
10.10 SSH statt Telnet . . . 81
10.11 Sichere Managementzugänge . . . 81
10.12 SNMPv3 . . . 82
10.13 Deaktivierung nicht benötigter Dienste . . . 82
10.14 Sichere DNS-Konfiguration . . . 82
10.15 DHCP-Sicherheit . . . 83
10.16 Firmware- und Sicherheitsupdates . . . 83
10.17 Backup und Wiederherstellung von Konfigurationen . . . 83
10.18 Managementzugänge beschränken . . . 83
10.19 Netzwerkgeräte dokumentieren . . . 84
10.20 Warum mehrere Schutzmaßnahmen nötig sind . . . 84

**11 Überwachung und Erkennung von Sicherheitsvorfällen . . . 87**
11.1 Warum Netzwerkmonitoring wichtig ist . . . 87
11.2 Sicherheitsrelevante Netzwerkereignisse . . . 87
11.3 Logdateien . . . 88
11.4 Syslog . . . 88
11.5 SNMP . . . 88
11.6 NetFlow und IPFIX . . . 89
11.7 IDS und IPS . . . 89
11.8 SIEM-Grundlagen . . . 89
11.9 Anomalieerkennung . . . 90
11.10 Netzwerkverkehr analysieren . . . 90
11.11 Wireshark für Sicherheitsanalysen . . . 91
11.12 Alarmierung und Eskalation . . . 91
11.13 False Positives und False Negatives . . . 91

11.14 Dokumentation von Sicherheitsvorfällen . . . 92
11.15 Überblick über die Werkzeuge . . . 92

**12 Sicherheitskonzepte für Unternehmen . . . 94**
12.1 Sicherheitsanforderungen ermitteln . . . 94
12.2 Schutzbedarf bestimmen . . . 94
12.3 Netzwerkrisiken bewerten . . . 95
12.4 Sicherheitszonen planen . . . 96
12.5 Firewall- und VLAN-Konzept . . . 97
12.6 VPN-Zugänge planen . . . 97
12.7 Benutzer- und Rechtekonzept . . . 97
12.8 Gastzugänge absichern . . . 98
12.9 Servernetz schützen . . . 98
12.10 Backup und Wiederherstellung . . . 98
12.11 Patch- und Update-Management . . . 99
12.12 Notfallplanung . . . 99
12.13 Sicherheitsdokumentation . . . 99
12.14 Regelmäßige Sicherheitsüberprüfungen . . . 100
12.15 Zusammenfassung des Beispiels . . . 100

**13 Praxisprojekte und Übungen . . . 102**
13.1 Projekt 1: Eine Firewall für ein Testnetzwerk konfigurieren . . . 103
13.2 Projekt 2: Ein Netzwerk mit mehreren VLANs segmentieren . . . 105
13.3 Projekt 3: Eine DMZ planen und umsetzen . . . 108
13.4 Projekt 4: Einen WireGuard-VPN-Tunnel einrichten . . . 110
13.5 Projekt 5: Eine Site-to-Site-VPN-Verbindung konzipieren . . . 112
13.6 Projekt 6: Ein Sicherheitskonzept nach Zero-Trust-Grundsätzen entwickeln . . . 114
13.7 Projekt 7: Netzwerkereignisse mit Wireshark analysieren . . . 116

**14 Zusammenfassung und Ausblick . . . 119**
14.1 Die wichtigsten Erkenntnisse . . . 119
14.2 Mehrschichtige Netzwerksicherheit . . . 120
14.3 Warum es keine einzelne perfekte Sicherheitslösung gibt . . . 120
14.4 Sicherheit als fortlaufender Prozess . . . 120
14.5 Bedeutung von Monitoring und Wartung . . . 121
14.6 Neue Entwicklungen in der Netzwerksicherheit . . . 121
14.7 Automatisierung und moderne Sicherheitsarchitekturen . . . 121
14.8 Übergang zu Band 9: Netzwerke im Homelab . . . 122

**Anhang . . . 124**
Glossar . . . 124
Abkürzungsverzeichnis . . . 125

**Quellen und Literatur . . . 128**

KAPITEL 1

# Grundlagen der Netzwerksicherheit

**Lernziele.** Nach diesem Kapitel kannst du erklären, was IT-Sicherheit bedeutet, die klassischen Schutzziele unterscheiden, die Begriffe Bedrohung, Schwachstelle und Risiko auseinanderhalten und die Grundprinzipien Defense in Depth und Security by Design anwenden. Außerdem erkennst du die Rolle des Netzwerkadministrators in einem Sicherheitskonzept.

## 1.1 Was bedeutet IT-Sicherheit?

IT-Sicherheit bezeichnet den Schutz von Informationen und der Systeme, die sie verarbeiten und übertragen. Der Begriff ist weiter als Datenschutz und enger als die Zuverlässigkeit der Technik insgesamt. Er fragt, ob Informationen zur richtigen Zeit, im richtigen Umfang und für die richtigen Personen verfügbar sind und ob sie unverfälscht bleiben.

Ein Netzwerk ist dabei der Weg, auf dem Informationen von einer Stelle zur anderen gelangen. Wer diesen Weg kontrolliert, kontrolliert einen großen Teil der Sicherheit. Gleichzeitig ist das Netz selbst ein Angriffsziel, denn wer die Verbindungen stört oder mitliest, erreicht viel.

## 1.2 Warum ist Netzwerksicherheit wichtig?

Netzwerke verbinden heute fast alles. Ein Büro verbindet Arbeitsplätze, Server, Drucker, Telefone und Kameras. Ein Heimnetz verbindet Smartphones, Fernseher, Laptops und Smart-Home-Geräte. Jede dieser Verbindungen kann ein Zugang sein, und viele Geräte werden selten aktualisiert.

Die Folgen eines Vorfalls reichen von einzelnen Ausfällen bis zu existenziellen Problemen. Ein verschlüsselter Dateiserver, der nicht mehr erreichbar ist, kann einen Betrieb für Tage lahmlegen. Ein abgeflossenes Kundenverzeichnis schadet dem Ruf und kann rechtliche Folgen haben. Netzwerksicherheit verhindert nicht jeden Vorfall, aber sie begrenzt, was ein Vorfall anrichten kann.

## 1.3 Schutzziele der Informationssicherheit

Die Schutzziele beschreiben, was man schützen will. Das Bundesamt für Sicherheit in der Informationstechnik, kurz BSI, nennt als zentrale Schutzziele Vertraulichkeit, Integrität und Verfügbarkeit. Ergänzend werden Authentizität und Nachvollziehbarkeit genannt. Diese sechs Begriffe bilden das Gerüst, mit dem man jedes Netz prüft.

| Schutzziel | Bedeutung | Beispiel im Netz |
|---|---|---|
| Vertraulichkeit | Nur Berechtigte dürfen Informationen lesen. | Verschlüsselter Zugriff auf das Kundenverzeichnis |
| Integrität | Daten bleiben unverändert, oder Änderungen werden erkannt. | Prüfsummen bei Software-Downloads |
| Verfügbarkeit | Dienste sind nutzbar, wenn sie gebraucht werden. | Redundanter Router für den Internetzugang |
| Authentizität | Absender und Gegenstelle sind zweifelsfrei identifiziert. | Zertifikat des Webservers wird geprüft |
| Nachvollziehbarkeit | Handlungen lassen sich einer Person oder einem Gerät zuordnen. | Anmeldeprotokoll des VPN-Zugang |

**Tabelle 1.1.** Schutzziele der Informationssicherheit mit Beispielen aus dem Netzbetrieb. Die Zuordnung ist vereinfacht, viele Maßnahmen wirken auf mehrere Ziele.

Die Schutzziele greifen ineinander. Eine Verschlüsselung schützt die Vertraulichkeit, sichert aber die Integrität nur, wenn sie auch Änderungen erkennt. Ein Dienst kann verfügbar sein und trotzdem gefälschte Antworten liefern, wenn die Authentizität fehlt. Deshalb prüft man alle sechs Ziele gemeinsam und nicht nur das, was gerade auffällt.

## 1.4 Sicherheitsrisiken in privaten und geschäftlichen Netzwerken

Im privaten Netz sind die Risiken oft unbemerkt. Ein Router mit Standardpasswort, ein veraltetes Gerät im Gastnetz oder ein Dienst, der aus dem Internet erreichbar ist, bleiben lange unentdeckt. Der Nutzer hat selten einen Plan für Vorfälle, und die Verantwortung liegt bei ihm selbst.

Im Unternehmen kommen Vertraulichkeit von Kundendaten, die Verfügbarkeit von Produktionssystemen und gesetzliche Pflichten hinzu. Die Zahl der Geräte ist höher, die Zuständigkeiten sind verteilt, und Mitarbeiter arbeiten von unterwegs. Diese Umgebung verlangt klare Regeln und festgelegte Verantwortlichkeiten.

## 1.5 Bedrohung, Schwachstelle und Risiko

Drei Begriffe werden oft verwechselt, sie beschreiben aber verschiedene Dinge. Eine Bedrohung ist ein möglicher Auslöser eines Schadens, etwa ein Angreifer, ein Virus oder ein Stromausfall. Eine Schwachstelle ist eine Eigenschaft eines Systems, die von einer Bedrohung ausgenutzt werden kann, etwa ein ungepatchter Dienst oder ein schwaches Passwort. Das Risiko entsteht aus der Kombination: Wie wahrscheinlich ist es, dass eine Bedrohung eine Schwachstelle trifft, und wie groß wäre der Schaden?

Ein Beispiel macht den Unterschied deutlich. Ein Webserver mit einem bekannten Fehler ist eine Schwachstelle. Ein Angreifer, der den Fehler ausnutzen könnte, ist die Bedrohung. Ist der Server aus dem Internet erreichbar und enthält er wichtige Daten, ist das Risiko hoch. Liegt er hinter einer Firewall, auf einem isolierten Netz, und ist er aktualisiert, sinkt das Risiko, auch wenn die Bedrohung bestehen bleibt.

## 1.6 Angriffsfläche und Sicherheitslücke

Die Angriffsfläche umfasst alle Stellen, über die ein System angegriffen werden kann. Dazu gehören offene Ports, Dienste, Verwaltungszugänge, Benutzerkonten, Schnittstellen und die Menschen, die das System bedienen. Jede Verbindung vergrößert die Angriffsfläche, jeder unnötige Dienst ebenfalls.

Eine Sicherheitslücke ist eine konkrete Schwachstelle, die bekannt oder nicht bekannt sein kann. Bekannte Lücken werden in Datenbanken erfasst und durch Updates geschlossen. Unbekannte Lücken sind schwerer zu erkennen, deshalb verlassen sich Schutzkonzepte nicht allein auf das Fehlen bekannter Lücken.

## 1.7 Defense in Depth

Defense in Depth bedeutet mehrschichtige Verteidigung. Jede Schutzebene soll einen Angreifer aufhalten, falls eine andere versagt. Im Netz kann das so aussehen: Eine Firewall begrenzt den Zugang von außen, eine Segmentierung begrenzt die Bewegung im Inneren, eine Verschlüsselung schützt die Verbindung, eine Zugriffskontrolle prüft die Berechtigung, und eine Überwachung erkennt Auffälligkeiten.

Die folgende Abbildung zeigt diese Schichten als Modell.




Schematische Darstellung. Jede äußere Schicht hält Angriffe auf.

**Abbildung 1.1.** Defense in Depth als Schichtenmodell. Die äußeren Schichten sind Organisation und Netzwerkgrenze, die inneren schützen die Daten selbst. Schematische Darstellung.

## 1.8 Security by Design

Security by Design bedeutet, Sicherheit von Anfang an einzuplanen und nicht nachträglich anzubauen. Ein Netz, das ohne Segmentierung geplant wird, lässt sich später nur mit großem Aufwand trennen. Ein Dienst, der ohne Verschlüsselung entwickelt wird, bleibt unsicher, auch wenn man später einen Filter davorsetzt. Die Planung entscheidet darüber, wie viel Schutz mit vertretbarem Aufwand möglich ist.

## 1.9 Sicherheitsrichtlinien und organisatorische Maßnahmen

Technik allein genügt nicht. Eine Sicherheitsrichtlinie legt fest, welche Anforderungen gelten, wer für was verantwortlich ist und wie Ausnahmen behandelt werden. Organisatorische Maßnahmen sind zum Beispiel Schulungen, Zugriffsregeln für Mitarbeiter, Vertretungsregeln bei Ausfall des Administrators, Meldewege für Vorfälle und regelmäßige Überprüfungen. Ohne diese Regeln bleiben technische Maßnahmen oft un-

genutzt oder werden umgangen.

Das BSI stellt mit dem IT-Grundschutz eine Methodik bereit, die diese Bausteine systematisch zusammenführt. Der Grundschutz ist ein Rahmen, der sich an Organisationen unterschiedlicher Größe anpassen lässt.

## 1.10 Rolle des Netzwerkadministrators

Der Netzwerkadministrator betreibt die Infrastruktur und trägt eine besondere Verantwortung, weil er tiefen Zugriff auf Geräte und Daten hat. Seine Aufgaben umfassen Konfiguration, Überwachung, Updates, Dokumentation und Reaktion auf Vorfälle. Er setzt die Richtlinien um, auch wenn sie unbequem sind, und er meldet Schwachstellen, die er nicht selbst beheben kann.

Diese Stellung verlangt Sorgfalt im eigenen Verhalten. Administrative Konten werden getrennt von den Alltagskonten genutzt, Zugriffe werden protokolliert, und die Zahl der Personen mit administrativen Rechten bleibt klein. Wer das Netz absichern will, beginnt bei den eigenen Zugängen.

> **Merke**
>
> Die sechs Begriffe Vertraulichkeit, Integrität, Verfügbarkeit, Authentizität und Nachvollziehbarkeit bilden den Prüfmaßstab. Ein Risiko entsteht aus einer Bedrohung, die auf eine Schwachstelle trifft. Mehrschichtige Verteidigung und Planung von Anfang an verringern die Folgen, auch wenn sie nicht jeden Vorfall verhindern.

## Zusammenfassung

IT-Sicherheit schützt Informationen und Systeme durch Schutzziele, die man gemeinsam prüft. Risiken entstehen aus Bedrohungen und Schwachstellen. Defense in Depth und Security by Design begrenzen die Folgen, und Richtlinien sowie die Rolle des Administrators machen die Technik wirksam.

## Kontrollfragen

1. Welche Schutzziele werden im BSI-Grundschutz genannt, und welches davon schützt eine Verschlüsselung am ehesten?
2. Worin unterscheidet sich eine Bedrohung von einer Schwachstelle?

3. Warum reicht eine einzelne Firewall für einen wirksamen Schutz nicht aus?
4. Was bedeutet Security by Design, und warum ist eine nachträgliche Segmentierung aufwendiger?
5. Welche Aufgaben hat der Netzwerkadministrator außerhalb der Technik?

KAPITEL 2

# Bedrohungen und Angriffsmethoden

**Lernziele.** Nach diesem Kapitel kannst du die wichtigsten Bedrohungen für Netzwerke benennen, ihre Wirkung und Voraussetzungen einordnen, Anzeichen für ihr Auftreten erkennen und passende Schutzmaßnahmen auswählen. Die Beschreibungen dienen der Abwehr. Angriffe werden nur so weit erklärt, wie es das Verständnis des Risikos verlangt.

## 2.1 Vorbemerkung zur Darstellung

Jede Bedrohung wird in denselben fünf Schritten behandelt: was passiert, welche Voraussetzungen erfüllt sein müssen, welche Auswirkungen entstehen, wie sich die Bedrohung erkennen lässt und welche Schutzmaßnahmen sinnvoll sind. Die Reihenfolge macht die Beschreibungen vergleichbar. Die Abschnitte bleiben bewusst allgemein, weil konkrete Anleitungen für Angriffe auf fremde Systeme nicht Gegenstand dieses Buches sind.

Die Tabelle gibt einen Überblick über die Bedrohungen dieses Kapitels und die Schutzebene, auf der sie am wirksamsten bekämpft werden.

| Bedrohung | Angegriffenes Schutzziel | Wirksamste Abwehr |
|---|---|---|
| Malware und Ransomware | Verfügbarkeit, Integrität | Segmentierung, Updates, getrennte Backups |
| Phishing und Social Engineering | Vertraulichkeit, Authentizität | Schulung, Mehrfaktor-Authentifizierung |
| Man-in-the-Middle | Vertraulichkeit, Authentizität | Verschlüsselung mit Zertifikatsprüfung |
| ARP-Spoofing | Authentizität, Vertraulichkeit | Dynamic ARP Inspection, Port Security |
| DNS-Spoofing | Authentizität | DNSSEC, verschlüsselte DNS-Abfragen |
| IP-Spoofing | Authentizität | Ingress-Filterung am Rand |
| DoS und DDoS | Verfügbarkeit | Ratenbegrenzung, vorgelagerter Schutz |
| Brute-Force und Passwortangriffe | Vertraulichkeit | Sperren, Mehrfaktor, lange Passwörter |
| Rogue Devices und Rogue Access Points | Vertraulichkeit, Integrität | Bestandsliste, 802.1X, Überwachung |
| Insider-Bedrohungen | Vertraulichkeit, Integrität | Minimale Rechte, Protokollierung |
| Unsichere Netzwerkdienste | Vertraulichkeit | Verschlüsselte Protokolle, Dienste abschalten |
| Fehlkonfigurationen | alle Schutzziele | Härtung, Prüfung, Dokumentation |
| Veraltete Firmware und Software | alle Schutzziele | Patch-Management, Ersatzplanung |
| Lieferkettenrisiken | Integrität, Vertrauen | Herkunftsprüfung, Auswahlkriterien |

**Tabelle 2.1.** Bedrohungen dieses Kapitels mit betroffenem Schutzziel und wirksamster Abwehr. Die Zuordnung ist eine Vereinfachung.

## 2.2 Malware und Ransomware

### Was passiert

Schadsoftware gelangt auf ein Gerät und führt Funktionen aus, die der Eigentümer nicht vorgesehen hat. Ransomware verschlüsselt Daten und verlangt ein Lösegeld für die Entschlüsselung. Die Verbreitung erfolgt über E-Mail-Anhänge, manipulierte Downloads, ungepatchte Dienste oder Zugangsdaten, die aus dem Netz kompromittiert wurden.

### Voraussetzungen

Ein Gerät muss die Schadsoftware ausführen oder einen Dienst anbieten, der sie aufnimmt. Viele Netze erlauben seitliche Bewegung zwischen Geräten, sodass sich die Software im Netz verteilen kann, wenn ein einzelnes Gerät betroffen ist.

### Auswirkungen

Betriebsunterbrechungen, Datenverlust, Kosten für die Wiederherstellung und Vertraulichkeitsverluste, wenn Daten abfließen. Bei Ransomware ist oft die Wiederherstellung das größere Problem als die Verschlüsselung selbst.

### Erkennung

Auffällig sind ungewöhnlich viele Dateiänderungen, neue Dateiendungen, Verbindungen zu unbekannten Zielen, plötzlich hohe Last auf Datei-Freigaben und Meldungen des Virenschutzes. Netzseitig fallen ungewöhnliche Verbindungsmuster auf, etwa ein Gerät, das viele andere Geräte im internen Netz anspricht.

### Schutzmaßnahmen

Regelmäßige Updates schließen bekannte Lücken. Segmentierung begrenzt die Ausbreitung, und Freigaben mit minimalen Rechten verringern den Schaden. Backups müssen getrennt vom Netz liegen, regelmäßig geprüft werden und Versionen über einen längeren Zeitraum vorhalten. Ein Backup, das auf demselben Netz liegt, wird von derselben Schadsoftware erreicht.

## 2.3 Phishing und Social Engineering

### Was passiert

Angreifer nutzen Vertrauen, um Menschen zu einer Handlung zu bewegen, etwa zur Eingabe eines Passworts auf einer gefälschten Seite, zur Überweisung oder zur Freigabe eines Zugangs. Phishing geschieht über E-Mail, Nachrichten oder Anrufe. Social Engineering umfasst auch persönliche Täuschung.

### Voraussetzungen

Ein Mensch muss der Nachricht glauben und handeln. Gelingt dies, umgeht der Angriff alle technischen Schutzmaßnahmen, die auf Passwörter vertrauen.

### Auswirkungen

Zugangsdaten gelangen in fremde Hände, Zahlungen gehen an Betrüger, und Schadsoftware wird eingeschleust. Ein erbeutetes Passwort öffnet oft mehr als ein einzelnes Konto, wenn es mehrfach verwendet wurde.

### Erkennung

Warnsignale sind Dringlichkeit, ungewöhnliche Absender, Links, die nicht zum angeblichen Absender passen, und Bitten um Daten, die die Organisation nie anfordert. Technisch erkennt man Phishing-Versuche über Filter, Anmeldeprotokolle an ungewöhnlichen Orten und Zeitpunkten.

### Schutzmaßnahmen

Mehrfaktor-Authentifizierung macht erbeutete Passwörter allein wertlos. Regelmäßige Schulung und Übungen stärken das Erkennen. Klare Prozesse für Zahlungen und Freigaben verhindern, dass eine einzelne Nachricht genügt. Technische Filter ergänzen diese Maßnahmen, ersetzen sie aber nicht.

## 2.4 Man-in-the-Middle-Angriffe

### Was passiert

Ein Angreifer platziert sich zwischen zwei Kommunikationspartnern und sieht oder verändert die Verbindung. Der Angriff zielt auf Verbindungen, die nicht oder nur schwach geschützt sind.

### Voraussetzungen

Der Angreifer muss den Verkehr umleiten oder mithören können, etwa in einem Netz, in dem er bereits Zugriff hat, oder über einen gefälschten Zugangspunkt. Unverschlüsselte Protokolle und fehlende Zertifikatsprüfung erleichtern den Angriff.

### Auswirkungen

Vertrauliche Daten wie Zugangsdaten gelangen in fremde Hände. Inhalte können verändert werden, etwa Software-Downloads oder Bankdaten. Der Nutzer merkt oft nichts, weil die Verbindung formal besteht.

### Erkennung

Warnungen des Browsers bei ungültigen Zertifikaten sind ein deutliches Zeichen. Unerwartete Zertifikatsänderungen, doppelte IP-Adressen im Netz und Auffälligkeiten im ARP-Verkehr deuten ebenfalls auf einen solchen Angriff hin.

### Schutzmaßnahmen

Verschlüsselung mit TLS und die Prüfung der Zertifikate schützen die Vertraulichkeit und die Authentizität. HSTS verhindert, dass Browser auf unverschlüsselte Verbindungen zurückfallen. Im Netz schützen 802.1X und die Trennung von Netzen den Zugang. Die Warnungen dürfen nicht leichtfertig übergangen werden, denn genau dort liegt der Angriff.

## 2.5 ARP-Spoofing

### Was passiert

Das Address Resolution Protocol ordnet IP-Adressen den MAC-Adressen im lokalen Netz zu. Das Protokoll prüft die Antworten nicht, sodass ein Gerät falsche Zuordnungen annehmen kann. Dadurch lassen sich Verbindungen umleiten.

### Voraussetzungen

Der Angreifer muss sich im selben Layer-2-Netz befinden. In einem Netz mit Switches ist das der Fall, wenn er einen Port besitzt oder Zugang zu einem Gerät im Segment hat.

### Auswirkungen

Der Verkehr eines Opfers läuft über den Angreifer, Verbindungen können mitgelesen oder gestört werden. Netzwerkausfälle für einzelne Geräte sind die häufigste Folge.

### Erkennung

Ein Gerät zeigt zwei unterschiedliche MAC-Adressen für dieselbe IP-Adresse, oder der ARP-Cache ändert sich ohne Anlass. Switches melden solche Konflikte, wenn entsprechende Funktionen aktiviert sind.

### Schutzmaßnahmen

Dynamic ARP Inspection prüft ARP-Antworten gegen eine Zuordnungstabelle, die aus DHCP Snooping stammt. Port Security begrenzt die MAC-Adressen pro Port. Für kritische Systeme helfen feste ARP-Einträge, sind aber aufwendig zu pflegen. Diese Funktionen werden in Kapitel 10 ausführlicher behandelt.

## 2.6 DNS-Spoofing

### Was passiert

Ein DNS-Server oder eine Antwort auf dem Weg wird manipuliert, sodass ein Name auf eine falsche Adresse zeigt. Der Nutzer landet dann auf einer fremden Seite, obwohl er den richtigen Namen eingegeben hat.

### Voraussetzungen

Das klassische DNS-Protokoll prüft die Antworten nicht kryptografisch. Ein Angreifer muss eine gültige Antwort vor dem legitimen Server erreichen oder den Server selbst kompromittieren.

### Auswirkungen

Der Nutzer wird auf gefälschte Seiten umgeleitet, Zugangsdaten werden abgegriffen, und Software kann aus falschen Quellen stammen. Das Vertrauen in Namen wird zerstört.

### Erkennung

Ungewöhnliche Adressen für bekannte Namen, Zertifikatswarnungen auf Seiten, die sonst ohne Warnung laden, und Abweichungen zwischen internen und externen Antworten geben Hinweise.

### Schutzmaßnahmen

DNSSEC signiert DNS-Antworten, sodass Resolver Fälschungen erkennen können. Verschlüsselte DNS-Abfragen über TLS oder HTTPS schützen den Weg zwischen Client und Resolver. Zertifikatsprüfung bleibt der letzte Schutz, wenn alles andere versagt.

## 2.7 IP-Spoofing

### Was passiert

Ein Absender setzt eine fremde Quelladresse in seine Pakete. Antworten gehen dann an das Opfer, nicht an den Absender. Das Verfahren verschleiert die Herkunft und erleichtert Angriffe, die auf Antworten angewiesen sind.

### Voraussetzungen

Der Absender muss Pakete mit beliebiger Quelladresse senden können. Viele Netze am Rand prüfen die Quelladresse nicht, was den Angriff ermöglicht.

### Auswirkungen

Die Herkunft eines Angriffs ist schwer nachzuvollziehen. Dienste können überlastet werden, weil Antworten an unbeteiligte Adressen gehen, und interne Vertrauensregeln, die auf Adressen beruhen, lassen sich umgehen.

### Erkennung

Pakete von außen mit internen Quelladressen sind ein deutliches Zeichen. Die Firewall protokolliert solche Pakete, wenn Regeln dafür existieren.

### Schutzmaßnahmen

Ingress-Filterung am Netzrand verwirft Pakete mit Quelladressen, die aus dem Netz selbst nicht stammen können. Die Empfehlung dazu ist in der BCP 38 festgehalten, dem Dokument RFC 2827. Vertrauensregeln sollten nicht allein auf IP-Adressen beruhen.

## 2.8 DoS- und DDoS-Angriffe

### Was passiert

Ein Dienst wird mit so vielen Anfragen überlastet, dass legitime Nutzer ihn nicht mehr erreichen. Bei einer verteilten Variante, DDoS, kommen die Anfragen von vielen Quellen, oft aus einem Botnetz.

### Voraussetzungen

Der Angreifer braucht Kapazität, die die Ressourcen des Ziels übersteigt. Für DDoS-Angriffe genügt eine große Zahl kompromittierter Geräte, die viel Verkehr senden können.

### Auswirkungen

Der Dienst fällt aus, Kunden können nicht bestellen, Mitarbeiter nicht arbeiten. Auch wenn die Daten sicher sind, leidet die Verfügbarkeit, und die Wiederherstellung kann Stunden oder Tage dauern.

### Erkennung

Ein plötzlicher, starker Anstieg des Verkehrs, viele Verbindungen aus wenigen oder vielen Quellen, unvollständige Verbindungsaufbauten und überlastete Schnittstellen sind typische Zeichen.

### Schutzmaßnahmen

Ratenbegrenzung und Begrenzung gleichzeitiger Verbindungen schützen einzelne Dienste. SYN-Cookies helfen gegen Verbindungsaufbau-Überflutung. Gegen große Angriffe braucht man vorgelagerten Schutz beim Internetanbieter oder bei einem spezialisierten Dienst, denn die Bandbreite des eigenen Anschlusses reicht dafür meist nicht. Ein Notfallplan mit Ansprechpartnern gehört ebenfalls dazu.

## 2.9 Brute-Force und Passwortangriffe

### Was passiert

Ein Angreifer probiert viele Passwörter oder Schlüssel aus, bis er einen Treffer hat. Bei Passwortangriffen werden zusätzlich gestohlene Passwortlisten genutzt, weil viele Menschen Passwörter wiederverwenden.

### Voraussetzungen

Der Dienst muss einen Anmeldeversuch zulassen, ohne Sperren oder Verzögerungen zu erzwingen. Schwache oder wiederverwendete Passwörter erleichtern den Erfolg.

### Auswirkungen

Ein erfolgreicher Zugriff verschafft Zugang zu dem Konto oder Dienst. Bei Administratorkonten ist der Schaden groß, weil der Angreifer dann das Netz verändern kann.

### Erkennung

Viele fehlgeschlagene Anmeldungen in kurzer Zeit, Anmeldungen aus ungewöhnlichen Orten oder zu ungewöhnlichen Zeiten und Sperren von Konten sind typische Hinweise.

### Schutzmaßnahmen

Sperren nach mehreren Fehlversuchen und Verzögerungen erschweren das Ausprobieren. Mehrfaktor-Authentifizierung macht ein erratenes Passwort allein wertlos. Lange, zufällige Passwörter aus einem Passwort-Manager und der Verzicht auf Wiederverwendung sind wirksam. Dienste sollten nicht aus dem Internet erreichbar sein, wenn es nicht nötig ist.

## 2.10 Rogue Devices und Rogue Access Points

### Was passiert

Ein nicht genehmigtes Gerät wird an das Netz angeschlossen, etwa ein privater Switch oder ein WLAN-Router. Es umgeht Richtlinien und öffnet einen Weg ins Netz, oft ohne dass die Verantwortlichen davon wissen.

### Voraussetzungen

Ein physischer Zugang zu einem Netzwerkport oder einer Dose genügt, wenn der Port nicht geschützt ist. Bei WLAN reicht ein Gerät in Reichweite mit dem richtigen Namen oder einer Täuschung.

### Auswirkungen

Der Verkehr läuft über ein Gerät, das niemand überwacht. Die Angriffsfläche wächst unbemerkt, und die Herkunft von Vorfällen ist schwer zu klären.

### Erkennung

Eine Bestandsliste der Geräte zeigt Abweichungen. MAC-Adressen, die an ungewöhnlichen Ports auftauchen, und Funknetze, die nicht zur Liste passen, sind Hinweise. Ein WLAN-Überwachungssystem meldet fremde Access Points automatisch.

### Schutzmaßnahmen

Port Security und 802.1X lassen nur bekannte Geräte an die Ports. Eine Bestandsliste mit regelmäßigen Abgleichen und Funkscans der Umgebung ergänzt den Schutz. Ungenutzte Ports werden abgeschaltet.

## 2.11 Insider-Bedrohungen

### Was passiert

Personen mit berechtigtem Zugang missbrauchen ihn oder verursachen Schäden, absichtlich oder aus Fahrlässigkeit. Insider sind schwer zu erkennen, weil ihre Handlungen zunächst regulär wirken.

### Voraussetzungen

Der Insider hat einen Zugang, der über das Nötige hinausgeht. Fehlende Protokollierung und fehlende Trennung von Aufgaben verstärken das Risiko.

### Auswirkungen

Datenabfluss, Manipulation von Konfigurationen, Sabotage und Schäden durch unbedachte Handlungen. Ein Administrator mit uneingeschränkten Rechten kann in kurzer Zeit viel bewirken.

### Erkennung

Auffällige Zugriffe außerhalb der Arbeitszeit, Massenkopien von Daten, Zugriffe auf Bereiche, die mit der Aufgabe nichts zu tun haben, und Änderungen ohne Ticket. Protokolle müssen dafür vorhanden und geprüft werden.

### Schutzmaßnahmen

Das Prinzip der minimalen Rechte gibt jeder Person nur die Zugriffe, die sie braucht. Administrative Konten werden getrennt von den Alltagskonten genutzt. Vier-Augen-Prinzip bei kritischen Änderungen und lückenlose Protokollierung erschweren Missbrauch und machen ihn nachvollziehbar.

## 2.12 Unsichere Netzwerkdienste

### Was passiert

Dienste wie Telnet, FTP oder ältere Versionen von SNMP übertragen Daten oder Anmeldeinformationen im Klartext. Wer den Verkehr mitschneidet, liest sie mit.

### Voraussetzungen

Der Angreifer muss den Verkehr sehen können, etwa in einem geteilten Netz oder über einen kompromittierten Zwischenpunkt. Ein Dienst, der unverschlüsselt läuft, ist dann sofort betroffen.

### Auswirkungen

Passwörter und Konfigurationsdaten werden offengelegt. Bei SNMP mit Standard-Community-Strings können Angreifer außerdem Geräte auslesen oder verändern.

### Erkennung

Ein Blick in die offenen Dienste eines Geräts zeigt, was läuft. Dienste, die man nicht benötigt, aber aktiv findet, sind ein Hinweis auf Handlungsbedarf.

### Schutzmaßnahmen

Verschlüsselte Ersatzprotokolle sind der Weg: SSH statt Telnet, SFTP statt FTP und SNMPv3 statt der älteren Versionen. Nicht benötigte Dienste werden abgeschaltet. Die Umstellung wird in Kapitel 10 praktisch behandelt.

## 2.13 Fehlkonfigurationen

### Was passiert

Ein Gerät oder ein Dienst ist falsch eingerichtet: Standardpasswörter bleiben aktiv, Verwaltungszugänge sind offen, Regeln sind zu weit gefasst oder Dienste laufen unnötig. Fehlkonfigurationen sind eine der häufigsten Ursachen für Vorfälle.

### Voraussetzungen

Ein Gerät muss erreichbar sein und die falsche Einstellung besitzen. Oft genügt es, dass Herstellerdokumentation und Standardwerte unverändert übernommen wurden.

### Auswirkungen

Angreifer erhalten Zugang, ohne eine Schwachstelle ausnutzen zu müssen. Fehlkonfigurationen sind schwer sichtbar, weil das Gerät normal funktioniert.

### Erkennung

Prüfungen anhand einer Checkliste, Vergleich der Konfiguration mit der Richtlinie und automatische Prüfwerkzeuge zeigen Abweichungen. Auch regelmäßige Sichtung der offenen Ports und Dienste hilft.

### Schutzmaßnahmen

Härtung nach einer festen Checkliste, Änderung aller Standardwerte beim ersten Einrichten, Dokumentation jeder Abweichung und regelmäßige Überprüfung gehören zusammen. Kapitel 10 enthält Beispiele dazu.

## 2.14 Veraltete Firmware und Software

### Was passiert

Bekannte Schwachstellen bleiben in Geräten bestehen, weil keine Aktualisierung eingespielt wird. Angreifer nutzen veröffentlichte Lücken oft schnell aus.

### Voraussetzungen

Eine bekannte Schwachstelle muss im Gerät vorhanden und erreichbar sein. Je länger ein Gerät ungepatcht bleibt, desto größer ist das Risiko.

### Auswirkungen

Die Folgen reichen von Datenabfluss bis zur vollständigen Übernahme des Geräts. Ein Router oder Switch mit alter Firmware kann den gesamten Verkehr betreffen.

### Erkennung

Eine Bestandsliste mit Versionsständen zeigt veraltete Geräte. Herstellerhinweise und Meldungen von Sicherheitsbehörden weisen auf konkrete Lücken hin.

### Schutzmaßnahmen

Patch-Management mit festen Terminen, Priorisierung nach Schwere und Erreichbarkeit, und ein Plan für das Ende des Herstellersupports. Geräte, die keine Sicherheitsupdates mehr erhalten, werden ersetzt, bevor sie zum Risiko werden.

## 2.15 Lieferkettenrisiken

## Was passiert

Ein Gerät oder eine Software enthält bereits beim Kauf eine Manipulation, oder ein Zulieferer wird angegriffen und die Schwachstelle gelangt über das Produkt in das Netz. Solche Risiken sind schwer zu erkennen, weil das Produkt zunächst unauffällig funktioniert.

## Voraussetzungen

Der Hersteller oder einer seiner Zulieferer muss kompromittiert sein. Abhängigkeit von wenigen Anbietern oder von Software ohne transparente Herkunft erhöht das Risiko.

## Auswirkungen

Eine Manipulation kann unbemerkt in vielen Installationen gleichzeitig wirken. Der Schaden trifft die Organisation, obwohl sie selbst keinen Fehler gemacht hat.

## Erkennung

Ungewöhnliche Verbindungen eines Geräts zu fremden Zielen, unerwartete Updates und Abweichungen in Prüfsummen geben Hinweise. Eine Herkunftsprüfung vor dem Einsatz ist der erste Schritt.

## Schutzmaßnahmen

Auswahlkriterien für Hersteller mit Sicherheitsnachweisen, Prüfung von Signaturen und Prüfsummen bei Updates, Begrenzung der Verbindungen geräteseitig und Netzsegmentierung begrenzen den Schaden. Ein Vertrag, der Sicherheitsupdates und Meldepflichten regelt, ist hilfreich.

> **Merke**
>
> Die meisten Bedrohungen treffen Schwachstellen, die durch Planung, Härtung und Pflege vermeidbar wären. Wirksam sind Schichten: Verschlüsselung gegen Mitlesen, Segmentierung gegen Ausbreitung, Mehrfaktor-Authentifizierung gegen gestohlene Passwörter und Protokollierung gegen unbemerkte Fehler.

## Zusammenfassung

Netzwerkbedrohungen reichen von technischen Lücken über Fehlkonfigurationen bis zu menschlichem Verhalten. Jede Bedrohung hat Voraussetzungen, die man verringern kann. Die Schutzmaßnahmen wirken zusammen und ersetzen einander nicht.

## Kontrollfragen

1. Welche Voraussetzung muss bei ARP-Spoofing im Netz erfüllt sein?
2. Warum schützt Mehrfaktor-Authentifizierung auch dann, wenn ein Passwort bekannt geworden ist?
3. Welches Schutzziel verletzt ein DoS-Angriff, und welche Maßnahme wirkt am ehesten?
4. Warum ist ein Backup im selben Netz kein wirksamer Schutz gegen Ransomware?
5. Welche Erkennungsmerkmale sprechen für eine Fehlkonfiguration statt für einen Angriff?

KAPITEL 3

# Firewalls verstehen

**Lernziele.** Nach diesem Kapitel kannst du erklären, was eine Firewall tut, zwischen Paketfilter, Stateful Inspection, Application Layer Gateway und Next-Generation-Firewall unterscheiden, Regeln nach Quelle, Ziel, Port und Protokoll formulieren, die Wirkung der Regelreihenfolge beurteilen und typische Fehler vermeiden.

## 3.1 Was ist eine Firewall?

Eine Firewall kontrolliert den Datenverkehr zwischen Netzen oder Netzbereichen nach festen Regeln. Sie entscheidet für jedes Paket, ob es weitergeleitet, verworfen oder abgelehnt wird. Der Name stammt aus dem Bauwesen, wo eine Brandschutzwand einen Brand auf einen Bereich begrenzt. Eine Netzwerk-Firewall begrenzt entsprechend die Ausbreitung von Problemen und die Reichweite von Angreifern.

Eine Firewall ersetzt keine Verschlüsselung und keine Zugriffskontrolle. Sie ist eine Schicht unter mehreren, wie in Kapitel 1 beschrieben. Ihre Stärke liegt in der Begrenzung: Sie entscheidet, welche Verbindungen überhaupt zustande kommen dürfen.

## 3.2 Aufgaben und Funktionsweise

Eine Firewall wertet jedes Paket anhand seiner Merkmale aus. Dazu gehören die Quelladresse, die Zieladresse, das Protokoll, der Zielport und die Schnittstelle, über die das Paket eintrifft. Passt das Paket zu einer Regel, wird die Aktion dieser Regel ausgeführt. Passt keine Regel, greift die Standardaktion.

Außerdem erfüllt eine Firewall Nebenaufgaben. Sie protokolliert Ereignisse, führt oft Adressumsetzung durch, begrenzt die Rate von Verbindungen und meldet Auffälligkeiten. Diese Funktionen machen sie zu einem Werkzeug für Überwachung und Nachvollziehbarkeit, nicht nur für Filterung.

## 3.3 Paketfilter

Der Paketfilter ist die einfachste Form. Er betrachtet jedes Paket für sich und vergleicht seine Kopfdaten mit den Regeln. Er kennt weder den Verbindungszustand noch den Inhalt der Daten. Ein Paket, das zu einer erlaubten Kombination aus Adressen und Port passt, wird durchgelassen, unabhängig davon, ob es zu einer bestehenden Verbindung gehört.

Dieses Verfahren ist schnell und einfach zu verstehen. Es hat aber Grenzen: Antwortpakete müssen oft gesondert erlaubt werden, und ein Paket, das nur einen erlaubten Port nutzt, wird unabhängig von seinem Zweck durchgelassen.

## 3.4 Stateless Filtering

Stateless Filtering ist ein anderer Begriff für den Paketfilter im engen Sinn. Jedes Paket wird ohne Bezug auf vorherige Pakete beurteilt. Die Regeln müssen deshalb auch Antworten erlauben, wenn Verbindungen aus dem Inneren nach außen aufgebaut werden. Das führt zu offenen Regeln für Rückkanäle, die man nicht immer beabsichtigt hat.

## 3.5 Stateful Inspection

Eine zustandsbehaftete Firewall führt eine Tabelle der aktiven Verbindungen. Sie erkennt, ob ein Paket zu einem bestehenden Verbindungsaufbau gehört, und lässt Antworten gezielt zu. Ein Verbindungsaufbau, der als erlaubt gilt, erlaubt auch die zugehörigen Rückpakete, ohne dass dafür eine eigene Regel nötig ist.

Der Zustand umfasst typischerweise den Aufbau einer Verbindung, eine bestehende Verbindung und die Beendigung. Pakete, die keinen gültigen Zustand haben, werden verworfen. Für TCP wertet die Firewall dazu die Flags aus, für UDP und andere Protokolle wird eine Verbindung anhand der Adressen und Ports erkannt.

Stateful Inspection ist der heute übliche Standard für Netzfirewalls. Sie verbindet die Geschwindigkeit des Paketfilters mit einem besseren Verständnis des Verkehrs.




Vereinfachte Darstellung. Die Adressen sind Beispiele aus dem Netz aus Band 5.

**Abbildung 3.1.** Stateful Inspection am Beispiel einer HTTPS-Verbindung. Die Firewall erlaubt die Anfrage, trägt die Verbindung ein und lässt die zugehörige Antwort ohne eigene Regel durch.

## 3.6 Application Layer Gateway

Ein Application Layer Gateway, kurz ALG, geht eine Schicht weiter als die Stateful Inspection. Es versteht ein bestimmtes Anwendungsprotokoll und prüft dessen Nachrichten. Ein klassisches Beispiel ist FTP, dessen Datenverbindung über einen zweiten, zunächst unbekannten Port läuft. Das ALG erkennt diese Aushandlung und öffnet den Port gezielt.

Der Vorteil liegt in der genaueren Kontrolle. Der Nachteil ist die Abhängigkeit von der Unterstützung des Protokolls und die Komplexität der Auswertung. Bei verschlüsselten Protokollen wird die Prüfung schwierig, weil der Inhalt nicht mehr lesbar ist.

## 3.7 Next-Generation-Firewall

Eine Next-Generation-Firewall, kurz NGFW, verbindet die Stateful Inspection mit weiteren Funktionen. Sie erkennt Anwendungen unabhängig vom Port, etwa einen Dienst, der über Port 443 läuft, aber nicht im Webbrowser. Sie enthält oft ein Intrusion Prevention System, das bekannte Angriffsmuster erkennt, und kann Schadsoftware in Dateien prüfen. Teilweise prüft sie auch verschlüsselten Verkehr, indem sie die Verbindung aufbricht.

Die Vorteile sind klar: feinere Regeln, bessere Erkennung und zentrale Verwaltung. Die Nachteile sind Kosten, Abhängigkeit vom Hersteller, zusätzliche Verarbeitungslast und die Notwendigkeit, dass Zertifikate für die Prüfung im Netz vertrauenswürdig installiert sind. Das Aufbrechen verschlüsselter Verbindungen wirft zudem rechtliche und datenschutzrechtliche Fragen auf, die vor dem Einsatz geklärt werden müssen.

## 3.8 Host-basierte und netzwerkbasierte Firewalls

Eine netzwerkbasierte Firewall steht zwischen Netzen und schützt alle Geräte dahinter. Eine host-basierte Firewall läuft auf dem einzelnen Gerät, etwa die Windows-Firewall oder die Firewall-Funktion von Linux. Beide ergänzen einander: Die Netzfirewall begrenzt den Zugang zu einem Netzbereich, die Host-Firewall schützt den einzelnen Dienst.

Host-basierte Firewalls sind wichtig, wenn Geräte auch innerhalb des Netzes miteinander kommunizieren. Sie erlauben feinere Regeln für einzelne Dienste und funktionieren auch dann, wenn ein Gerät im Netz einen anderen Weg nimmt.

## 3.9 Hardware- und Software-Firewalls

Hardware-Firewalls sind spezialisierte Geräte mit eigener Verarbeitung. Sie sind auf Durchsatz ausgelegt und oft redundant aufgebaut. Software-Firewalls laufen auf Standard-Hardware oder virtuellen Maschinen, etwa unter Linux mit nftables. Sie sind flexibel und kostengünstig, verlangen aber Pflege des Betriebssystems und der Konfiguration.

Die Wahl richtet sich nach Durchsatz, Verfügbarkeitsanforderungen, Budget und vorhandenem Know-how. Ein Heimnetz kommt meist mit dem Router aus, ein Unternehmen braucht oft eine dedizierte Firewall.

## 3.10 Eingehender und ausgehender Datenverkehr

Die Richtung des Verkehrs bestimmt, wo die Regeln ansetzen. Eingehender Verkehr kommt von außen in das Netz, ausgehender Verkehr verlässt das Netz. Die meisten Firewalls behandeln beide Richtungen getrennt. Eine häufige Schwäche ist, dass der ausgehende Verkehr nicht eingeschränkt wird. Schadsoftware nutzt oft ausgehende Verbindungen, um Befehle zu empfangen oder Daten abzuziehen. Eine Regel, die nur den eingehenden Verkehr sperrt, lässt diesen Weg offen.

Der Gastbereich aus Kapitel 9 ist ein Beispiel: Der Verkehr aus dem Gastnetz in das interne Netz wird verboten, der Verkehr ins Internet wird erlaubt. Beide Richtungen müssen bewusst geregelt sein.

## 3.11 Firewall-Regeln

Eine Regel besteht aus Bedingungen und einer Aktion. Die Bedingungen beschreiben, welche Pakete betroffen sind, die Aktion legt fest, was mit ihnen geschieht. Typische Bestandteile sind Quelle, Ziel, Protokoll, Zielport, Richtung und ein Kommentar, der den Zweck festhält. Ein Kommentar ist keine Formalität: Er macht spätere Änderungen und Prüfungen möglich.

Die folgende Tabelle zeigt ein Beispiel für eine Regelmatrix. Die Adressen entsprechen dem Netz aus Band 5, die Regeln sind Beispiele und müssen für jede Umgebung neu geprüft werden.

| Nr. | Quelle | Ziel | Protokoll/Port | Aktion |
|---|---|---|---|---|
| 1 | 10.10.20.0/24 (IT) | 10.10.40.0/24 (Server) | TCP 443 | erlauben |
| 2 | 10.10.30.0/24 (Produktion) | 10.10.40.0/24 (Server) | TCP 1433 | erlauben |
| 3 | 10.10.60.0/24 (Gäste) | 10.10.0.0/16 (intern) | alle | verwerfen |
| 4 | 10.10.60.0/24 (Gäste) | alle | TCP 80, 443, UDP 53 | erlauben |
| 5 | alle | alle | alle | verwerfen |

**Tabelle 3.1.** Beispiel einer Firewall-Regelmatrix. Die Regeln werden in der Reihenfolge von oben nach unten geprüft. Die Adressen gehören zum Beispielnetz aus Band 5, die Regeln sind keine Empfehlung für eine konkrete Umgebung.

Die Regel 3 steht über Regel 4, damit der Gastverkehr ins interne Netz zuerst verworfen wird. Hätte die Regel 4 Vorrang, würde sie den Zugriff nicht verhindern, sie erlaubt ja nur Internetdienste. Die Reihenfolge entscheidet also über die Wirkung.

Die Regel 1 erlaubt der IT den Zugriff auf Webanwendungen im Serverbereich. Die Regel 2 erlaubt der Produktion nur den Zugriff auf die Datenbank, nicht auf den übrigen Serverbereich. Die Regel 3 verbietet den Gästen jeden Zugriff auf interne Adressen. Die Regel 4 erlaubt den Gästen nur Webdienste und die Namensauflösung ins Internet. Die Regel 5 verwirft alles, was bis dahin nicht erlaubt wurde.

## 3.12 Allow- und Deny-Regeln

Eine Allow-Regel erlaubt Verkehr, eine Deny-Regel verwirft ihn. Verwerfen bedeutet, dass das Paket still gelöscht wird, Ablehnen bedeutet, dass der Absender eine Rückmeldung erhält. Die Wahl hängt vom Zweck ab. Ablehnen gibt dem Absender schnell Gewissheit und vermeidet Wartezeiten, verrät aber, dass hinter der Adresse eine Firewall steht. Verwerfen verschleiert die Filterung, erzeugt aber Wartezeiten bei legitimen Verbindungen.

## 3.13 Default Deny

Default Deny bedeutet, dass alles verboten ist, was nicht ausdrücklich erlaubt wurde. Das ist die sichere Grundhaltung. Die Gegenstrategie, Default Allow, erlaubt alles und verbietet nur bekannte Gefahren. Sie ist bequem, aber sie schützt nur vor dem Bekannten.

Default Deny verlangt Pflege: Jeder neue Dienst braucht eine Regel. Dieser Aufwand lohnt sich, weil er sichtbar macht, welche Verbindungen wirklich benötigt werden.

## 3.14 Regelreihenfolge

Die meisten Firewalls prüfen Regeln von oben nach unten und wenden die erste passende Regel an. Eine allgemeine Regel weit oben kann daher spezifischere Regeln darunter unwirksam machen. Ebenso kann eine spezifische Erlaubnis eine Sperre überschreiben, wenn sie vorher steht. Vor jeder Änderung prüft man deshalb, wie sich die neue Regel in die bestehende Reihenfolge einfügt.

Typische Fehler sind Regeln, die zu weit gefasst sind, und Regeln, die unter einer allgemeinen Erlaubnis liegen und deshalb nie greifen. Eine Testmessung nach jeder Änderung zeigt, ob die Wirkung der Absicht entspricht.

## 3.15 Logging und Monitoring

Eine Firewall, die nichts protokolliert, verliert ihren Nutzen für die Nachvollziehbarkeit. Protokolle zeigen verworfene Pakete, Verbindungsversuche und Regeltreffer. Sie helfen, Fehlkonfigurationen zu finden und Angriffe zu erkennen. Wichtig ist, dass die Protokolle zusätzlich an einen zentralen Ort gesendet werden, damit ein Angreifer sie nicht einfach löschen kann. Kapitel 11 behandelt Syslog und die Auswertung.

Protokolle belasten Speicher und Datenschutz. Man legt fest, welche Ereignisse protokolliert werden, wie lange sie aufbewahrt werden und wer Zugriff hat.

## 3.16 NAT und Firewall

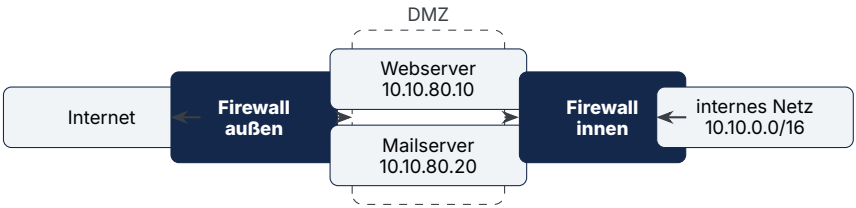
Network Address Translation verändert Adressen beim Übergang zwischen Netzen. Ein Heimrouter übersetzt beispielsweise viele private Adressen auf eine öffentliche. NAT ist keine Sicherheitsfunktion, auch wenn es oft so verstanden wird. Es verbirgt interne Adressen, schützt aber nicht vor Verbindungen, die von innen aufgebaut werden, und ersetzt keine Regeln.

Die Firewall und das NAT arbeiten zusammen. Die Firewall entscheidet, welche Verbindungen erlaubt sind, das NAT setzt die Adressen für den erlaubten Verkehr um. Bei Portweiterleitungen, mit denen ein Dienst aus dem Internet erreichbar gemacht wird, muss die Firewall die Weiterleitung ausdrücklich erlauben und begrenzen.

## 3.17 DMZ-Konzepte

Eine demilitarisierte Zone, kurz DMZ, ist ein Netzbereich für Dienste, die aus dem Internet erreichbar sein müssen, etwa Webserver oder Mailserver. Die DMZ liegt zwischen dem Internet und dem internen Netz. Verbindungen aus dem Internet dürfen in die DMZ, aber nicht direkt in das interne Netz. Verbindungen aus der DMZ ins interne Netz sind stark eingeschränkt.

Die folgende Abbildung zeigt diese Anordnung.




Schematische Darstellung. Die Adressen sind Beispiele und nicht Teil des Band-5-Netzes.

**Abbildung 3.2.** Eine DMZ zwischen zwei Firewalls. Der Verkehr aus dem Internet erreicht nur die Dienste in der DMZ, der Weg ins interne Netz führt über die zweite Firewall. Schematische Darstellung.

Eine DMZ lässt sich mit einer einzelnen Firewall mit drei Schnittstellen umsetzen, und das ist oft der Normalfall in kleinen Unternehmen. Entscheidend ist die Trennung der Regeln, nicht die Zahl der Geräte. Eine Kompromittierung eines Dienstes in der DMZ soll den Zugriff auf das interne Netz nicht öffnen.

## 3.18 Typische Firewall-Fehler

Häufige Fehler sind: Regeln mit ANY als Quelle und Ziel, die nicht begründet sind. Verwaltungszugänge, die aus dem Internet erreichbar sind. Regeln ohne Kommentar, die niemand mehr versteht. Testregeln, die nach dem Test stehen bleiben. Fehlende Protokollierung. Eine Firewall, die nur für den eingehenden Verkehr eingerichtet ist. Und Änderungen ohne Prüfung der Regelreihenfolge.

Ein weiterer, oft übersehener Fehler ist das Vertrauen auf die Firewall allein. Sie begrenzt den Zugang, sie repariert keine verwundbaren Dienste. Ein Dienst mit bekannter Lücke bleibt gefährlich, auch wenn er hinter einer gut konfigurierten Firewall liegt.

> **Merke**
>
> Eine Firewall entscheidet über Verbindungen anhand von Regeln. Stateful Inspection erkennt Antworten, Next-Generation-Firewalls prüfen den Verkehr tiefer. Default Deny, eine begründete Regelreihenfolge, Protokollierung und eine DMZ für öffentliche Dienste sind die Grundlagen eines sinnvollen Einsatzes.

## Zusammenfassung

Firewalls begrenzen den Verkehr zwischen Netzen durch Regeln. Die Verfahren reichen vom Paketfilter bis zur Next-Generation-Firewall. Wirksam sind sie nur mit einer klaren Regelreihenfolge, Default Deny, Protokollierung und einer sauberen Trennung öffentlicher Dienste.

## Kontrollfragen

1. Worin unterscheidet sich ein Paketfilter von einer Stateful Inspection?
2. Warum muss ein Paketfilter Rückpakete gesondert erlauben?
3. Welche Regel in der Beispielmatrix verhindert den Zugriff der Gäste auf interne Systeme, und warum muss sie vor der Internetregel stehen?

4. Warum ist NAT keine Sicherheitsfunktion im engen Sinn?
5. Was bedeutet eine DMZ für einen Webserver, der aus dem Internet erreichbar sein muss?

KAPITEL 4

# Netzwerksegmentierung und VLAN-Sicherheit

**Lernziele.** Nach diesem Kapitel kannst du erklären, warum Netze segmentiert werden, wie VLANs nach IEEE 802.1Q funktionieren, zwischen Access- und Trunk-Ports unterscheiden, das Zusammenspiel von Inter-VLAN-Routing und ACLs beschreiben, typische Angriffe auf VLANs einordnen und eine Kommunikationsmatrix für ein Unternehmensnetz entwickeln.

## 4.1 Warum Netzwerke segmentiert werden

Segmentierung teilt ein großes Netz in kleinere Bereiche auf und regelt, welche Bereiche miteinander sprechen dürfen. Der Grund ist einfach: Ein Gerät, das in einem flachen Netz kompromittiert wird, erreicht sofort alle anderen. In einem segmentierten Netz bleibt der Schaden auf einen Bereich begrenzt, sofern die Grenzen wirksam sind.

Segmentierung wirkt auch im Alltag. Ein Drucker, der keine Verbindung zu Personalakten braucht, sollte nicht dort erreichbar sein. Eine Kaffeemaschine mit Netzanschluss hat im Verwaltungsnetz nichts zu suchen. Die Trennung macht das Netz übersichtlicher und die Fehlersuche schneller, weil sich Störungen auf einen Bereich eingrenzen lassen.

## 4.2 Broadcast-Domänen

Eine Broadcast-Domäne ist der Bereich, den eine Broadcast-Nachricht erreicht. Ein Switch leitet Broadcasts an alle Ports weiter, außer an den Empfangsport. Ohne Trennung gehört das gesamte Netz zu einer Broadcast-Domäne. Jeder Broadcast, etwa eine ARP-Anfrage, erreicht dann alle Geräte, und ein Gerät mit fehlerhafter Konfiguration kann viel Verkehr erzeugen.

Ein Router trennt Broadcast-Domänen, weil er Broadcasts nicht weiterleitet. Ein VLAN erzeugt eine logische Trennung innerhalb eines Switches, ohne dass dafür ein zusätzlicher Router nötig ist. Die Grenze zwischen VLANs muss deshalb bewusst durch einen Router oder eine Firewall geführt werden, sonst gibt es keine Verbindung und auch keine Kontrolle.

## 4.3 VLAN-Grundlagen

Ein virtuelles lokales Netz, kurz VLAN, teilt die Ports eines Switches in logische Gruppen auf. Jede Gruppe hat eine Kennung, die VLAN-ID. Geräte in verschiedenen VLANs können auf demselben Switch sitzen, sie kommunizieren aber nicht direkt miteinander. Ein Frame aus VLAN 20 erreicht nur Ports, die zu VLAN 20 gehören.

Die VLAN-ID umfasst 12 Bit, damit sind die Werte 1 bis 4094 nutzbar. Der Wert 0 und der Wert 4095 sind reserviert. Im Netz aus Band 5 wurden die IDs 10, 20, 30, 40, 50, 60 und 99 verwendet. Die Nummern sind frei wählbar, sie sollten aber dokumentiert und einheitlich sein.

## 4.4 Access- und Trunk-Ports

Ein Access-Port gehört zu genau einem VLAN. Das Endgerät sendet und empfängt Frames ohne VLAN-Kennung, der Switch ordnet sie dem VLAN des Ports zu. Ein Drucker oder ein Arbeitsplatz hängt typischerweise an einem Access-Port.

Ein Trunk-Port transportiert mehrere VLANs über eine Verbindung, etwa zwischen zwei Switches oder zu einem Access Point. Die Frames tragen dafür eine VLAN-Kennung. Der Trunk ist nur für Geräte gedacht, die diese Kennungen auswerten können, also Switches, Router, Firewalls oder Access Points mit mehreren SSIDs.

## 4.5 IEEE 802.1Q und VLAN-Tagging

IEEE 802.1Q beschreibt, wie die VLAN-Kennung in den Ethernet-Frame eingefügt wird. Der Standard ergänzt den Frame um vier Byte. Diese Erweiterung enthält eine Tag Protocol Identifier, der den Frame als VLAN-getaggt kennzeichnet, und die VLAN-ID mit 12 Bit. Die übrigen Bits betreffen die Priorität und die Zuordnung der Kennung, die hier nicht weiter vertieft werden.

Der Ablauf ist überschaubar. Der Switch fügt beim Eingang aus einem Access-Port die Kennung hinzu, wenn der Frame über einen Trunk weitergeleitet wird. Beim Ausgang in einen Access-Port entfernt er die Kennung wieder, bevor das Endgerät den Frame erhält. Diese Umsetzung ist der Kern des VLAN-Konzepts.

## 4.6 Native VLAN

Auf einem Trunk-Port gibt es ein Native VLAN. Frames aus diesem VLAN werden ohne Kennung übertragen. Das Native VLAN dient historisch der Abwärtskompatibilität mit Geräten, die keine Tags verstehen. Die Gefahr liegt darin, dass ein Frame ohne Kennung immer im Native VLAN landet. Deshalb sollte das Native VLAN ein ungenutztes VLAN sein, das keinen Endgeräten zugeordnet ist.

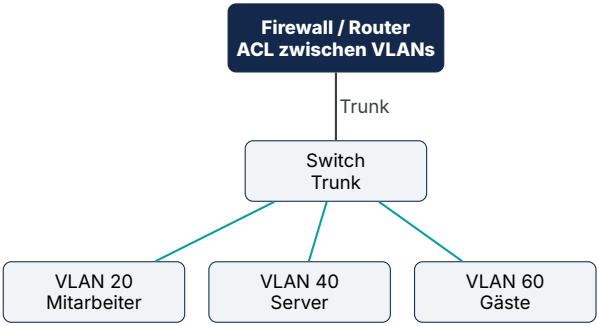
## 4.7 Inter-VLAN-Routing

Geräte in verschiedenen VLANs brauchen eine kontrollierte Verbindung, wenn sie miteinander arbeiten sollen. Diese Verbindung führt über einen Router oder einen Layer-3-Switch. Der Verkehr zwischen zwei VLANs wird dabei auf der Netzwerkschicht geroutet, und dort lassen sich Regeln anwenden.

Es gibt zwei Varianten. Beim Router-on-a-Stick ist der Router über einen einzigen Trunk-Port an den Switch angeschlossen, und für jedes VLAN gibt es eine Unterschnittstelle. Der gesamte Verkehr zwischen den VLANs läuft über diese eine Verbindung, was zum Engpass werden kann. Beim Layer-3-Switch übernimmt der Switch selbst das Routing über virtuelle Schnittstellen für jedes VLAN. Die Leistung ist höher, und der Verkehr muss nicht über eine einzelne Leitung laufen.

## 4.8 Layer-3-Switching

Ein Layer-3-Switch leitet Pakete zwischen VLANs in Hardware. Er spart dadurch die Umwege über einen Router, verliert aber nicht die Kontrolle, wenn er ACLs unterstützt. Für die Sicherheit ist entscheidend, dass die Regeln auf dem Switch und an der Firewall gleichermaßen konsistent sind. Eine Regel, die nur in einer der beiden Stellen steht, kann umgangen werden.




Schematische Darstellung. Die VLAN-Zuordnung ist ein Beispiel.

**Abbildung 4.1.** Inter-VLAN-Verkehr läuft über die Firewall. Der Trunk trägt alle VLANs zum Router oder zur Firewall, die den Verkehr zwischen den Netzen kontrolliert. Schematische Darstellung.

## 4.9 Trennung von Benutzer- und Servernetzwerken

Benutzer und Server gehören in getrennte Netze. Benutzer brauchen Zugriff auf bestimmte Dienste, aber nicht auf alle Ports eines Servers. Der Server braucht selbst keine Verbindung zu den Arbeitsplätzen, außer für die Antworten auf deren Anfragen. Eine Regel, die Verbindungen nur vom Benutzernetz zum Server erlaubt, und die Antworten über die Zustandstabelle der Firewall zulässt, bildet die Grundlage.

Die Trennung verhindert, dass ein kompromittierter Arbeitsplatz die Server direkt scannt und angreift. Der Angreifer muss dann zuerst die Firewall überwinden oder eine erlaubte Verbindung missbrauchen, und beides ist überwachbar.

## 4.10 Gastnetzwerke

Gastnetzwerke sind vollständig vom internen Netz getrennt. Ihre Clients erhalten Zugang zum Internet, aber keinen Zugang zu internen Systemen, auch nicht zu Druckern oder Freigaben. Die Trennung besteht aus VLAN, eigenem Adressbereich und einer Firewall-Regel, die den Verkehr in die internen Netze verbietet. Kapitel 9 hat den Aufbau bereits beschrieben.

## 4.11 Management-VLAN

Das Management-VLAN enthält die Verwaltungsschnittstellen von Switches, Routern, Firewalls und Access Points. Nur wenige Arbeitsplätze, die für die Administration vorgesehen sind, dürfen dorthin. Das Management-VLAN braucht keine Verbindung ins Internet und keine Verbindung zu Benutzernetzen. Es ist die wertvollste Zone des Netzes, weil dort die Geräte konfiguriert werden, die alles andere schützen.

## 4.12 IoT-Netzwerke

Geräte mit Netzanschluss, die keine klassischen Computer sind, gehören in ein eigenes Segment. Dazu zählen Sensoren, Kameras, Gebäudetechnik und Smart-Home-Geräte. Viele dieser Geräte werden selten aktualisiert, haben schwache Standardpasswörter und senden Daten an fremde Dienste. Das IoT-Segment erhält deshalb nur die Verbindungen, die für den Betrieb nötig sind, und keine Verbindung in die Benutzernetze.

## 4.13 DMZ

Die DMZ wurde in Kapitel 3 beschrieben. Im Segmentierungskonzept ist sie eine eigene Sicherheitszone für Dienste, die aus dem Internet erreichbar sein müssen. Sie folgt denselben Regeln wie andere Zonen: Eingehende Verbindungen sind nur auf die notwendigen Dienste begrenzt, und die Verbindung ins interne Netz ist stark eingeschränkt.

## 4.14 Sicherheitszonen

Sicherheitszonen fassen Netzbereiche mit ähnlichem Schutzbedarf zusammen. Eine Zone ist eine Schutzkategorie, die durch Regeln beschrieben wird, und sie entspricht nicht zwingend einem einzelnen VLAN. Typische Zonen sind das Internet, die DMZ, das interne Benutzernetz, das Serverbereich, das Management und die Gastzone. Der Verkehr zwischen Zonen wird grundsätzlich verboten und nur ausdrücklich erlaubt.

## 4.15 ACLs

Eine Access Control List, kurz ACL, ist eine Liste von Regeln, die auf einem Router oder Switch den Verkehr zwischen Netzen oder auf einer Schnittstelle filtert. ACLs wirken

ähnlich wie Firewall-Regeln, sind aber meist einfacher und arbeiten mit Adressen, Protokollen und Ports. Sie eignen sich gut zur Begrenzung innerhalb eines Netzes, ersetzen aber keine zustandsbehaftete Firewall, wenn Verbindungen kontrolliert werden müssen.

## 4.16 Kommunikation zwischen VLANs kontrollieren

Die Kontrolle beginnt mit einer Kommunikationsmatrix. Sie beschreibt für jedes Paar von Zonen, welche Verbindungen erlaubt sind. Die Matrix wird aus der Notwendigkeit des Betriebs abgeleitet, die technische Machbarkeit ist nur die zweite Frage. Jede Erlaubnis braucht einen Grund, und jeder Grund sollte dokumentiert sein.

Der folgende Abschnitt zeigt ein vollständiges Beispiel für ein mittelständisches Unternehmen.

## 4.17 Beispielunternehmen: Segmentierung im Mittelstand

Das Beispiel beschreibt ein Unternehmen mit rund 40 Mitarbeitenden, das eine Verwaltung, eine Geschäftsführung, eine Abteilung für Mitarbeitende, Server, Drucker, IoT-Geräte, Gäste und das Netzwerkmanagement hat. Die Nummern der VLANs folgen dem Netz aus Band 5, die Geschäftsführung und IoT sind neu hinzugekommen.

| VLAN | Bereich | Subnetz | Aufgabe |
|---|---|---|---|
| 10 | Verwaltung | 10.10.10.0/24 | Büroarbeit, Buchhaltung |
| 11 | Geschäftsführung | 10.10.11.0/24 | Leitung, besonders geschützt |
| 20 | Mitarbeitende | 10.10.20.0/24 | Arbeitsplätze der Fachabteilungen |
| 40 | Server | 10.10.40.0/24 | Dateien, Anwendungen, Dienste |
| 50 | Drucker | 10.10.50.0/24 | Netzwerkdrucker und Multifunktionsgeräte |
| 60 | Gäste | 10.10.60.0/24 | Besucher, nur Internet |
| 70 | IoT | 10.10.70.0/24 | Sensoren, Gebäudetechnik |
| 99 | Management | 10.10.99.0/24 | Verwaltungszugänge der Geräte |

**Tabelle 4.1.** VLAN-Plan des Beispielunternehmens. Die Subnetze sind Beispiele und folgen dem Schema aus Band 5.

Die Kommunikationsmatrix bestimmt, welche Zone mit welcher sprechen darf. Die folgende Tabelle zeigt die wichtigsten Entscheidungen. Eine Zeile heißt: Die Quelle darf zum Ziel nur mit den genannten Diensten.

| Quelle | Ziel | Entscheidung und Begründung |
|---|---|---|
| Geschäftsführung | Server | erlaubt: HTTPS und Dateiablage, begründet durch Zugriff auf Berichte |
| Geschäftsführung | Drucker | erlaubt: Druckdienste |
| Geschäftsführung | IoT, Gäste | verboten, keine betriebliche Notwendigkeit |
| Verwaltung | Server | erlaubt: HTTPS, Dateiablage, DNS |
| Verwaltung | Drucker | erlaubt: Druckdienste |
| Mitarbeitende | Server | erlaubt: HTTPS und Dateiablage, begrenzt auf die Fachanwendungen |
| Mitarbeitende | Management | verboten, nur Administratoren haben Zugang |
| Server | Mitarbeitende | verboten, Antworten laufen über die Zustandstabelle |
| Server | Internet | erlaubt: Aktualisierungen, Zeitdienst, begrenzt auf bekannte Ziele |
| Gäste | alle internen | verboten, nur Internet erlaubt |
| Gäste | Internet | erlaubt: HTTP, HTTPS, DNS |
| IoT | Server | erlaubt: nur der Dienst für Sensordaten, verschlüsselt |
| IoT | alle übrigen | verboten, auch nicht in das Internet ohne Freigabe |
| Management | Geräte | erlaubt: SSH und HTTPS, nur von Administrator-Arbeitsplätzen |

**Tabelle 4.2.** Ausschnitt der Kommunikationsmatrix. Alles, was nicht ausdrücklich erlaubt ist, ist verboten.

Die Matrix zeigt drei Grundsätze. Die Geschäftsführung bekommt im Netz keine Sonderrechte, sie erhält nur die Dienste, die sie tatsächlich nutzt. Der Server beginnt keine Verbindungen zu den Arbeitsplätzen. Die IoT-Geräte sprechen nur einen verschlüsselten Dienst im Serverbereich an und erreichen sonst nichts.

> **Merke**
>
> Segmentierung begrenzt die Ausbreitung eines Vorfalls. VLANs trennen auf Switchebene, aber die Kontrolle entsteht erst durch Routing, ACLs oder Firewall-Regeln zwischen den Zonen. Ohne Kommunikationsmatrix bleibt jede Trennung ungefähr.

## 4.18 Typische Segmentierungsfehler

Häufige Fehler sind: Das Native VLAN ist ein Benutzer-VLAN. Ein Trunk ist für Endgeräte geöffnet, die keinen Trunk brauchen. Die VLANs sind nicht gepflegt, und ungenutzte bleiben aktiv. Regeln zwischen VLANs sind so weit gefasst, dass sie fast alles erlauben. Die Matrix existiert nur im Kopf des Administrators. Und ein Gast-VLAN hat zwar eine eigene ID, aber kein eigenes Routing.

## 4.19 VLAN-Hopping und Schutzmaßnahmen

VLAN-Hopping bezeichnet Techniken, mit denen ein Angreifer den Verkehr eines fremden VLANs erreicht, obwohl sein Port einem anderen VLAN zugeordnet ist. Zwei Wege sind in der Fachliteratur bekannt: Die Täuschung als Switch, damit der Port in einen Trunk wechselt, und die doppelte Kennzeichnung eines Frames, bei der das Native VLAN ausgenutzt wird. Beide Wege sind nur möglich, wenn die Konfiguration Schwächen hat.

Die Schutzmaßnahmen sind klar und wirksam. Ports werden fest als Access- oder Trunk-Port konfiguriert, und die automatische Aushandlung von Trunks wird abgeschaltet. Das Native VLAN wird auf ein ungenutztes VLAN gelegt, das keinem Endgerät zugeordnet ist. Ungenutzte Ports werden deaktiviert und in ein Quarantäne-VLAN gelegt. Nicht benötigte VLANs werden von den Trunks entfernt. Eine Konfiguration nach diesen Regeln beseitigt die beschriebenen Angriffsmöglichkeiten im Wesentlichen.

Diese Angriffe beschreibe ich nur in der Form, die für die Abwehr nötig ist. Die Schutzmaßnahmen sind der eigentliche Lerninhalt.

> **Merke**
>
> Ein Trunk ist ein Vertrauensbereich. Wer ihn nicht bewusst konfiguriert, macht ihn zur Angriffsfläche. Feste Port-Rollen, ein ungenutztes Native VLAN und das Entfernen nicht benötigter VLANs sind die Grundregeln.

## Zusammenfassung

Segmentierung teilt das Netz in Zonen mit klaren Grenzen. VLANs nach IEEE 802.1Q trennen die Broadcast-Domänen auf dem Switch, die Kontrolle entsteht durch Routing, ACLs und Firewall-Regeln. Eine Kommunikationsmatrix macht die Entscheidungen nachvollziehbar und überprüfbar.

## Kontrollfragen

1. Warum ist ein VLAN allein noch keine Sicherheitsgrenze?
2. Was unterscheidet einen Access-Port von einem Trunk-Port?
3. Warum sollte das Native VLAN nicht für Benutzergeräte verwendet werden?
4. Welchen Vorteil bietet ein Layer-3-Switch gegenüber dem Router-on-a-Stick, und welchen Nachteil hat er unter Umständen für die Kontrolle?
5. Warum sind im Beispielunternehmen die Verbindungen von IoT-Geräten in alle übrigen Zonen verboten?

KAPITEL 5

# VPN verstehen

**Lernziele.** Nach diesem Kapitel kannst du erklären, was ein VPN leistet und warum es eingesetzt wird, das Tunnelprinzip mit Kapselung und Verschlüsselung beschreiben, Site-to-Site, Remote Access und Client-to-Site unterscheiden, Split und Full Tunneling bewerten und typische Probleme wie DNS-Lecks und MTU-Fehler diagnostizieren.

## 5.1 Was ist ein Virtual Private Network?

Ein Virtual Private Network, kurz VPN, verbindet zwei Netze oder ein Gerät mit einem Netz über ein öffentliches Netz so, dass der Verkehr geschützt ist. Der Begriff beschreibt das Ergebnis: Die Verbindung wirkt wie ein privates Netz, obwohl sie über das Internet läuft. Das VPN schafft also einen geschützten Kanal über einen unsicheren Weg.

Ein VPN gewährleistet in der Regel Vertraulichkeit und Integrität des Verkehrs sowie die Authentifizierung der Gegenstelle. Es ersetzt nicht die Sicherheit der Endgeräte oder der Dienste, die über den Tunnel erreicht werden. Ein Gerät, das über ein VPN verbunden ist und einen Schadcode enthält, bleibt gefährlich.

## 5.2 Warum werden VPNs eingesetzt?

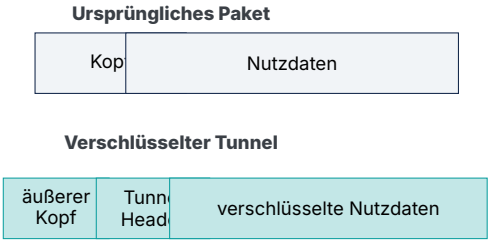
Der häufigste Grund ist der Zugriff von außen auf interne Ressourcen. Beschäftigte im Homeoffice oder auf Dienstreise brauchen Zugriff auf Dateien, Anwendungen und Verwaltungssysteme, die nicht öffentlich erreichbar sein dürfen. Ein zweiter Grund ist die Verbindung von Standorten, etwa einer Filiale mit der Zentrale. Ein dritter Grund ist der Schutz des Verkehrs in fremden Netzen, etwa in Hotels oder Flughäfen, wo die Verbindung nicht vertrauenswürdig ist.

Ein VPN ist kein Allheilmittel. Wer nur ein VPN einrichtet und sonst nichts, schiebt das Problem nach innen: Sobald jemand im Tunnel ist, sieht das Netz ihn als vertrauenswürdig. Diese Schwäche greift Zero Trust in Kapitel 8 auf.

## 5.3 Tunnelprinzip

Ein Tunnel verpackt Pakete in andere Pakete. Das ursprüngliche Paket, das innere, wird verschlüsselt und mit einem neuen Kopf versehen, dem äußeren. Der äußere Kopf enthält die Adressen der beiden Tunnelendpunkte. Für das öffentliche Netz sieht die Verbindung wie ein gewöhnlicher Datenverkehr zwischen zwei Gateways aus, der Inhalt ist nicht lesbar.

Am Zielende entfernt der Endpunkt den äußeren Kopf, entschlüsselt das innere Paket und leitet es in das Zielnetz weiter. Diese Kapselung ist der Kern des Verfahrens. Sie erklärt auch den Aufwand: Jedes Paket trägt zusätzliche Kopfdaten, und die Größe der Pakete wächst.




Schematische Darstellung. Die Breiten sind nicht maßstabsgetreu.

**Abbildung 5.1.** Kapselung im Tunnel. Das innere Paket wird verschlüsselt und mit einem Tunnelkopf und einem äußeren Kopf versehen, die die Endpunkte adressieren. Schematische Darstellung.

## 5.4 Verschlüsselung und Authentifizierung

Zwei Eigenschaften machen einen Tunnel zu einem VPN. Die Verschlüsselung schützt den Inhalt vor dem Mitlesen. Die Authentifizierung stellt sicher, dass beide Seiten die sind, für die sie sich ausgeben. Ohne Authentifizierung könnte ein Angreifer sich als Gegenstelle ausgeben und den Verkehr umleiten.

Die Authentifizierung kann auf Schlüsseln, Zertifikaten oder Benutzerdaten beruhen. Bei Benutzerdaten kommt oft eine zweite Prüfung hinzu, etwa eine Mehrfaktor-Abfrage. Der Schlüsselaustausch muss selbst geschützt sein, weil er die Grundlage der gesamten Verbindung bildet.

## 5.5 Tunneling-Protokolle

Es gibt mehrere Verfahren, die Tunnel aufbauen. IPsec ist ein Satz von Standards, der auf der Netzwerkschicht arbeitet und in Kapitel 7 behandelt wird. WireGuard ist ein neueres, schlankes Protokoll, das in Kapitel 6 erklärt wird. OpenVPN nutzt TLS und läuft über UDP oder TCP, meist auf Port 1194. Das Protokoll L2TP ist ein Tunnelprotokoll ohne eigene Verschlüsselung, es wird deshalb meist mit IPsec kombiniert. SSTP und ähnliche Verfahren kapseln den Verkehr in TLS-Verbindungen, was in restriktiven Netzen den Durchgang erleichtert.

Die Wahl hängt von Einsatz, Gegenstelle, Leistung, Verwaltung und den Anforderungen an Kompatibilität ab. Ein Protokoll ist nicht allein deshalb sicher, weil es verbreitet ist. Entscheidend ist die Umsetzung: aktuelle Algorithmen, sauber geprüfte Zertifikate und eine gepflegte Konfiguration.

## 5.6 Site-to-Site-VPN

Ein Site-to-Site-VPN verbindet zwei Netze dauerhaft miteinander. Die Gateways an beiden Standorten bauen den Tunnel auf, und die Geräte in den Netzen merken davon nichts. Eine Filiale kann so auf den Server der Zentrale zugreifen, als läge er im selben Gebäude. Der Tunnel läuft automatisch und wird bei Bedarf neu aufgebaut.

Bei dieser Variante ist die Verwaltung zentral. Die Gateways tragen die Verantwortung für Verschlüsselung und Routing, die Endgeräte bleiben unverändert. Gerade deshalb ist die Konfiguration der Gateways sorgfältig zu prüfen, denn ein Fehler betrifft ganze Standorte.

## 5.7 Remote-Access-VPN

Ein Remote-Access-VPN erlaubt einzelnen Benutzern von unterwegs den Zugang zum internen Netz. Der Benutzer startet eine Verbindung von seinem Gerät aus, meist über einen VPN-Client, und authentifiziert sich am VPN-Gateway. Nach erfolgreicher Anmeldung erhält das Gerät eine Adresse im Tunnelnetz und darf auf die freigegebenen Dienste zugreifen.

Der Begriff wird oft mit dem Client-to-Site-VPN gleichgesetzt. Beide meinen dasselbe: einen einzelnen Client, der sich mit einem Netz verbindet. Die Unterscheidung ist eher eine Frage der Terminologie, die je nach Hersteller und Literatur variiert.

## 5.8 Client-to-Site-VPN

Der Begriff Client-to-Site bezeichnet die gleiche Konstellation wie das Remote-Access-VPN: ein Client verbindet sich mit einem Standort. Im engeren Sinn betont er den Client als Gerät mit eigener Software und eigener Identität. Für die Planung sind die Fragen wichtiger als die Bezeichnung: Welche Geräte dürfen sich verbinden, wie werden sie authentifiziert, und welche Ressourcen sind erreichbar?

## 5.9 Split Tunneling und Full Tunneling

Bei Full Tunneling läuft der gesamte Datenverkehr des Clients durch den Tunnel, auch der Zugriff auf das Internet. Das Unternehmen behält damit die Kontrolle über alle Verbindungen, etwa über Filter und Protokollierung. Der Nachteil ist höhere Last auf dem Gateway und eine längere Strecke für jeden Webzugriff.

Bei Split Tunneling läuft nur der Verkehr zu bestimmten Netzen durch den Tunnel, der übrige Verkehr geht direkt ins Internet. Das entlastet das Gateway und verbessert die Geschwindigkeit für Webzugriffe. Der Nachteil ist, dass das Gerät gleichzeitig im Heimnetz oder in einem öffentlichen Netz und im Unternehmensnetz erreichbar ist. Ein Angreifer, der das Gerät über das Internet erreicht, kann so einen Weg ins Unternehmen finden.

Die Entscheidung ist eine Abwägung. Wer sensible Daten schützen muss, wählt meist Full Tunneling oder begleitet Split Tunneling mit einer Endpunktprüfung und einer Firewall auf dem Gerät.

## 5.10 VPN-Gateways und VPN-Clients

Das VPN-Gateway ist der Endpunkt im Unternehmen, der die Tunnel annimmt, entschlüsselt und in das Netz weiterleitet. Es ist oft eine Firewall mit VPN-Funktion oder ein dedizierter Server. Der VPN-Client läuft auf dem Gerät des Benutzers und baut die Verbindung auf. Clients können Standardsoftware des Betriebssystems sein oder eine Anwendung des Herstellers.

Das Gateway ist ein zentraler Punkt und damit ein lohnendes Ziel. Es muss deshalb besonders aktuell gehalten, überwacht und sparsam konfiguriert werden. Viele bekannte Sicherheitslücken betrafen VPN-Gateways verschiedener Hersteller, was zeigt, dass der Schutz des Gateways selbst wichtig ist.

## 5.11 Routing durch VPN-Tunnel

Ein Tunnel braucht Routen, damit Pakete den richtigen Weg nehmen. Im Site-to-Site-Fall stehen auf beiden Seiten Routen für das jeweils andere Netz, die auf den Tunnel zeigen. Beim Remote-Access-Fall bekommt der Client Routen für die freigegebenen Netze, meist über eine Konfiguration beim Verbindungsaufbau.

Ein häufiger Fehler ist eine fehlende Rückroute. Die Verbindung wird aufgebaut, aber die Antwort findet den Weg nicht zurück, weil das andere Netz den Tunnel nicht kennt. Die Fehlersuche folgt dann dem Weg eines Pakets Hop für Hop.

## 5.12 DNS im VPN

Namen werden über DNS aufgelöst. Wer eine interne Anwendung über ihren Namen erreichen will, braucht den internen DNS-Server im Tunnel. Wird der DNS-Verkehr nicht durch den Tunnel geleitet, fragt der Client öffentliche Server, und interne Namen lassen sich nicht auflösen. Umgekehrt kann eine Anfrage nach öffentlichen Namen über den Tunnel unnötig Last erzeugen.

Ein DNS-Leck entsteht, wenn der Client Namensanfragen an einen Server außerhalb des Tunnels sendet, obwohl der Tunnel aktiv ist. Dann verrät der Client, welche Ziele er ansprechen will, auch wenn der eigentliche Verkehr verschlüsselt ist. Das Problem tritt besonders bei Split Tunneling auf. Die Prüfung erfolgt durch den Blick, welcher DNS-Server tatsächlich antwortet, während der Tunnel aktiv ist.

## 5.13 MTU und typische VPN-Probleme

Die maximale Paketgröße heißt MTU, Maximum Transmission Unit. In Ethernet-Netzen beträgt sie häufig 1500 Byte. Ein Tunnel fügt Kopfdaten hinzu und verringert die Nutzlast, die in ein Paket passt. Ist die MTU im Tunnel zu groß eingestellt, werden Pakete zerteilt oder verworfen, wenn das Verbot der Fragmentierung gesetzt ist. Das Ergebnis sind Verbindungen, die zuerst funktionieren, aber bei großen Übertragungen hängen bleiben.

Typische Hinweise sind Webseiten, die laden, aber große Formulare oder Dateien nicht übertragen, und Verbindungen, die bei größeren Datenmengen abbrechen. Die Lösung ist eine kleinere MTU im Tunnel oder das Anpassen der maximalen Segmentgröße des TCP-Verkehrs. Wie groß der Abzug ist, hängt vom Protokoll und seinen Kopfdaten ab, deshalb ist die Herstellerdokumentation maßgeblich.

## 5.14 VPN-Sicherheit

Ein VPN ist nur so sicher wie seine Konfiguration und sein Zustand. Dazu gehören aktuelle Software, starke Algorithmen, Zertifikate mit gültiger Prüfung und Mehrfaktor-Authentifizierung für Benutzer. Konten sollten nur die Zugriffe bekommen, die sie brauchen. Protokolle des Gateways müssen aufgehoben und ausgewertet werden.

Ein weiterer Punkt betrifft den Client. Ein VPN schützt den Weg, nicht das Endgerät. Ein kompromittierter Laptop, der sich über ein gültiges VPN verbindet, ist für das Netz ein vertrauenswürdiger Gast. Deshalb sollten Clients auf aktuellen Stand geprüft werden, bevor sie sich verbinden dürfen. Dieser Gedanke führt zu Zero Trust.

## 5.15 Vor- und Nachteile verschiedener VPN-Varianten

Die folgende Tabelle fasst die Varianten zusammen. Sie zeigt Tendenzen, keine feste Rangfolge.

| Variante | Vorteile | Nachteile |
|---|---|---|
| Site-to-Site | Dauerhaft, transparent für Geräte, zentral verwaltet | Fehler betreffen ganze Standorte, Gateway-Abhängigkeit |
| Remote Access | Flexibel, pro Benutzer steuerbar | Client-Software nötig, Gerät wird Teil des Netzes |
| Full Tunneling | Volle Kontrolle über den Verkehr | Höhere Last, längere Wege, mehr Verkehr im Gateway |
| Split Tunneling | Entlastung, schnelle Internetzugriffe | Doppelte Erreichbarkeit, Risiko des Gerätes steigt |

**Tabelle 5.1.** Vor- und Nachteile der VPN-Varianten im Überblick. Die Einordnung ist vereinfacht und hängt vom Einzelfall ab.

> **Merke**
>
> Ein VPN verschlüsselt und authentifiziert den Weg, nicht das Ziel. Site-to-Site verbindet Standorte, Remote Access verbindet Personen. Full Tunneling kontrolliert den gesamten Verkehr, Split Tunneling entlastet und öffnet eine zweite Verbindung. DNS und MTU sind die häufigsten Stolpersteine.

## Zusammenfassung

Ein VPN schafft einen geschützten Kanal über ein unsicheres Netz. Das Tunnelprinzip kapselt Pakete, Verschlüsselung und Authentifizierung schützen den Verkehr. Die Variante richtet sich nach der Verbindung, Routing, DNS und MTU bestimmen den Erfolg im Betrieb, und die Sicherheit des Gateways und der Clients entscheidet über den Schutz.

## Kontrollfragen

1. Welche zwei Eigenschaften machen einen Tunnel zu einem VPN?
2. Was passiert mit dem ursprünglichen Paket im Tunnel?
3. Worin liegt der Unterschied zwischen Full Tunneling und Split Tunneling in Bezug auf das Gateway?
4. Woran erkennt man ein DNS-Leck, und warum ist es problematisch?
5. Warum führt eine zu große MTU im Tunnel zu Verbindungen, die zuerst funktionieren und dann hängen bleiben?

KAPITEL 6

# WireGuard in der Praxis

**Lernziele.** Nach diesem Kapitel kannst du das Funktionsprinzip von WireGuard erklären, die Rolle von Schlüsseln, Peers, AllowedIPs, Endpoint und PersistentKeepalive beschreiben, eine Beispielkonfiguration für ein Testnetz lesen und anpassen, Firewall-Regeln für den Tunnel formulieren und typische Fehler mit den Bordmitteln prüfen.

**Hinweis zu den Beispielen.** Alle Adressen, Schlüssel und Namen in diesem Kapitel sind Testwerte für ein eigenes Labornetz. Die Adressen stammen aus den für Dokumentation reservierten Bereichen nach RFC 5737 und dürfen nicht im Internet verwendet werden. Die Schlüssel sind Platzhalter. Erzeuge für jede Umgebung eigene Schlüssel und veröffentliche private Schlüssel nie.

## 6.1 Was ist WireGuard?

WireGuard ist ein VPN-Protokoll, das bewusst klein gehalten wurde. Der Quelltext umfasst nur wenige tausend Zeilen, und das Protokoll nutzt eine feste Auswahl moderner kryptografischer Verfahren. Diese Beschränkung soll die Prüfbarkeit verbessern: Weniger Code und weniger Auswahlmöglichkeiten bedeuten weniger Stellen, an denen eine Fehlkonfiguration oder eine Schwachstelle entstehen kann.

Seit Version 5.6 ist WireGuard Bestandteil des Linux-Kernels. Für viele Systeme gibt es zudem Anwendungen und Treiber. Das Protokoll arbeitet über UDP, der Standardport ist 51820, und es verbindet Geräte über Schlüssel statt über Benutzerkonten.

## 6.2 Architektur und Funktionsprinzip

WireGuard erzeugt eine virtuelle Netzwerkschnittstelle, meist mit dem Namen wg0. Jeder Verkehr, der über diese Schnittstelle geroutet wird, wird verschlüsselt und über UDP an den zugehörigen Peer geschickt. Auf der Gegenseite wird er entschlüsselt und in das Netz des Empfängers weitergeleitet.

Das Protokoll kennt keinen eigenen Verbindungsaufbau im klassischen Sinn. Ein Handshake baut die Sitzungsschlüssel auf, sobald Verkehr zu einem Peer fließt. Danach werden die Schlüssel regelmäßig erneuert. Für die Verschlüsselung nutzt WireGuard

ChaCha20 mit Poly1305, für den Schlüsselaustausch Curve25519, und als Hashfunktion BLAKE2s. Der Handshake folgt dem Noise-Framework.

Ein besonderes Merkmal ist das Cryptokey Routing. Der öffentliche Schlüssel eines Peers und die erlaubten Adressen gehören zusammen. Ein Paket wird nur an den Peer gesendet, dessen AllowedIPs seine Zieladresse enthalten, und nur Pakete mit einer passenden Quelladresse werden vom Peer angenommen.

## 6.3 Public- und Private-Keys

Jedes Gerät besitzt ein Schlüsselpaar aus einem privaten und einem öffentlichen Schlüssel. Der private Schlüssel bleibt auf dem Gerät und darf nicht weitergegeben werden. Der öffentliche Schlüssel wird dem Gegenüber mitgeteilt und in dessen Konfiguration eingetragen. Die Identität eines Peers ist damit der öffentliche Schlüssel.

Die Schlüssel werden mit den Werkzeugen von WireGuard erzeugt. Der private Schlüssel wird mit einer Befehlszeile erzeugt, der öffentliche Schlüssel daraus abgeleitet. Die Dateien erhalten nur Rechte für den Besitzer, damit andere Benutzer sie nicht lesen können. Eine Konfigurationsdatei, die einen privaten Schlüssel enthält, ist so schützenswert wie das Passwort eines Administrators.

Bei einer Kompromittierung eines Schlüssels wird das Schlüsselpaar sofort ersetzt und auf allen Gegenstellen aktualisiert. Ein gestohlener privater Schlüssel erlaubt, sich als Peer auszugeben, deshalb ist die schnelle Rotation ein wichtiger Teil des Betriebs.

## 6.4 Peers

Ein Peer ist ein Gegenüber im Tunnel, also ein Server oder ein Client. Jeder Peer wird über seinen öffentlichen Schlüssel eindeutig beschrieben. Ein Server kennt in seiner Konfiguration alle Clients, die sich mit ihm verbinden dürfen. Ein Client kennt im einfachsten Fall nur den Server.

## 6.5 AllowedIPs

AllowedIPs ist die wichtigste Einstellung eines Peers. Sie erfüllt zwei Aufgaben. Erstens legt sie fest, welche Adressen über diesen Peer geroutet werden. Zweitens filtert sie: Vom Peer kommen nur Pakete mit einer Quelladresse aus dieser Liste an. Ein Client, der 0.0.0.0/0 angibt, leitet den gesamten IPv4-Verkehr über den Tunnel, also Full Tunneling. Ein Client mit 10.99.0.0/24 leitet nur das Tunnelnetz, also Split Tunneling.

Die Einstellung ist deshalb mehr als eine Routenangabe. Eine zu weit gefasste Liste auf dem Server lässt einen Client beliebige Adressen im Netz erreichen und Pakete mit fremden Quelladressen einschleusen. Die Liste sollte so eng wie möglich sein.

## 6.6 Endpoint

Der Endpoint ist die Adresse und der Port, unter dem ein Peer erreichbar ist. Der Client kennt den Endpoint des Servers, damit er den Tunnel aufbauen kann. Der Server muss in der Regel keinen Endpoint der Clients kennen, weil WireGuard die Adresse aus dem letzten gültigen Paket übernimmt. Dieses Verhalten erlaubt Clients, die häufig ihre Adresse wechseln, etwa im Mobilfunknetz.

## 6.7 PersistentKeepalive

Hinter einer NAT-Umsetzung, etwa in einem Heimrouter, schließt die Umsetzung eine untätige Verbindung nach kurzer Zeit. Der Tunnel stirbt dann, ohne dass es auffällt, bis wieder Verkehr fließt. PersistentKeepalive sendet in festen Abständen ein kleines Paket, damit die Zuordnung in der NAT-Tabelle bestehen bleibt. Ein Wert von 25 Sekunden ist ein verbreiteter Ausgangswert. Ein Server mit öffentlicher Adresse braucht diese Einstellung nicht.

## 6.8 Handshake

Der Handshake verbindet die beiden Peers über den Austausch öffentlicher Schlüssel. Er erzeugt neue Sitzungsschlüssel und läuft in regelmäßigen Abständen erneut. Der Zeitpunkt des letzten erfolgreichen Handshakes ist das wichtigste Zeichen für den Zustand des Tunnels. Gibt es seit längerer Zeit keinen Handshake, ist der Tunnel nicht aktiv, egal was die Konfiguration sagt.

## 6.9 Verschlüsselung

WireGuard verschlüsselt jeden Datenpfad mit einem authentifizierten Verfahren. Die Verschlüsselung schützt die Vertraulichkeit, und die Authentifizierung schützt die Integrität und die Herkunft der Pakete. Ein gefälschtes Paket wird verworfen, ohne dass der Empfänger Rückmeldungen gibt. Diese Stille ist beabsichtigt: Ein Angreifer erfährt aus einer verworfenen Nachricht nichts über den Tunnel.

## 6.10 WireGuard unter Linux

Unter Linux sind die Werkzeuge wg für die Steuerung und wg-quick für den Auf- und Abbau aus einer Konfigurationsdatei verfügbar. Die Paketnamen unterscheiden sich je nach Distribution. Die Konfiguration liegt meist unter /etc/wireguard/ und trägt den Namen der Schnittstelle, etwa wg0.conf. Wer den Tunnel startet, braucht Root-Rechte, weil eine Netzwerkschnittstelle angelegt wird.

## 6.11 Installation und Grundkonfiguration

Die Installation erfolgt über die Paketverwaltung der Distribution. Danach erzeugt man für jedes Gerät ein Schlüsselpaar. Die Dateirechte werden auf den Besitzer beschränkt. Anschließend wird die Konfiguration geschrieben, die Schnittstelle gestartet und die Verbindung geprüft.

Die folgende Tabelle beschreibt das Testnetz, das in den nächsten Abschnitten verwendet wird.

| Gerät | Tunneladresse | Öffentlicher Endpunkt |
|---|---|---|
| Server (Testwert) | 10.99.0.1/24 | 198.51.100.10:51820 |
| Client A (Testwert) | 10.99.0.2/24 | hinter NAT, kein fester Endpoint |
| Testnetz intern | 10.20.0.0/24 | Ziel hinter dem Server |

**Tabelle 6.1.** Testnetz für die Beispiele dieses Kapitels. Alle Werte sind Testwerte aus den Dokumentationsbereichen.

## 6.12 Konfiguration eines Server-Peers

Die folgende Konfiguration gehört auf den Server. Sie enthält den privaten Schlüssel des Servers und den öffentlichen Schlüssel des Clients. Die Schlüssel sind Platzhalter.

```
[Interface]
Address = 10.99.0.1/24
ListenPort = 51820
PrivateKey = SERVER_PRIVATKEY_PLATZHALTER

[Peer]
# Client A (Testwert)
```

```
PublicKey = CLIENT_A_PUBLICKEY_PLATZHALTER
AllowedIPs = 10.99.0.2/32
```

Der Server nimmt keine Adressen außer 10.99.0.2 von diesem Peer an. Antworten an den Client laufen über denselben Peer zurück, weil der Server die Adresse 10.99.0.2 diesem Peer zuordnet. Die Einstellung PersistentKeepalive fehlt, weil der Server eine öffentliche Adresse hat.

## 6.13 Konfiguration eines Client-Peers

Die Konfiguration auf dem Client enthält den privaten Schlüssel des Clients und den öffentlichen Schlüssel des Servers.

```
[Interface]
Address = 10.99.0.2/24
PrivateKey = CLIENT_A_PRIVATKEY_PLATZHALTER

[Peer]
PublicKey = SERVER_PUBLICKEY_PLATZHALTER
Endpoint = 198.51.100.10:51820
AllowedIPs = 10.99.0.0/24, 10.20.0.0/24
PersistentKeepalive = 25
```

Diese Konfiguration leitet nur das Testnetz und das Ziel 10.20.0.0/24 über den Tunnel. Der übrige Verkehr bleibt im lokalen Netz, es handelt sich also um Split Tunneling. Für Full Tunneling würde man 0.0.0.0/0 eintragen. Die Keepalive-Einstellung hilft, weil der Client hinter einer NAT-Umsetzung sitzt.

## 6.14 Site-to-Site-Verbindungen

Bei einer Site-to-Site-Verbindung hat jedes Gateway ein eigenes Netz hinter sich. Jedes Gateway ist Peer des anderen und trägt das Netz des Gegenübers in AllowedIPs ein. Das Prinzip ist dasselbe wie bei Clients, nur dass beide Seiten Routen für Netze anbieten. Ein Fehler in AllowedIPs betrifft dann ein ganzes Netz, deshalb sollte jede Liste bewusst gepflegt werden.

## 6.15 Routing durch den Tunnel

Die Routen entstehen durch die AllowedIPs. Die Konfiguration wird über wg-quick in Routen übersetzt, sodass das Betriebssystem die Pakete in die Schnittstelle leitet. Auf dem Server muss die Route zum Client-Netz zusätzlich stimmen, wenn Pakete aus dem Server-Netz zurückgeleitet werden sollen. Das Weiterleiten zwischen Netzen erfordert außerdem die Aktivierung der IP-Weiterleitung im Betriebssystem des Gateways.

## 6.16 Firewall-Regeln für WireGuard

Die Firewall muss den UDP-Port des Servers erlauben, sonst kommt kein Handshake zustande. Im Testnetz gilt eine Regel für UDP 51820 aus dem öffentlichen Netz. Darüber hinaus kontrolliert die Firewall, welche Verbindungen durch den Tunnel erlaubt sind, denn WireGuard entscheidet nur über den Schlüssel, nicht über die Dienste. Die Regeln aus Kapitel 3 bleiben also wirksam, wenn der Tunnelverkehr ins interne Netz weitergeleitet wird.

## 6.17 Schlüsselverwaltung

Die Schlüssel sind der Kern der Sicherheit. Sie sollten für jedes Gerät getrennt erzeugt, sicher gespeichert und regelmäßig geprüft werden. Ein Verzeichnis aller öffentlichen Schlüssel mit Gerät, Besitzer und Ausgabedatum hilft beim Wechsel. Ein Gerät, das verloren geht oder ausscheidet, muss aus allen Peer-Listen entfernt werden, bevor der Tunnel wieder genutzt wird. Ein optionaler Pre-Shared-Key erhöht die Sicherheit zusätzlich, ist aber nur sinnvoll, wenn er ebenfalls sicher verteilt und verwaltet wird.

## 6.18 Fehleranalyse

Der wichtigste Befehl ist wg show. Er zeigt den Zustand jeder Schnittstelle, die Peers, die Endpunkte, den Zeitpunkt des letzten Handshakes und die übertragene Datenmenge. Ein fehlender Handshake deutet auf Probleme mit Schlüsseln, Endpunkt oder Firewall hin. Ein Handshake, der besteht, aber kein Verkehr, deutet auf Routing oder AllowedIPs hin.

Typische Ursachen sind vertauschte öffentliche und private Schlüssel, eine falsche Portangabe, eine Firewall, die UDP blockiert, eine fehlende Route, eine zu enge oder falsche AllowedIPs-Liste oder ein fehlendes PersistentKeepalive hinter NAT. Die Fehlersuche folgt dem Weg: Schlüssel, Handshake, Routing, Firewall, Dienst.

## 6.19 Sicherheits-Best-Practices

Die wichtigsten Maßnahmen sind einfach. Private Schlüssel bleiben auf dem Gerät und in Dateien mit Rechten nur für den Besitzer. AllowedIPs wird so eng gefasst wie möglich. Jedes Gerät erhält ein eigenes Schlüsselpaar, und ausscheidende Geräte werden sofort entfernt. Die Firewall erlaubt nur den nötigen UDP-Port und die nötigen Verbindungen. Die Software wird aktuell gehalten. Konfigurationsdateien werden nicht in Versionsverwaltungen oder Chats kopiert, wo sie öffentlich werden könnten.

> **Merke**
>
> WireGuard ist klein, schlüsselbasiert und über AllowedIPs eng mit dem Routing verbunden. AllowedIPs entscheidet darüber, was geroutet und was akzeptiert wird. Der letzte erfolgreiche Handshake zeigt, ob der Tunnel lebt. Private Schlüssel gehören ausschließlich auf das Gerät, das sie besitzt.

## Zusammenfassung

WireGuard verbindet Geräte über Schlüssel und feste kryptografische Verfahren. AllowedIPs steuert Routing und Filterung, Endpoint und PersistentKeepalive sichern die Verbindung auch hinter NAT. Der Handshake und die Firewall entscheiden über den Betrieb, und die Schlüsselverwaltung über die Sicherheit.

## Kontrollfragen

1. Welche zwei Aufgaben erfüllt AllowedIPs?
2. Warum benötigt ein Client hinter einer NAT-Umsetzung oft PersistentKeepalive, ein Server mit öffentlicher Adresse dagegen nicht?
3. Was zeigt ein fehlender Handshake, und was ein Handshake ohne Verkehr?
4. Welche Folge hat ein zu weit gefasstes AllowedIPs auf dem Server?
5. Warum sollte ein ausscheidendes Gerät sofort aus allen Peer-Listen entfernt werden?

KAPITEL 7

# IPsec verstehen

**Lernziele.** Nach diesem Kapitel kannst du erklären, was IPsec leistet, AH und ESP unterscheiden, Transport- und Tunnelmodus einordnen, den Aufbau einer Verbindung über IKEv2 mit Security Associations beschreiben, NAT-Traversal und die nötigen Firewall-Freigaben begründen, typische Fehler diagnostizieren und IPsec gegen WireGuard abwägen.

**Hinweis zu den Beispielen.** Adressen in diesem Kapitel stammen aus den Dokumentationsbereichen nach RFC 5737, Zertifikatsnamen und Schlüssel sind Platzhalter. Die Konfigurationsbeispiele sind für ein Labor gedacht und ersetzen keine Planung für ein Produktivnetz.

## 7.1 Was ist IPsec?

IPsec, kurz für Internet Protocol Security, ist eine Sammlung von Standards, die Sicherheitsfunktionen auf der Netzwerkschicht bereitstellen. Eine IPsec-Verbindung schützt IP-Pakete, unabhängig von der Anwendung darüber. Der Schutz umfasst Vertraulichkeit, Integrität und die Authentifizierung der Gegenstelle, je nach Konfiguration in unterschiedlicher Kombination.

IPsec ist im Gegensatz zu WireGuard kein einzelnes Protokoll, es ist ein Gerüst aus mehreren Komponenten: Die Pakete werden mit ESP oder AH geschützt, der Schlüsselaustausch läuft über IKE, und die ausgehandelten Parameter werden in Security Associations gespeichert. Diese Vielfalt macht IPsec flexibel, aber auch komplex.

## 7.2 Einsatzgebiete

IPsec ist seit vielen Jahren in Unternehmensnetzen verbreitet. Es verbindet Standorte per Site-to-Site-VPN, bindet Mitarbeitende über Remote-Access-Verbindungen an, und es ist in vielen Routern, Firewalls und Gateways als Standardfunktion enthalten. Auch Geräte verschiedener Hersteller können über IPsec zusammenarbeiten, weil der Standard festlegt, wie Verhandlung und Pakete aussehen.

Die Verbreitung hat einen praktischen Grund: Viele Organisationen haben bereits

Hardware mit IPsec-Unterstützung im Einsatz und Prozesse dafür etabliert. Wo Compliance-Vorgaben bestimmte Verfahren oder Zertifizierungen verlangen, ist IPsec oft die vorgegebene Wahl.

## 7.3 AH und ESP

IPsec schützt Pakete über zwei Protokolle. Der Authentication Header, kurz AH, stellt Integrität und Authentizität sicher, verschlüsselt aber nichts. Der Inhalt eines AH-geschützten Pakets ist also lesbar. AH wird heute kaum noch eingesetzt, weil er nicht mit NAT zusammenarbeitet, das die Adressen im Paket verändert.

Der Encapsulating Security Payload, kurz ESP, verschlüsselt die Nutzdaten und sichert optional auch die Integrität. ESP ist das Protokoll, das in der Praxis den Verkehr schützt. Moderne Konfigurationen nutzen ESP mit einem authentifizierten Verschlüsselungsverfahren, das Verschlüsselung und Integrität in einem Schritt erledigt. Die Protokollnummern sind festgelegt: ESP trägt die IP-Protokollnummer 50, AH die 51.

## 7.4 Transportmodus

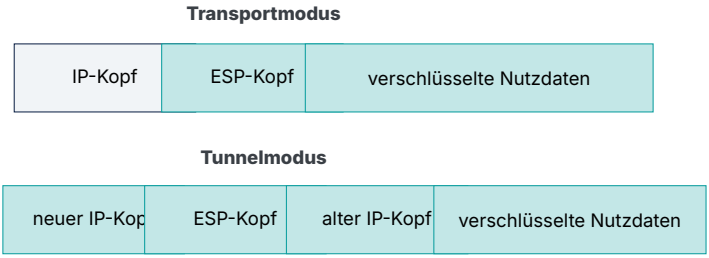
Im Transportmodus wird nur die Nutzlast des IP-Pakets geschützt, der ursprüngliche IP-Kopf bleibt erhalten. Die Endgeräte sprechen direkt miteinander, und der IPsec-Schutz liegt auf dem Gerät selbst. Der Transportmodus eignet sich für die Verbindung zwischen zwei Hosts, etwa zwischen Server und Verwaltungsrechner.

Der Nachteil ist, dass der ursprüngliche Kopf sichtbar bleibt und die Adressen der Endgeräte offen liegen. Außerdem muss jeder Host IPsec unterstützen.

## 7.5 Tunnelmodus

Im Tunnelmodus wird das gesamte ursprüngliche IP-Paket geschützt und in ein neues IP-Paket verpackt. Der äußere Kopf trägt die Adressen der beiden Tunnel-Endpunkte, der innere die der eigentlichen Kommunikationspartner. Das Gateway übernimmt Verschlüsselung und Kapselung, die Endgeräte im Netz bemerken davon nichts.

Der Tunnelmodus ist der Standard für Site-to-Site-Verbindungen. Er verbirgt die internen Adressen nach außen und schützt ganze Netze, ohne dass jedes Gerät angepasst werden muss.




Schematische Darstellung. Die Breiten sind nicht maßstabsgetreu.

**Abbildung 7.1.** Aufbau der Pakete im Transportmodus und im Tunnelmodus. Im Tunnelmodus wird das gesamte ursprüngliche Paket geschützt und mit einem neuen Kopf versehen. Schematische Darstellung.

## 7.6 IKE und IKEv2

Die Verschlüsselung braucht Schlüssel, die beide Seiten kennen, ohne dass sie über das Netz im Klartext übertragen werden. Dafür ist das Internet Key Exchange Protokoll zuständig, kurz IKE. Die aktuelle Version IKEv2 ist in RFC 7296 beschrieben und ersetzt die ältere IKEv1.

IKEv2 läuft über UDP auf Port 500. Der Ablauf besteht aus einem Austausch, der die Verbindung absichert, und einem zweiten, der die Verbindung für den Datenverkehr einrichtet. Dabei werden Algorithmen verhandelt, Identitäten bestätigt und ein Schlüsselaustausch mit Diffie-Hellman oder einem elliptischen Verfahren durchgeführt. Wer die Verbindung initiiert, sendet zuerst die Vorschläge, die Gegenstelle wählt daraus aus.

Die Trennung in zwei Austauschvorgänge hat eine Folge: IKEv2 braucht weniger Nachrichten als das alte Verfahren und ist robuster bei Fehlern. Für die Fehlersuche bedeutet das, dass man die beiden Schritte getrennt betrachtet.

## 7.7 Security Associations

Eine Security Association, kurz SA, ist die Vereinbarung über einen geschützten Kanal in eine Richtung. Sie enthält die verhandelten Algorithmen, die Schlüssel, die Lebensdauer und eine Kennung, den Security Parameter Index, kurz SPI. Eine vollständige Verbindung besteht aus mindestens zwei SAs, je eine für jede Richtung. Die IKE-SA schützt den Austausch der Verhandlung selbst, die Child-SA schützt die Datenpakete.

Die Kennung im Paket zeigt dem Empfänger, welche SA zu verwenden ist. Die Gegenseite hat die Schlüssel in ihrer Tabelle, sodass sie das Paket zuordnen kann. Ein Paket mit unbekannter Kennung wird verworfen. Läuft die Lebensdauer einer SA ab, wird sie erneuert, damit Schlüssel nicht unbegrenzt genutzt werden.

## 7.8 Authentifizierung

Bevor eine Verbindung aufgebaut wird, müssen sich beide Seiten ausweisen. Die gebräuchlichen Verfahren sind ein gemeinsamer geheimer Schlüssel, ein sogenannter Pre-Shared Key, Zertifikate aus einer Public-Key-Infrastruktur und die Anmeldung über EAP für Benutzer.

Ein Pre-Shared Key ist einfach einzurichten, skaliert aber schlecht: Jeder neue Standort oder Benutzer braucht den gleichen Schlüssel, und ein bekannt gewordener Schlüssel betrifft alle. Zertifikate sind aufwendiger, bieten aber eine klare Zuordnung, Gültigkeitsdauer und Sperrung. Für Benutzer ist EAP mit Mehrfaktor-Authentifizierung der übliche Weg, wie in Kapitel 9 ausführlicher behandelt wird.

## 7.9 Verschlüsselungsalgorithmen

Die Wahl der Algorithmen entscheidet über die Sicherheit. Empfohlen sind heute authentifizierte Verschlüsselungsverfahren wie AES im GCM-Modus, das Verschlüsselung und Integrität in einem Schritt liefert. Für den Schlüsselaustausch sind Diffie-Hellman-Gruppen mit ausreichender Länge oder elliptische Kurven üblich. Veraltet und nicht mehr zu verwenden sind DES und 3DES sowie Verfahren mit SHA-1 für die Integrität in neuen Konfigurationen.

Die aktuellen Empfehlungen des BSI in der Technischen Richtlinie TR-02102 legen geeignete Verfahren und Mindestlängen fest. Dort ist zu prüfen, welche Verfahren zum Zeitpunkt der Einrichtung zulässig sind, denn die Empfehlungen werden fortgeschrieben.

## 7.10 Integritätsschutz

Integrität bedeutet, dass ein Paket auf dem Weg nicht verändert werden kann, ohne dass der Empfänger es bemerkt. Bei ESP geschieht das über einen Authentifizierungswert, der das Paket absichert. Bei AEAD-Verfahren wie AES-GCM ist die Integritätsprüfung Teil der Verschlüsselung. Ein verändertes Paket wird verworfen, und der Empfänger sendet keine Rückmeldung darüber, was genau fehlgeschlagen ist.

## 7.11 Diffie-Hellman-Schlüsselaustausch

Der Diffie-Hellman-Schlüsselaustausch erlaubt beiden Seiten, einen gemeinsamen geheimen Schlüssel zu bilden, ohne ihn zu übertragen. Die öffentlichen Teile werden ausgetauscht, und jede Seite berechnet mit ihrem eigenen geheimen Teil denselben Wert. Ein Beobachter sieht nur die öffentlichen Teile und kann den Schlüssel nicht daraus ableiten, nach dem heutigen Stand der Technik.

Perfect Forward Secrecy bedeutet, dass ein neuer Schlüsselaustausch für jede Child-SA stattfindet. Wird später der langfristige Schlüssel bekannt, bleiben frühere Sitzungen geschützt. Diese Eigenschaft ist in modernen Konfigurationen Standard und sollte bewusst eingeschaltet bleiben.

## 7.12 Site-to-Site-IPsec

Bei Site-to-Site-IPsec bauen zwei Gateways eine Verbindung zwischen ihren Netzen auf. Jedes Gateway kennt die Netze auf der Gegenseite. Die Verschlüsselung und das Routing übernehmen die Gateways, die Geräte dahinter bleiben unberührt. Die Verhandlung legt sogenannte Traffic Selectors fest, also die Netze, die durch die Child-SA geschützt werden.

Ein häufiger Fehler sind nicht übereinstimmende Traffic Selectors. Stimmen die Netze auf beiden Seiten nicht überein, entsteht eine Verbindung, die steht, aber keine Daten transportiert.

## 7.13 Remote-Access-IPsec

Beim Remote-Access-Einsatz verbindet sich ein Client mit dem Gateway des Unternehmens. Der Client erhält eine Adresse im Unternehmensnetz oder in einem Tunnelnetz. Mit IKEv2 und EAP lässt sich die Anmeldung eines Benutzers mit Mehrfaktor-Authentifizierung verbinden. Viele Betriebssysteme bringen einen IPsec-Client mit, der sich ohne Zusatzsoftware einrichten lässt.

## 7.14 NAT-Traversal

NAT verändert die Adressen auf dem Weg, und ESP trägt keine Ports. Ein NAT-Gerät kann die Verbindung deshalb nicht einem Gerät zuordnen, und ESP-Pakete werden oft verworfen oder falsch zugeordnet. Die Lösung heißt NAT-Traversal. Die ESP-Pakete

werden in UDP eingepackt und über Port 4500 gesendet. Das NAT-Gerät kann sie dann wie gewöhnlichen UDP-Verkehr behandeln.

Die Aushandlung erkennt, ob ein NAT auf dem Weg liegt. Dann wechselt die Verbindung automatisch auf den UDP-Port 4500. Für die Fehlersuche ist wichtig, dass der Port freigegeben sein muss, sonst bleibt der Tunnel hinter einem NAT dauerhaft unterbrochen.

## 7.15 IPsec und Firewall

Für eine IPsec-Verbindung braucht die Firewall vier Freigaben. UDP 500 für IKE, UDP 4500 für NAT-Traversal, ESP mit der IP-Protokollnummer 50, und AH mit der Nummer 51, falls es benutzt wird. Die Freigabe von ESP ist eine Freigabe eines IP-Protokolls und nicht eines Ports. Viele Firewalls behandeln diesen Fall anders, deshalb muss die Regel ausdrücklich das Protokoll erlauben.

Die Regeln sollten auf die Gegenstellen beschränkt sein. Eine Freigabe von UDP 500 für alle Adressen aus dem Internet ist nicht nötig, wenn nur ein bekannter Standort verbinden soll. Die Vorgehensweise aus Kapitel 3 gilt auch hier.

## 7.16 IPsec unter Linux

Unter Linux übernimmt der Kernel die Verschlüsselung über das XFRM-Framework. Die Verhandlung und Verwaltung der Verbindungen übernimmt ein Dienst wie strongSwan oder Libreswan. Die Konfiguration erfolgt meist über eine Datei, die Verbindungen, Zertifikate und Algorithmen beschreibt. Die Datei hat eine feste Struktur, die sich je nach Software unterscheidet.

Das folgende Beispiel zeigt die Grundstruktur für ein Labor mit strongSwan und zertifikatsbasierter Authentifizierung. Die Namen, Zertifikate und Adressen sind Platzhalter aus dem Dokumentationsbereich.

```
connections {
  standort-a {
    version = 2
    local_addrs = 198.51.100.10
    remote_addrs = 203.0.113.20
    proposals = aes256-sha384-ecp384
    local {
      auth = pubkey
```

```
      certs = gateway-a-platzhalter.pem
      id = gateway-a.example.test
    }
    remote {
      auth = pubkey
      id = gateway-b.example.test
    }
    children {
      standort-a-netz {
        local_ts = 10.20.0.0/24
        remote_ts = 10.30.0.0/24
        esp_proposals = aes256gcm16-ecp384
        start_action = start
      }
    }
  }
}
```

Die Datei beschreibt eine Verbindung zwischen zwei Gateways. Die Vorschläge legen Verschlüsselung und Schlüsselaustausch fest, die Traffic Selectors die geschützten Netze. Der Eintrag start_action sorgt dafür, dass die Verbindung beim Start aufgebaut wird. Ein Test mit einem Paket aus dem Netz A in das Netz B zeigt, ob der Tunnel funktioniert.

## 7.17 Typische Fehler und deren Diagnose

Die häufigsten Ursachen für eine nicht funktionierende IPsec-Verbindung lassen sich in wenige Gruppen einteilen. Die Verhandlung scheitert, wenn die Vorschläge nicht zusammenpassen. Die Authentifizierung scheitert bei falschen oder abgelaufenen Zertifikaten, bei nicht übereinstimmenden Identitäten oder bei einer fehlerhaften Zeit auf einer Seite, weil Zertifikate an Gültigkeitszeiträume gebunden sind. Ein NAT ohne Freigabe von UDP 4500 verhindert den Aufbau. Eine falsche Route oder falsche Traffic Selectors lassen den Tunnel stehen, aber ohne Verkehr. Eine zu große MTU führt zu den Problemen, die Kapitel 5 beschrieben hat.

Die Diagnose folgt dem Ablauf: Zuerst prüft man, ob die IKE-SA steht, dann die Child-SA, dann die Routen und zuletzt die Firewall. Die Protokolle des Dienstes zeigen meist genau, an welcher Stelle die Verhandlung scheitert. Die Meldungen sind ausführlich und sollten geprüft statt gelöscht werden.

## 7.18 Vergleich mit WireGuard

Die folgende Tabelle stellt beide Verfahren gegenüber. Eine pauschale Aussage, dass eines der beiden grundsätzlich sicherer sei, ist nicht möglich. Beide liefern bei sorgfältiger Konfiguration einen starken Schutz, unterscheiden sich aber in Umfang, Verwaltung und Einsatz.

| Merkmal | IPsec | WireGuard |
|---|---|---|
| Architektur | mehrere Standards, Verhandlung über IKE, SAs | ein Protokoll, Schlüssel und AllowedIPs |
| Konfiguration | umfangreich, viele Vorschläge und Traffic Selectors | kurz, eine Schlüsselzuordnung je Peer |
| Verschlüsselung | flexibel, viele Verfahren, Auswahl nötig | feste, moderne Verfahren |
| Einsatz | Hardware-Interoperabilität, Compliance, Standortverbindungen | schlanke Standortverbindungen, Clients, Roaming |
| Verwaltung | oft mit PKI, Zertifikatslebenszyklus | Schlüsselverteilung durch den Betreiber |
| NAT | NAT-Traversal über UDP 4500 | UDP, Keepalive für NAT |

**Tabelle 7.1.** Vergleich von IPsec und WireGuard. Die Tabelle zeigt Unterschiede in Umfang und Betrieb, sie bewertet die Sicherheit nicht pauschal.

Für die Wahl zählen die konkreten Anforderungen. Ein Unternehmen mit vorhandenen Geräten, Zertifikatsinfrastruktur und Compliance-Vorgaben findet bei IPsec gute Gründe. Ein kleines Team, das schlanke Verbindungen zu Clients und Standorten braucht, findet bei WireGuard einen einfacheren Betrieb. In beiden Fällen gehören Schlüsselverwaltung, Protokollierung und Aktualität der Software zum Betrieb.

> **Merke**
>
> IPsec schützt IP-Pakete über AH und ESP und handelt Schlüssel über IKEv2 aus. Der Tunnelmodus schützt ganze Netze, der Transportmodus einzelne Hosts. NAT-Traversal und die Freigaben für UDP 500, UDP 4500 und das Protokoll 50 entscheiden über den Aufbau.

## Zusammenfassung

IPsec ist ein Gerüst aus Standards, das Verschlüsselung, Integrität und Authentifizierung auf der Netzwerkschicht bietet. Der Aufbau läuft über IKEv2 und Security Associations, NAT-Traversal und Firewall-Freigaben sind häufige Stolpersteine, und der Vergleich mit WireGuard zeigt Unterschiede in Umfang und Betrieb.

## Kontrollfragen

1. Welche Schutzfunktion bietet AH nicht, und warum wird es deshalb selten eingesetzt?
2. Was ist der Unterschied zwischen Transport- und Tunnelmodus?
3. Warum benötigt IPsec hinter einem NAT-Gerät UDP 4500?
4. Was bedeutet es, wenn die IKE-SA steht, aber kein Datenverkehr fließt?
5. Warum ist eine pauschale Aussage über die größere Sicherheit eines der beiden Verfahren nicht haltbar?

KAPITEL 8

# Zero Trust verstehen

**Lernziele.** Nach diesem Kapitel kannst du erklären, warum klassische Netzwerkgrenzen nicht mehr ausreichen, die Grundprinzipien von Zero Trust benennen, die Rolle von Identität, Gerätezustand und Mikrosegmentierung beschreiben, typische Fehlinterpretationen erkennen und einen schrittweisen Übergang für ein Unternehmen skizzieren.

## 8.1 Was bedeutet Zero Trust?

Zero Trust, übersetzt etwa Null Vertrauen, ist ein Sicherheitskonzept, das auf Vertrauen in Netzbereiche verzichtet. Ein Gerät, eine Person oder ein Dienst bekommt Zugriff, weil er jede Anfrage erfolgreich nachweist, und nicht deshalb, weil er sich im internen Netz befindet. Jede Zugriffsentscheidung wird einzeln getroffen, und zwar anhand von Identität, Gerätezustand, Kontext und Richtlinie.

Der Begriff ist kein Produkt und keine Norm im engen Sinn. Das amerikanische NIST beschreibt in der Special Publication 800-207 eine Zero-Trust-Architektur mit klaren Komponenten und Grundsätzen. Diese Beschreibung dient in diesem Kapitel als Referenz. Andere Stellen, auch das BSI, veröffentlichen eigene Empfehlungen, die sich in den Grundgedanken decken.

## 8.2 Warum klassische Netzwerkgrenzen nicht reichen

Das klassische Modell kennt ein vertrauenswürdiges Innen und ein unsicheres Außen. Die Firewall am Rand kontrolliert den Übergang, und wer innen ist, darf vieles. Dieses Modell hat drei Schwächen, die in den letzten Jahren deutlicher geworden sind.

Erstens haben viele Beschäftigte heute keinen festen Arbeitsplatz mehr. Sie arbeiten im Homeoffice, unterwegs oder bei Kunden, und ihr Gerät verlässt das Netz ständig. Zweitens liegen Anwendungen und Daten inzwischen auch in Cloud-Diensten, deren Zugriff über das Internet läuft, und nicht mehr allein im eigenen Rechenzentrum. Drittens hat ein Angreifer, der einmal innen ist, oft leichtes Spiel, weil das interne Netz kaum geschützt ist. Die Grenze schützt dann nur den Eingang, nicht den Weg von dort aus.

Ein Beispiel verdeutlicht das. Ein Laptop mit Schadsoftware verbindet sich über das VPN.

Das Gerät besteht die Anmeldung, weil das Passwort stimmt. Im klassischen Modell ist es danach innen und kann Dateiserver erreichen, die es nie benötigt hat. Zero Trust würde die Anfrage nach dem Gerätezustand und nach der benötigten Aufgabe prüfen und nur den Zugriff erlauben, den diese Aufgabe braucht.

## 8.3 Grundprinzipien

Die NIST-Beschreibung nennt mehrere Grundsätze, die sich auf die Praxis übertragen lassen. Alle Datenquellen und Dienste gelten als Ressourcen, die geschützt werden müssen. Jede Kommunikation wird gesichert, unabhängig davon, ob sie im Netz oder außerhalb stattfindet. Der Zugriff wird pro Sitzung und pro Ressource gewährt, nicht pauschal für das ganze Netz. Die Richtlinie wird dynamisch angewendet und berücksichtigt den aktuellen Zustand. Das Unternehmen sammelt Informationen über Benutzer, Geräte und Verkehr, um die Richtlinien anzupassen.

Daraus folgt eine einfache Haltung, die häufig mit Never trust, always verify zusammengefasst wird: Keine Verbindung ist von sich aus vertrauenswürdig, jede muss ihre Berechtigung nachweisen.

## 8.4 Never Trust, Always Verify

Der Satz beschreibt die Haltung, nicht eine Technik. Er verlangt, dass jede Anfrage geprüft wird, auch wenn sie aus dem eigenen Netz kommt. In der Praxis bedeutet das Prüfung bei jedem Zugriff, auf jeder Ebene, und zwar möglichst automatisch. Eine Prüfung, die nur am Anmeldezeitpunkt stattfindet, ist nach diesem Verständnis zu wenig.

## 8.5 Least Privilege

Das Prinzip der minimalen Rechte verlangt, dass jede Identität nur die Zugriffe erhält, die sie für ihre Aufgabe braucht. Das gilt für Benutzer, für Geräte und für Dienste. Eine Buchhaltungssoftware braucht Zugriff auf die Buchungsdaten, aber nicht auf die Personalakten. Ein Drucker braucht Zugriff auf den Druckdienst, aber nicht auf den Dateiserver.

Least Privilege ist ein älteres Grundprinzip der IT-Sicherheit und keine Zero-Trust-Erfindung. Zero Trust macht es technisch durchsetzbar, weil die Richtlinie an jeder Ressource angewendet wird.

## 8.6 Continuous Verification

Eine Verbindung kann nach dem Aufbau unsicher werden. Ein Gerät wird infiziert, ein Benutzerkonto wird kompromittiert, oder der Standort ändert sich. Continuous Verification bedeutet, dass die Zugriffsentscheidung während der Sitzung wiederholt geprüft wird. Die Häufigkeit richtet sich nach dem Risiko der Ressource. Für Verwaltungszugänge ist eine engmaschige Prüfung sinnvoll, für ein internes Wiki genügt eine seltenere.

## 8.7 Identitätsbasierte Zugriffskontrolle

In Zero-Trust-Architekturen ist die Identität der Ausgangspunkt. Ein Zugriff wird zuerst nach Person, Gerät und Kontext bewertet und erst danach, falls überhaupt, nach der IP-Adresse. Die IP-Adresse bleibt ein Signal unter anderen, verliert aber ihre Rolle als Vertrauensmerkmal. Ein Angreifer kann eine Adresse übernehmen oder aus dem Netz heraus eine erlaubte Quelle vortäuschen, eine Identität mit Mehrfaktor-Nachweis ist schwerer zu fälschen.

Die Identitätsverwaltung hält dafür Benutzerkonten, Gruppen und deren Rollen zentral vor. Kapitel 9 vertieft diese Themen.

## 8.8 Geräteidentität

Ein Gerät ist mehr als ein Benutzer. Es braucht eine eigene Identität, meist über ein Zertifikat, und einen geprüften Zustand. Zu den Prüfungen gehören das Betriebssystem in aktueller Version, der Status des Virenschutzes, die Verschlüsselung des Datenträgers und die Zugehörigkeit zum Unternehmen. Ein Gerät, das diese Anforderungen nicht erfüllt, erhält nur eingeschränkten Zugriff oder wird in einen Quarantänebereich geführt.

Geräteprüfungen sind technisch anspruchsvoll, weil sie von der Plattform, der Verwaltung und den verfügbaren Daten abhängen. Ein Einstieg mit wenigen wichtigen Prüfungen ist sinnvoller als ein vollständiges Konzept, das nie umgesetzt wird.

## 8.9 Benutzeridentität und Multi-Faktor-Authentifizierung

Die Benutzeridentität wird durch Mehrfaktor-Authentifizierung gestärkt. Ein Passwort allein gilt in diesem Modell als zu schwach für sensible Zugriffe. Die zweite Komponente sollte unabhängig vom Passwort sein, etwa eine Bestätigung auf einem Gerät oder ein

Hardware-Schlüssel. Kapitel 2 hat gezeigt, warum Phishing so wirksam ist. Mehrfaktor-Verfahren mit Bestätigung können Angriffe erschweren, sie sind aber nicht unangreifbar, deshalb bleibt die Schulung wichtig.

## 8.10 Mikrosegmentierung

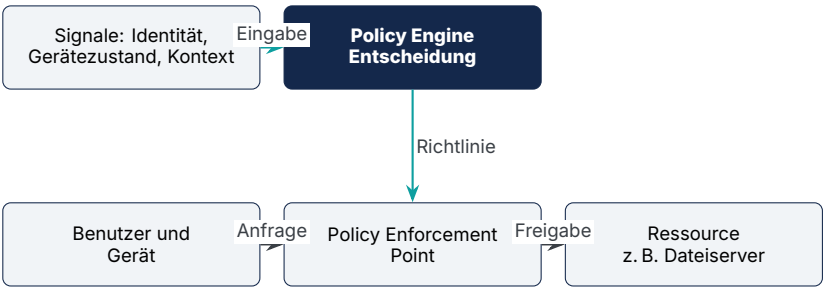
Mikrosegmentierung teilt das Netz nicht nur grob in Zonen, sie reicht bis auf die einzelne Anwendung oder Maschine. Jeder Dienst erhält eine eigene Richtlinie, welche Identitäten und Geräte zugreifen dürfen. Ein Server, der nur eine Datenbank bereitstellt, lässt nur die Anwendungen zu, die diese Datenbank brauchen.

Die Mikrosegmentierung ist die logische Fortsetzung der VLAN-Segmentierung aus Kapitel 4. VLANs trennen Netzbereiche grob, Mikrosegmentierung kontrolliert jede Verbindung. Sie kann über Firewalls auf Host-Ebene, über Verwaltungswerkzeuge oder über identitätsbasierte Zugangsdienste umgesetzt werden.

## 8.11 Policy Enforcement

Die Richtlinie ist nur wirksam, wenn sie durchgesetzt wird. Die NIST-Beschreibung trennt dafür drei Komponenten. Die Policy Engine entscheidet anhand der Richtlinie und der Signale aus Identität, Gerät und Kontext. Der Policy Administrator führt diese Entscheidung aus, indem er die Sitzung vorbereitet und die dafür nötigen Zugangsdaten bereitstellt. Der Policy Enforcement Point ist das Tor im Kommunikationsweg, das die Verbindung zulässt oder blockiert. Policy Engine und Policy Administrator bilden zusammen den Policy Decision Point. Die Trennung macht die Architektur überprüfbar: Man kann die Entscheidung analysieren, ohne die Durchsetzung zu ändern.

Die folgende Abbildung zeigt diesen Ablauf.




Schematische Darstellung nach dem Muster der NIST SP 800-207.

**Abbildung 8.1.** Vereinfachter Ablauf einer Zugriffsentscheidung. Die Policy Engine bewertet Signale und trifft die Entscheidung, der Policy Enforcement Point setzt sie an der Ressource um. Schematische Darstellung.

## 8.12 Conditional Access

Conditional Access bezeichnet Zugriffsregeln, die an Bedingungen geknüpft sind. Eine Regel kann verlangen, dass der Zugriff auf eine Finanzanwendung nur von einem verwalteten Gerät, nur mit Mehrfaktor-Authentifizierung und nur aus bekannten Ländern erfolgt. Solche Regeln sind ein praktischer Baustein der Zero-Trust-Umsetzung. Die konkrete Umsetzung hängt vom Produkt ab, die Idee ist unabhängig davon.

## 8.13 Zero-Trust-Architektur

Eine Zero-Trust-Architektur verbindet die genannten Bausteine. Sie besteht aus einer zentralen Identitätsverwaltung, Geräteprüfungen, einer Policy Engine, Durchsetzungspunkten vor den Ressourcen, einer Überwachung und der Protokollierung aller Entscheidungen. Die Architektur ist keine einzelne Komponente, die man kauft. Sie entsteht durch das Zusammenspiel vieler Komponenten, die einander ergänzen.

## 8.14 Zero Trust und VPN

Ein VPN ist in Zero-Trust-Architekturen nicht verboten, aber es verliert seine Funktion als Vertrauenszone. Der Tunnel verbindet ein Gerät mit dem Netz, und ab da gilt ein

klassisches Modell, sofern die Richtlinie dahinter nicht greift. Viele Unternehmen ersetzen deshalb den breiten Netzzugang über VPN durch Zugriffe auf einzelne Anwendungen, die für jede Anfrage geprüft werden. Das VPN bleibt dann als Transportweg, die Entscheidung trifft die Richtlinie.

## 8.15 Zero Trust im Unternehmen

Im Unternehmen beginnt die Einführung mit dem Bestand. Man kennt die Anwendungen, Daten und Benutzergruppen nicht im Detail, bevor man Richtlinien schreibt. Danach kommen Identität und Mehrfaktor-Authentifizierung, dann Geräteprüfungen und schließlich die Segmentierung. Die Einführung ist ein Programm über Jahre, kein Projekt in wenigen Wochen.

Die Einführung betrifft auch die Organisation. Fachabteilungen müssen wissen, welche Zugriffe sie brauchen, und Administratoren müssen die Richtlinien pflegen. Ohne diese Zusammenarbeit entstehen Ausnahmen, die die Architektur schwächen.

## 8.16 Typische Fehlinterpretationen

Häufige Missverständnisse sind:

Zero Trust bedeutet, dass man kein Netzwerk mehr braucht. Das stimmt nicht. Das Netz bleibt die Verbindung, die Vertrauensannahme ändert sich.

Zero Trust ist ein Produkt, das man kauft. Es gibt Produkte, die Teile der Architektur umsetzen, aber keine vollständige Lösung als Paket.

Zero Trust macht das VPN und die Firewall überflüssig. Beide bleiben Bausteine, ihre Rolle ändert sich.

Zero Trust ist unfehlbar. Es reduziert die Angriffsfläche und begrenzt den Schaden, es verhindert aber nicht jeden Vorfall.

## 8.17 Grenzen und Herausforderungen

Zero Trust hat Grenzen, die man kennen sollte. Ältere Anwendungen unterstützen moderne Anmeldeverfahren oft nicht. Geräte, die sich nicht prüfen lassen, bleiben schwierig einzubinden. Die Richtlinien werden schnell komplex, und ohne gute Dokumentation verliert man den Überblick. Dazu kommen Aufwand für Betrieb und Schulung, mögliche Reibung für Benutzer und Abhängigkeit von zentralen Diensten, deren Ausfall den Zugriff

unterbricht.

Ein Zero-Trust-Konzept muss deshalb Notfallwege vorsehen, die selbst gesichert sind, und regelmäßig geprüft werden.

## 8.18 Schrittweiser Übergang: Ein Beispiel

Das Beispiel beschreibt ein Unternehmen mit rund 40 Mitarbeitenden, das heute ein klassisches Netz mit Firewall am Rand, VLANs und einem VPN für den Fernzugriff betreibt. Der Übergang erfolgt in fünf Phasen, die jeweils eigenständig nutzen und die nächste vorbereiten.

In der ersten Phase erfasst das Unternehmen den Bestand. Es listet Anwendungen, Dateiablagen, Benutzergruppen und Geräte auf und ordnet jeder Ressource einen Schutzbedarf zu. Außerdem prüft es, welche Zugriffe heute bestehen und welche wirklich gebraucht werden.

In der zweiten Phase führt das Unternehmen eine zentrale Anmeldung ein und aktiviert Mehrfaktor-Authentifizierung für alle Benutzer, zuerst für Fernzugriffe und Verwaltungskonten. Die Passwortrichtlinie wird überarbeitet. Dieser Schritt bringt den größten Sicherheitsgewinn bei überschaubarem Aufwand.

In der dritten Phase kommen Geräteprüfungen dazu. Verwaltete Geräte erhalten Zertifikate, und der Zustand wird geprüft, bevor der Zugriff auf sensible Anwendungen erlaubt wird. Geräte, die die Anforderungen nicht erfüllen, erhalten nur Zugriff auf eine eingeschränkte Umgebung, mit der sie das Problem beheben können.

In der vierten Phase wird die Segmentierung verfeinert. Der Serverbereich wird nach Anwendungen getrennt, und der Zugriff auf jede Anwendung folgt einer eigenen Richtlinie. Der breite Netzzugang über das VPN wird schrittweise durch Zugriffe auf einzelne Anwendungen ersetzt, die über einen Zugangsdienst mit Richtlinie laufen.

In der fünften Phase überwacht das Unternehmen die Entscheidungen. Alle Zugriffe werden protokolliert, Auffälligkeiten ausgewertet und die Richtlinien angepasst. Der Übergang gilt als abgeschlossen, wenn der Großteil der Zugriffe über die Richtlinie läuft und das alte Netzmodell nur noch für Ausnahmen gebraucht wird. Die Ausnahmen sind dokumentiert und werden regelmäßig überprüft.

> **Merke**
>
> Zero Trust verlangt, jede Anfrage anhand von Identität, Gerätezustand und Kontext zu prüfen. Least Privilege, kontinuierliche Prüfung und Mikrosegmentierung

setzen die Haltung um. Der Übergang erfolgt schrittweise, und die Protokollierung macht ihn überprüfbar.

## Zusammenfassung

Zero Trust ersetzt das Vertrauen in Netzbereiche durch die Prüfung jeder Anfrage. Die Grundprinzipien sind Identität, Gerätezustand, minimale Rechte und kontinuierliche Prüfung. Die Umsetzung ist ein Programm, das Schritt für Schritt aufgebaut wird.

## Kontrollfragen

1. Warum reicht eine Firewall am Netzrand nicht mehr aus, wenn Beschäftigte von unterwegs arbeiten?
2. Welche Funktion hat die Policy Engine, und welche der Policy Enforcement Point?
3. Warum ist die IP-Adresse als Vertrauensmerkmal schwach?
4. Warum wird ein VPN in Zero-Trust-Architekturen oft durch Zugriffe auf einzelne Anwendungen ergänzt?
5. Welche Phase des Übergangs bringt den größten Gewinn bei überschaubarem Aufwand, und warum?

KAPITEL 9

# Zugriffskontrolle und Authentifizierung

**Lernziele.** Nach diesem Kapitel kannst du Authentifizierung und Autorisierung unterscheiden, rollenbasierte und attributbasierte Zugriffskontrolle vergleichen, Verfahren für Passwörter und Mehrfaktor-Authentifizierung bewerten, die Rolle von Zertifikaten und PKI beschreiben und RADIUS, TACACS+ und IEEE 802.1X einordnen. Außerdem verstehst du, warum Rechte regelmäßig überprüft werden müssen.

## 9.1 Authentifizierung und Autorisierung

Authentifizierung beantwortet die Frage, wer jemand ist. Autorisierung beantwortet die Frage, was diese Person tun darf. Beide Schritte hängen zusammen, sind aber zu trennen. Ein Benutzer kann sich korrekt anmelden und trotzdem keinen Zugriff auf eine bestimmte Anwendung haben, weil er dort nicht berechtigt ist.

Die Trennung hat praktische Folgen. Eine Anmeldung allein sagt nichts über die Berechtigung aus. Und eine Berechtigung ist nur so verlässlich wie die Identität, auf die sie sich bezieht. Wer eine fremde Identität übernimmt, erbt alle Rechte dieser Identität, deshalb bleibt die Authentifizierung die Grundlage.

## 9.2 Identitäts- und Zugriffsmanagement

Identity and Access Management, kurz IAM, fasst die Prozesse und Werkzeuge zusammen, mit denen Identitäten angelegt, verwaltet, berechtigt und entfernt werden. Dazu gehören Benutzerkonten, Gruppen, Rollen, Anmeldeverfahren und die Protokollierung von Zugriffen. Ein zentrales Verzeichnis, das alle Anwendungen nutzen, verhindert, dass Konten an verschiedenen Stellen unterschiedlich verwaltet werden.

Ein IAM-Prozess beginnt mit dem Eintritt einer Person in das Unternehmen, begleitet ihre Wechsel innerhalb des Unternehmens und endet mit dem Austritt. Diese Stationen werden oft als Joiner, Mover und Leaver bezeichnet. Die meisten Sicherheitsprobleme mit Konten entstehen an den Übergängen, etwa wenn Rechte aus einer alten Aufgabe nach einem Wechsel bestehen bleiben.

## 9.3 Benutzerkonten und Gruppen

Benutzerkonten sind die individuellen Identitäten. Jeder Mensch sollte genau ein persönliches Konto besitzen. Gemeinsam genutzte Konten erschweren die Nachvollziehbarkeit, weil man nicht mehr sagen kann, wer gehandelt hat. Administrative Konten werden zusätzlich getrennt von den alltäglichen Konten angelegt.

Gruppen fassen Konten mit gleichen Aufgaben zusammen. Rechte werden dann an Gruppen vergeben und nicht an einzelne Personen. Das vereinfacht die Verwaltung, weil eine Änderung an der Gruppe alle Mitglieder erfasst. Gruppen sollten nicht unbegrenzt wachsen, denn eine Gruppe mit vielen unterschiedlichen Mitgliedern erzeugt Rechte, die niemand mehr überblickt.

## 9.4 Rollenbasierte Zugriffskontrolle

Rollenbasierte Zugriffskontrolle, englisch Role-Based Access Control, kurz RBAC, ordnet Rechte einer Rolle zu und die Rolle den Personen. Eine Rolle wie Buchhalter enthält alle Zugriffe, die diese Aufgabe braucht, und keine weiteren. Eine Person erhält eine oder mehrere Rollen, und die Zugriffe ergeben sich daraus.

RBAC ist verbreitet, weil es sich gut auf Organisationsstrukturen abbilden lässt. Es hat aber Grenzen. Wenn viele Ausnahmen entstehen, wächst die Zahl der Rollen schnell, und man erzeugt Rollen für einzelne Personen. Dann verliert das Modell seine Übersichtlichkeit.

## 9.5 Attributbasierte Zugriffskontrolle

Attributbasierte Zugriffskontrolle, englisch Attribute-Based Access Control, kurz ABAC, entscheidet anhand von Attributen. Attribute sind Eigenschaften der Person, des Geräts, der Ressource und der Umgebung, etwa die Abteilung, der Standort, der Gerätezustand, die Klassifizierung des Dokuments und die Uhrzeit. Eine Regel kann dann lauten: Mitarbeitende der Abteilung Finanzen dürfen Dokumente der Klassifizierung intern lesen, wenn das Gerät verwaltet ist und der Zugriff während der Arbeitszeit erfolgt.

ABAC ist ausdrucksstärker als RBAC und passt gut zu Zero-Trust-Ansätzen aus Kapitel 8. Die Regeln werden allerdings schnell schwer zu prüfen, und fehlerhafte Attribute führen zu falschen Entscheidungen. Die Qualität der Attributdaten bestimmt deshalb den Nutzen des Modells.

## 9.6 Least Privilege

Das Prinzip der minimalen Rechte gilt für jedes Modell. Eine Person erhält nur die Zugriffe, die sie für ihre Aufgabe braucht, und diese Zugriffe enden, wenn die Aufgabe endet. Zeitlich begrenzte Rechte sind dafür ein gutes Mittel, etwa für eine Vertretung oder ein Projekt. Ein Recht ohne Ablaufdatum wird vergessen und bleibt bestehen.

## 9.7 Passwortsicherheit

Passwörter bleiben das häufigste Anmeldeverfahren. Das BSI empfiehlt in seinen Empfehlungen lange Passwörter, die nicht aus leicht zu erratenden Wörtern bestehen und nicht für mehrere Dienste verwendet werden. Starre Regeln mit erzwungenen regelmäßigen Wechseln gelten heute als weniger wirksam als lange, eindeutige Passwörter, die bei einem Verdacht gewechselt werden. Die aktuellen Empfehlungen sollten im BSI-Grundschutz nachgelesen werden, weil sie sich fortentwickeln.

Ein Passwort-Manager erzeugt und speichert eindeutige Passwörter für jeden Dienst. Der Benutzer muss sich dann nur noch ein Hauptpasswort merken. Der Passwort-Manager reduziert das Risiko der Wiederverwendung, bringt aber eine zentrale Abhängigkeit mit sich. Sein Schutz muss deshalb besonders gut sein.

## 9.8 Multi-Faktor-Authentifizierung

Mehrfaktor-Authentifizierung kombiniert mindestens zwei unabhängige Nachweise. Die klassischen Faktoren sind etwas, das man weiß, etwa ein Passwort, etwas, das man besitzt, etwa ein Gerät oder ein Schlüssel, und etwas, das man ist, etwa ein biometrisches Merkmal. Der Zusatznutzen entsteht durch die Unabhängigkeit: Ein gestohlenes Passwort allein genügt dann nicht.

Verfahren unterscheiden sich in ihrer Stärke. Eine Bestätigung über eine App, eine Code-Eingabe oder ein Hardware-Schlüssel sind unterschiedlich widerstandsfähig gegen Phishing. Verfahren, die einen Code per SMS senden, sind schwächer, weil sie von der Mobilfunkinfrastruktur abhängen und abgefangen werden können. Die Wahl sollte nach dem Schutzbedarf der Ressource erfolgen.

## 9.9 Zertifikate und Public-Key-Infrastruktur

Zertifikate binden einen öffentlichen Schlüssel an eine Identität. Eine vertrauenswürdige Stelle, die Zertifizierungsstelle, bestätigt diese Bindung mit ihrer Signatur. Die Infrastruktur, die Zertifikate ausstellt, prüft und sperrt, heißt Public-Key-Infrastruktur, kurz PKI.

Eine PKI braucht Regeln für Ausstellung, Gültigkeit, Erneuerung und Sperrung. Gesperrte Zertifikate werden über Sperrlisten oder ein Online-Prüfverfahren bekannt gemacht. Wer PKI einführt, sollte die Zertifizierungsstelle schützen, weil sie die Grundlage des Vertrauens bildet. Eine kompromittierte Zertifizierungsstelle erlaubt, beliebige Identitäten zu fälschen.

## 9.10 RADIUS

RADIUS, Remote Authentication Dial-In User Service, ist ein Protokoll, mit dem ein Netzwerkgerät die Anmeldung eines Benutzers an einen zentralen Server weitergibt. Der Server prüft die Daten, entscheidet über den Zugang und liefert Attribute wie die VLAN-Zuordnung zurück. RADIUS wird für WLAN mit 802.1X, für VPN-Zugänge und für Netzgeräte eingesetzt. Die Kommunikation läuft über UDP, meist auf den Ports 1812 für die Authentifizierung und 1813 für die Abrechnung.

RADIUS verschlüsselt nur bestimmte Teile der Nachricht, vor allem das Passwort. Der übrige Inhalt ist für Beobachter im Netz lesbar. Deshalb läuft RADIUS im Netz möglichst über geschützte Verbindungen oder in einem abgeschotteten Management-Netz, und das gemeinsame Geheimnis zwischen Gerät und Server muss stark sein.

## 9.11 TACACS+

TACACS+ ist ein Protokoll, das vor allem für die Anmeldung an Netzwerkgeräten genutzt wird. Es trennt die Dienste Authentifizierung, Autorisierung und Abrechnung, und es verschlüsselt den gesamten Nachrichtenkörper, nicht nur das Passwort. Der Server kann dadurch genau festlegen, welche Befehle ein Administrator auf einem Router ausführen darf.

TACACS+ läuft über TCP auf Port 49. Die Trennung der Dienste und die feingranulare Befehlskontrolle machen es für die Verwaltung von Netzgeräten geeignet. Für den Netzzugang von Endgeräten ist RADIUS dagegen der übliche Weg. Beide Protokolle haben also unterschiedliche Aufgaben.

## 9.12 IEEE 802.1X

IEEE 802.1X ist ein Verfahren zur Zugangskontrolle am Netzwerkport. Ein Port bleibt geschlossen, bis sich das angeschlossene Gerät erfolgreich authentifiziert hat. Die drei Rollen sind der Supplicant, das ist das Endgerät, der Authenticator, das ist der Switch oder Access Point, und der Authentication Server, meist ein RADIUS-Server. Die eigentliche Anmeldung läuft über EAP, das Extensible Authentication Protocol, in verschiedenen Varianten.

Kapitel 6 hat die Rollen für das WLAN beschrieben. Für kabelgebundene Ports gilt dasselbe Prinzip. Ein unbekanntes Gerät, das an eine Dose angeschlossen wird, bekommt keinen Zugang, bevor es sich ausweist. Für Geräte, die keine Anmeldung unterstützen, gibt es Ausnahmen über die MAC-Adresse, die aber eine schwächere Lösung ist.

## 9.13 Network Access Control

Network Access Control, kurz NAC, prüft Geräte und Benutzer, bevor sie Zugang zum Netz erhalten, und weist sie einem passenden Bereich zu. Das Verfahren kombiniert häufig 802.1X mit einer Prüfung des Gerätezustands. Ein Gerät, das nicht die Anforderungen erfüllt, landet in einem Quarantänebereich, in dem es Updates beziehen kann.

NAC kann vor dem Zugang geschehen, also vor der Freigabe, und danach, also während der Verbindung. Die Kontrolle nach dem Zugang ist wichtig, weil sich der Zustand eines Geräts ändern kann. Die Einführung erfordert Abstimmung mit Fachabteilungen, denn Geräte, die nicht unterstützt werden, brauchen eine Ausnahme oder einen Ersatz.

## 9.14 Geräteauthentifizierung

Geräte brauchen eine eigene Identität, die unabhängig von den Personen ist, die sie benutzen. Ein Zertifikat auf dem Gerät, das in der PKI ausgestellt wurde, ist dafür der übliche Weg. Gerätekonten, die Passwörter verwenden, sind schwieriger zu verwalten, weil Passwörter vergessen oder verteilt werden. Dienste, die ohne Benutzer laufen, brauchen ebenfalls eigene, eng begrenzte Identitäten.

## 9.15 Rechteverwaltung und regelmäßige Überprüfung

Rechte veralten. Personen wechseln Aufgaben, Projekte enden, und Ausnahmen bleiben bestehen. Eine regelmäßige Überprüfung, die Rechteüberprüfung, stellt fest, ob jede

Berechtigung noch gebraucht wird. Die Prüfung erfolgt durch die fachlich verantwortliche Stelle, nicht allein durch die Administration, weil nur die Fachstelle weiß, was eine Aufgabe erfordert.

Eine Rechteüberprüfung braucht eine feste Frequenz, etwa einmal im Jahr für alle Berechtigungen und häufiger für privilegierte Konten. Sie erzeugt einen Nachweis, dass die Prüfung stattgefunden hat, und sie führt zu Entzug nicht mehr benötigter Rechte.

### 9.15.1 Unterschiede anhand eines Unternehmensbeispiels

Ein Unternehmen mit Buchhaltung, Vertrieb und Produktion zeigt die Unterschiede. Die Buchhaltung nutzt RBAC, weil ihre Aufgaben klar umrissen sind: Die Rolle Buchhalter erhält Zugriff auf das Finanzsystem und die Ablage der Belege. Der Vertrieb braucht zusätzlich eine Regel, die nur Zugriff auf Kundendaten der eigenen Region erlaubt. Hier passt ABAC, weil das Attribut Region entscheidet. Die Produktionsanlagen erhalten Gerätezertifikate und Zugang über 802.1X. Die Administratoren melden sich an den Netzgeräten über TACACS+ an, damit jeder Befehl nachvollziehbar bleibt.

Das Beispiel zeigt, dass die Verfahren nebeneinander bestehen. Keines ersetzt das andere, und jedes hat seinen Platz.

> **Merke**
>
> Authentifizierung klärt die Identität, Autorisierung die Berechtigung. RBAC ordnet Rechte Rollen zu, ABAC entscheidet anhand von Attributen. Mehrfaktor-Authentifizierung und Zertifikate schützen die Anmeldung. RADIUS begleitet den Netzzugang, TACACS+ die Verwaltung der Geräte. Regelmäßige Rechteüberprüfung verhindert veraltete Berechtigungen.

## Zusammenfassung

Zugriffskontrolle verbindet Identität, Rolle und Umgebung zu einer Entscheidung. Passwörter und Mehrfaktor-Verfahren sichern die Anmeldung, Zertifikate und PKI die Identität von Geräten und Diensten. RADIUS, TACACS+ und 802.1X tragen die Entscheidung in das Netz. Regelmäßige Überprüfung hält die Rechte aktuell.

## Kontrollfragen

1. Warum darf eine erfolgreiche Anmeldung nicht mit einer Berechtigung gleichgesetzt werden?
2. Worin unterscheidet sich RBAC von ABAC?
3. Warum ist eine SMS-basierte Code-Eingabe schwächer als ein Hardware-Schlüssel?
4. Welchen Unterschied gibt es zwischen RADIUS und TACACS+ bei der Verschlüsselung und dem Einsatzzweck?
5. Warum sollte die Rechteüberprüfung durch die Fachstelle und nicht allein durch die Administration erfolgen?

KAPITEL 10

# Netzwerkgeräte und Dienste absichern

**Lernziele.** Nach diesem Kapitel kannst du die Grundkonfiguration von Routern, Switches und Firewalls härten, sichere Managementzugänge mit SSH und SNMPv3 einrichten, die Schutzfunktionen Port Security, DHCP Snooping, Dynamic ARP Inspection, IP Source Guard und BPDU Guard erklären, sichere DNS- und DHCP-Dienste konfigurieren und begründen, warum mehrere Schutzmaßnahmen zusammenwirken müssen.

**Hinweis.** Dieses Kapitel beschreibt Funktionen und Prinzipien. Befehlssyntax unterscheidet sich je nach Hersteller und wird hier bewusst nicht vorgegeben. Die Herstellerdokumentation ist für die konkrete Umsetzung maßgeblich.

## 10.1 Warum Netzwerkgeräte besonders geschützt werden müssen

Router, Switches, Firewalls und Access Points bilden das Rückgrat des Netzes. Wer eines dieser Geräte kontrolliert, kann den Verkehr mitlesen, umleiten oder abschalten. Anders als Arbeitsplätze werden Netzwerkgeräte selten aktualisiert, oft mit Standardpasswörtern betrieben und sind häufig vergessen, sobald sie laufen. Die Härtung richtet sich deshalb auf die Geräte selbst und auf die Dienste, die sie anbieten.

Das Ziel ist, nur das zu betreiben, was gebraucht wird, und jeden Zugang so eng wie möglich zu machen. Diese Haltung ergibt sich aus den Grundsätzen der früheren Kapitel: Angriffsfläche verringern, Rechte begrenzen und Zustände überprüfen.

## 10.2 Sichere Grundkonfiguration von Routern

Ein Router braucht zuerst eine geänderte Verwaltungsanmeldung. Standardpasswörter und Standardbenutzernamen sind öffentlich bekannt und gehören zu den häufigsten Ursachen für Vorfälle. Danach sollte der Router nur die Dienste anbieten, die er tatsächlich braucht. Dienste wie Telnet, unverschlüsseltes HTTP für die Verwaltung und nicht benötigte Protokolle werden abgeschaltet.

Weitere Grundregeln betreffen die Zeit, die Protokollierung und die Nachvollziehbarkeit. Der Router synchronisiert seine Uhrzeit über einen Zeitdienst mit Authentifizierung, damit

Protokolle korrekt zugeordnet werden können. Er sendet Meldungen an einen zentralen Protokollserver, damit ein Angreifer die eigene Spur nicht im Gerät löschen kann. Ein Warnhinweis beim Anmelden weist unbefugte Benutzer darauf hin, dass der Zugang überwacht wird.

## 10.3 Switch-Hardening

Switches sind am stärksten verwundbar an ihren Ports, weil dort Geräte angeschlossen werden, deren Herkunft nicht immer bekannt ist. Die Härtung eines Switches beginnt mit einfachen Regeln: Nicht benutzte Ports werden abgeschaltet oder in ein Quarantäne-VLAN gelegt. Jeder Port erhält eine feste Rolle, Zugangsport oder Trunk, damit keine automatischen Aushandlungen entstehen, wie in Kapitel 4 beschrieben. Das Native VLAN bleibt ungenutzt.

Dazu kommen Schutzfunktionen, die auf Layer 2 wirken und die im Folgenden erklärt werden.

## 10.4 Port Security

Port Security begrenzt, welche und wie viele MAC-Adressen an einem Port zugelassen werden. Der Switch lernt die Adresse des angeschlossenen Geräts und erlaubt nur diese oder eine festgelegte Anzahl. Eine unbekannte Adresse löst eine Verletzung aus, die je nach Einstellung den Verkehr verwirft, den Port blockiert oder nur eine Meldung erzeugt.

Die Einstellungen müssen zum Betrieb passen. Ein Port, der hinter einem Gerät mit mehreren Adressen hängt, etwa einem Telefon mit angeschlossenem Computer, braucht eine höhere Grenze. Ein zu strenger Modus blockiert legitime Geräte, etwa nach einem Gerätewechsel, und erzeugt Ausfälle, die schwer zu erklären sind.

## 10.5 DHCP Snooping

DHCP Snooping überwacht die Antworten des DHCP-Servers. Die Ports werden in vertrauenswürdige und nicht vertrauenswürdige unterteilt. Antworten eines DHCP-Servers sind nur über vertrauenswürdige Ports erlaubt. Der Switch führt außerdem eine Tabelle, die jede vergebene Adresse einer MAC-Adresse und einem Port zuordnet. Diese Tabelle ist die Grundlage für zwei weitere Schutzfunktionen.

Ohne DHCP Snooping kann ein unberechtigter DHCP-Server im Netz Adressen und Gateway-Angaben verteilen und so den Verkehr umleiten. Die Schutzfunktion verhin-

dert diesen Angriff, weil nur der vertrauenswürdige Port Antworten weitergibt. Kapitel 9 hat die Authentifizierung behandelt, DHCP Snooping ergänzt sie auf Netzebene.

## 10.6 Dynamic ARP Inspection

Dynamic ARP Inspection prüft ARP-Antworten. Der Switch vergleicht die IP-Adresse und die MAC-Adresse in einer Antwort mit der Tabelle aus DHCP Snooping. Stimmt die Zuordnung nicht, wird die Antwort verworfen. Dadurch lässt sich die Fälschung von ARP-Zuordnungen verhindern, die in Kapitel 2 als Bedrohung beschrieben wurde.

Die Funktion setzt voraus, dass die Tabelle vollständig ist. Statische Adressen, die nicht über DHCP vergeben werden, müssen daher in die Tabelle aufgenommen werden, sonst blockiert der Switch legitime Verbindungen. Dieser Aufwand ist die häufigste Fehlerquelle bei der Einführung.

## 10.7 IP Source Guard

IP Source Guard lässt an einem Port nur Pakete mit der Quelladresse zu, die dem Port in der Tabelle zugeordnet ist. Ein Gerät, das eine fremde Adresse einsetzt, wird am Switch gestoppt, bevor der Verkehr das Netz erreicht. Die Funktion ergänzt Dynamic ARP Inspection und wirkt auf den IP-Verkehr selbst.

## 10.8 BPDU Guard

Spanning Tree sorgt in Netzen mit mehreren Switches für schleifenfreie Wege. Die Switches tauschen dafür Nachrichten aus, die BPDUs heißen. Ein Zugangsport, der nie einen Switch angeschlossen haben sollte, darf keine solche Nachricht empfangen. BPDU Guard schaltet einen als Endgerät-Port markierten Port ab, sobald dort eine BPDU ankommt. Dadurch verhindert die Funktion, dass ein angeschlossener Switch den Spanning Tree stört oder die Topologie umbaut.

Eine verwandte Funktion ist Root Guard. Er verhindert, dass ein Port die Rolle des Root-Switches übernimmt, die die Topologie bestimmt. Beide Funktionen schützen den Weg, auf dem Verkehr fließt.

## 10.9 Firewall-Hardening

Eine Firewall braucht dieselbe Grundhärtung wie andere Geräte: geänderte Zugangsdaten, Verwaltung nur aus dem Management-Netz, aktuelle Firmware und protokollierte Änderungen. Die Regeln sollten nach Kapitel 3 gepflegt werden, insbesondere mit Default Deny, begründeten Freigaben und regelmäßiger Prüfung. Zusätzlich lohnt sich die Aktivierung der Schutzfunktionen, die das Gerät anbietet, etwa Intrusion Prevention oder Prüfung auf bekannte Angriffsmuster, soweit sie zum Einsatzzweck passen.

Eine Firewall, die zugleich VPN-Gateway und Verwaltungspunkt ist, braucht besondere Sorgfalt. Ihre Verwaltungsoberfläche sollte aus dem Internet nicht erreichbar sein und nur aus einem abgeschotteten Netz.

## 10.10 SSH statt Telnet

Telnet überträgt Benutzernamen und Passwort im Klartext. Wer den Verkehr mitschneidet, erhält die Zugangsdaten. SSH verschlüsselt die gesamte Sitzung und authentifiziert das Gerät gegenüber dem Benutzer, sodass auch Gerätewechsel auffallen. Für die Verwaltung von Netzgeräten gilt deshalb: Telnet wird abgeschaltet, SSH mit aktuellen Verfahren aktiviert.

Für SSH gelten Auswahlregeln. Aktuelle Protokollversionen und starke Algorithmen sind Pflicht, veraltete Verfahren werden deaktiviert. Anmeldung über Schlüssel ist sicherer als Passwörter. Der Zugang sollte auf wenige Quelladressen aus dem Management-Netz beschränkt werden.

## 10.11 Sichere Managementzugänge

Die Verwaltung eines Netzgeräts ist die wertvollste Funktion im Netz. Sie braucht deshalb einen eigenen Zugang: ein Management-VLAN, einen Zugang nur von bestimmten Administrationsarbeitsplätzen aus und eine Anmeldung mit Mehrfaktor-Authentifizierung über einen zentralen Dienst, wie in Kapitel 9 beschrieben. Bei besonders kritischen Geräten kommt ein getrenntes Verwaltungsnetz oder ein Zugang über eine Zusatzverbindung hinzu, die unabhängig vom Produktivnetz funktioniert.

Gerätezugänge werden protokolliert, und die Protokolle werden zentral gespeichert. Eine Sitzung ohne Protokoll ist für die Nachvollziehbarkeit verloren.

## 10.12 SNMPv3

SNMP dient der Überwachung und teilweise der Konfiguration von Netzgeräten. Die älteren Versionen 1 und 2c arbeiten mit einem Community-String, der im Klartext übertragen wird und oft auf dem Standardwert steht. Wer ihn kennt, kann das Gerät auslesen, und bei schreibenden Rechten auch verändern.

SNMPv3 bietet Authentifizierung und Verschlüsselung. Die sichere Stufe kombiniert beides und nutzt Benutzerkonten mit eigenen Schlüsseln. Die älteren Versionen sollten abgeschaltet werden, sobald alle Überwachungssysteme SNMPv3 unterstützen. Schreibrechte über SNMP sind nur in begründeten Ausnahmen sinnvoll.

## 10.13 Deaktivierung nicht benötigter Dienste

Jeder laufende Dienst ist eine mögliche Angriffsstelle. Ein Gerät sollte nur die Dienste anbieten, die sein Betriebszweck verlangt. Die Prüfung umfasst offene Ports, aktive Protokolle und Funktionen der Weboberfläche. Die Frage lautet jeweils, ob der Dienst gebraucht wird und, falls ja, ob die sichere Variante zur Verfügung steht.

Die Liste sollte dokumentiert und regelmäßig geprüft werden. Dienste, die nach einem Update neu aktiviert werden, fallen sonst unbemerkt wieder an.

## 10.14 Sichere DNS-Konfiguration

Ein DNS-Server, der jedem aus dem Internet Anfragen beantwortet, kann für Verstärkungsangriffe missbraucht werden. Man spricht dann von einem offenen Resolver. Die Lösung ist, rekursive Auflösung nur für das eigene Netz zuzulassen. Autoritative Server, die Zonen für die Öffentlichkeit beschreiben, und rekursive Server für interne Clients sollten getrennt betrieben werden.

Zusätzlich sollte der Resolver DNSSEC validieren, damit gefälschte Antworten erkannt werden, wie in Kapitel 2 beschrieben. Verschlüsselte DNS-Abfragen schützen den Weg zwischen Client und Resolver. Der Zugriff auf die Verwaltung des DNS-Servers folgt den gleichen Regeln wie für andere Geräte.

## 10.15 DHCP-Sicherheit

DHCP vergibt Adressen und Netzwerkparameter. Ein DHCP-Server, der in das falsche Netz antwortet oder einen unberechtigten Eindringling zulässt, kann den Verkehr umleiten. Die Schutzmaßnahmen sind DHCP Snooping am Switch, eine Begrenzung des Adressbereichs auf die tatsächlich benötigten Adressen und Protokollierung der Vergaben. Eine Reservierung für wichtige Geräte schützt vor Verwechslung.

Ein DHCP-Server, der nicht mehr benötigt wird, sollte abgeschaltet werden, weil ein vergessener Dienst weiter Adressen vergibt. Die Dokumentation der Adressbereiche hilft dabei, solche Dienste zu finden.

## 10.16 Firmware- und Sicherheitsupdates

Updates schließen bekannte Lücken. Die Umsetzung braucht einen Plan: Hersteller-Hinweise lesen, Updates in einem Testumfeld prüfen, die Konfiguration vorher sichern und die Installation in einem Wartungsfenster durchführen. Nach dem Update werden Funktion und Protokolle geprüft.

Geräte ohne Hersteller-Unterstützung sind ein Risiko, das in der Planung zu berücksichtigen ist. Ein Ersatz sollte vor dem Support-Ende eingeplant werden, nicht danach.

## 10.17 Backup und Wiederherstellung von Konfigurationen

Eine Konfigurationssicherung ermöglicht die schnelle Wiederherstellung nach einem Defekt oder einem Angriff. Sie muss regelmäßig erstellt, verschlüsselt gespeichert und getrennt vom Netz aufbewahrt werden. Die Sicherung enthält häufig Passwörter und Schlüssel, deshalb darf sie nicht frei zugänglich liegen.

Eine Sicherung ist nur so gut wie ihr Test. Eine Wiederherstellung auf einem Testgerät zeigt, ob die Datei vollständig ist. Die Testabstände richten sich nach dem Risiko des Geräts.

## 10.18 Managementzugänge beschränken

Die Beschränkung der Managementzugänge ist die wirksamste Einzelmaßnahme. Ein Gerät, das nur von einem bestimmten Netz aus verwaltet werden kann, ist für Angreifer

aus dem Produktivnetz oder dem Internet nicht erreichbar. Die Beschränkung erfolgt auf dem Gerät selbst und zusätzlich an der Firewall, damit beide Stellen übereinstimmen.

## 10.19 Netzwerkgeräte dokumentieren

Eine vollständige Dokumentation umfasst Gerätetyp, Standort, Firmware-Version, Verwaltungsadresse, aktivierte Dienste, Zugangsberechtigte, Sicherungsstand und Ansprechpartner. Die Dokumentation ist die Grundlage für Prüfungen, Updates und den Notfall. Sie muss aktuell gehalten werden, sonst führt sie in die Irre.

## 10.20 Warum mehrere Schutzmaßnahmen nötig sind

Keine einzelne Maßnahme schützt ein Netzgerät vollständig. Port Security stoppt unbekannte Geräte, verhindert aber nicht, dass ein berechtigtes Gerät gefälschte ARP-Antworten sendet. Dynamic ARP Inspection prüft die ARP-Antworten, braucht aber eine korrekte Tabelle aus DHCP Snooping. Die Verwaltung per SSH ist sicher, wenn das Gerät nur aus dem Management-Netz erreichbar ist. Fehlt die Beschränkung, bleibt der sichere Zugang ein Angriffsziel unter anderen.

Die Maßnahmen ergänzen sich. Jede Schicht verringert das Risiko, und die Lücke einer Schicht wird von einer anderen begrenzt. Eine Konfiguration, die nur eine Schutzfunktion einsetzt, schafft ein falsches Gefühl von Sicherheit.

Die folgende Tabelle fasst die wichtigsten Maßnahmen zusammen.

| Maßnahme | Schutzwirkung |
|---|---|
| SSH statt Telnet | Zugangsdaten bleiben im Verkehr verborgen |
| SNMPv3 statt v1 und v2c | Keine Klartext-Community, Authentifizierung und Verschlüsselung |
| Port Security | Nur bekannte Geräte an einem Port |
| DHCP Snooping | Nur vertrauenswürdige DHCP-Antworten, Bindungstabelle |
| Dynamic ARP Inspection | Gefälschte ARP-Antworten werden verworfen |
| IP Source Guard | Gefälschte Quelladressen werden am Port gestoppt |
| BPDU Guard | Keine fremden Switches an Zugangsports |
| Beschränkter Management-Zugang | Verwaltung nur aus dem Management-Netz |
| Rekursion nur intern | Kein offener DNS-Resolver |
| Konfigurationssicherung | Schnelle Wiederherstellung, Schutz der Sicherung |

**Tabelle 10.1.** Wichtige Maßnahmen zur Härtung von Netzwerkgeräten mit ihrer Schutzwirkung. Die genaue Umsetzung hängt vom Gerät ab.

> **Merke**
>
> Netzwerkgeräte brauchen geänderte Zugangsdaten, nur benötigte Dienste und sichere Managementwege. Die Switch-Funktionen Port Security, DHCP Snooping, Dynamic ARP Inspection, IP Source Guard und BPDU Guard wirken zusammen. Eine Maßnahme allein genügt nicht, und jede Konfiguration braucht Dokumentation und Tests.

## Zusammenfassung

Netzwerkgeräte werden über Management, Ports und Dienste angegriffen, deshalb setzt die Härtung dort an. SSH und SNMPv3 sichern den Zugang, die Switch-Funktionen schützen Layer 2, und sichere DNS- und DHCP-Dienste verhindern Umleitungen. Erst das Zusammenspiel macht die Konfiguration belastbar.

## Kontrollfragen

1. Warum schützt DHCP Snooping allein nicht vor gefälschten ARP-Antworten, und welche Funktion ergänzt es?

2. Welche Gefahr besteht, wenn ein Zugangsport keinen BPDU Guard hat?
3. Warum ist SNMPv2c mit Standard-Community-String ein Risiko?
4. Was ist ein offener DNS-Resolver, und wie verhindert man ihn?
5. Warum wirkt die Beschränkung des Management-Zugangs stärker als viele einzelne Schutzeinstellungen?

KAPITEL 11

# Überwachung und Erkennung von Sicherheitsvorfällen

**Lernziele.** Nach diesem Kapitel kannst du erklären, warum Netzwerküberwachung für die Sicherheit wichtig ist, sicherheitsrelevante Ereignisse benennen, die Werkzeuge Syslog, SNMP, NetFlow und IPFIX, IDS und IPS sowie SIEM einordnen, Anomalien von Fehlalarmen unterscheiden, Wireshark für Sicherheitsanalysen einsetzen und Vorfälle sachgerecht dokumentieren.

## 11.1 Warum Netzwerkmonitoring wichtig ist

Wer nicht sieht, was im Netz geschieht, erkennt einen Angriff erst, wenn der Schaden sichtbar wird. Die Zeit zwischen dem Eindringen und der Entdeckung ist oft lang, und in dieser Zeit kann sich ein Angreifer ausbreiten. Überwachung verkürzt diese Zeit, weil Auffälligkeiten früher auffallen.

Monitoring hat außerdem einen Nutzen, der über die Sicherheit hinausgeht. Die gleichen Daten zeigen Fehlkonfigurationen, überlastete Geräte und ausgefallene Dienste. Ein Netz, das gut überwacht wird, ist meist auch leichter zu betreiben. Die Überwachung ist deshalb ein fester Teil des Betriebs und kein nachträglicher Zusatz.

## 11.2 Sicherheitsrelevante Netzwerkereignisse

Nicht jedes Ereignis ist ein Hinweis auf einen Angriff. Relevant sind vor allem Anmeldungen, die fehlschlagen oder ungewöhnlich wirken, Änderungen an Konfigurationen, verworfene Verbindungen an der Firewall, neue Geräte am Netz, ungewöhnliche Mengen an Daten, Verbindungen zu unbekannten Zielen und Ausfälle von Sicherheitsfunktionen selbst. Wenn ein Schutzmechanismus abgeschaltet wird, ist das ein Ereignis, das sofort auffallen muss.

Die Auswahl der Ereignisse richtet sich nach dem Schutzbedarf. Ein Netz, das alles protokolliert, erzeugt mehr Daten, als jemand auswerten kann. Ein Netz, das zu wenig protokolliert, verliert die Spur. Die richtige Menge liegt in der Mitte und wird im Betrieb angepasst.

## 11.3 Logdateien

Logdateien halten fest, was ein Gerät getan hat. Jedes Ereignis trägt in der Regel einen Zeitstempel, eine Quelle, eine Kategorie und eine Beschreibung. Die Zeitangabe ist entscheidend: Ohne korrekt synchronisierte Uhren lassen sich Ereignisse aus verschiedenen Geräten nicht in eine zeitliche Reihenfolge bringen. Der Zeitdienst aus Kapitel 10 ist deshalb Voraussetzung für jede Auswertung.

Logs sind selbst schützenswert. Ein Angreifer, der sie löschen oder verändern kann, verwischt seine Spur. Deshalb werden Logs zentral gespeichert, mit Schreibrechten nur für den Dienst, der sie sammelt, und mit Prüfsummen oder ähnlichen Verfahren, die Veränderungen zeigen.

## 11.4 Syslog

Syslog ist ein verbreitetes Protokoll, mit dem Geräte ihre Meldungen an einen zentralen Empfänger senden. Die klassische Übertragung läuft über UDP auf Port 514. UDP ist einfach, bestätigt aber keine Zustellung, Meldungen können also verloren gehen. TCP und die verschlüsselte Variante über TLS bieten Zuverlässigkeit und Vertraulichkeit. Die verschlüsselte Übertragung über TLS nutzt in der Regel Port 6514.

Ein Syslog-Empfänger sammelt die Meldungen, speichert sie und leitet sie an Auswertungswerkzeuge weiter. Die Meldungen haben ein Format, das je nach Protokollversion unterschiedlich aufgebaut ist. Für die Auswertung ist wichtig, dass die Felder einheitlich sind. Geräte verschiedener Hersteller liefern Meldungen oft in leicht unterschiedlicher Form, und diese Unterschiede müssen beim Sammeln ausgeglichen werden.

## 11.5 SNMP

SNMP wurde bereits in Kapitel 10 als Protokoll zur Verwaltung behandelt. Für die Überwachung liefert es Zustandswerte wie Auslastung, Fehlerzähler, Temperatur und Verfügbarkeit. Ein Gerät kann außerdem Traps senden, wenn ein Schwellenwert überschritten wird. Eine Trap ist eine Nachricht, die das Gerät von sich aus meldet.

Für die Sicherheit sind die Zähler wichtig: Steigende Fehlerzahlen, ungewöhnliche Auslastung oder der Ausfall eines Geräts können auf Angriffe oder Störungen hindeuten. Die Verwendung von SNMPv3 mit Authentifizierung und Verschlüsselung gehört zur Absicherung der Überwachung selbst.

## 11.6 NetFlow und IPFIX

NetFlow und IPFIX sind Verfahren, die Verbindungen zusammenfassen. Ein Flow beschreibt, wer mit wem über welche Ports und Protokolle kommuniziert hat, wie viele Pakete und Bytes übertragen wurden und wann die Verbindung begann und endete. Die Inhalte der Pakete sind nicht enthalten. Flows zeigen also das Verhalten, nicht den Inhalt.

Diese Metadaten sind für die Erkennung wertvoll. Ein Arbeitsplatz, der plötzlich große Datenmengen an ein unbekanntes Ziel sendet, fällt im Flow-Bild auf, auch wenn der Inhalt verschlüsselt ist. NetFlow ist ein Herstellerverfahren mit mehreren Versionen, IPFIX ist der standardisierte Nachfolger, der in RFC 7011 beschrieben ist. Die Datenmenge kann groß werden, deshalb wird oft mit Stichproben gearbeitet.

## 11.7 IDS und IPS

Ein Intrusion Detection System, kurz IDS, erkennt verdächtigen Verkehr und meldet ihn. Ein Intrusion Prevention System, kurz IPS, greift zusätzlich ein und verwirft den Verkehr. Beide Systeme arbeiten mit Signaturen bekannter Angriffsmuster oder mit Anomalieerkennung, die vom normalen Verhalten abweicht.

Die Unterscheidung nach Ort ist wichtig. Ein netzwerkbasiertes System sieht den Verkehr auf einem Netzsegment und wird über einen Spiegelport oder einen Netzabgriff angeschlossen. Ein hostbasiertes System läuft auf dem Gerät selbst und sieht Dateizugriffe, Prozesse und lokale Anmeldungen. Beide ergänzen sich, weil sie unterschiedliche Sichtweisen haben.

Ein IPS im Verkehrspfad kann Dienste stören, wenn es falsch konfiguriert ist. Ein legitimer Verkehr, der einem Muster ähnelt, wird verworfen. Deshalb startet man oft im reinen Melde-Modus und schaltet das Eingreifen erst ein, wenn die Treffer geprüft sind.

## 11.8 SIEM-Grundlagen

Ein Security Information and Event Management System, kurz SIEM, sammelt Ereignisse aus vielen Quellen, normalisiert sie in ein einheitliches Format, verknüpft sie miteinander und erzeugt Alarme. Die Korrelation ist das Herzstück: Eine einzelne fehlgeschlagene Anmeldung ist unauffällig, dieselbe Anmeldung auf zehn Konten in zwei Minuten aus einem fremden Land nicht.

Das folgende Bild zeigt den Datenfluss in einem SIEM.




Schematische Darstellung des Datenflusses. Die Breiten sind nicht maßstabsgetreu.

**Abbildung 11.1.** Datenfluss in einem SIEM. Ereignisse aus vielen Quellen werden gesammelt, vereinheitlicht, verknüpft und bei Auffälligkeiten als Alarm gemeldet. Schematische Darstellung.

Ein SIEM braucht Speicher, Pflege der Regeln und Personal, das die Alarme bearbeitet. Ein System, das täglich Hunderte Meldungen erzeugt, ohne dass jemand sie prüft, nützt wenig. Die Einführung beginnt deshalb mit wenigen wichtigen Quellen und klaren Regeln.

## 11.9 Anomalieerkennung

Anomalieerkennung vergleicht das aktuelle Verhalten mit einer Grundlinie, der Baseline. Ein Gerät, das normalerweise wenige Verbindungen aufbaut, und plötzlich Hunderte, fällt auf. Der Vorteil ist, dass auch unbekannte Angriffsmuster sichtbar werden können. Der Nachteil ist, dass normale Veränderungen, etwa ein Backup oder ein Projekt mit neuen Anwendungen, ebenfalls auffallen.

Die Baseline muss regelmäßig angepasst werden und braucht Kenntnis des Betriebs. Ohne diese Kenntnis entstehen viele Fehlalarme.

## 11.10 Netzwerkverkehr analysieren

Die Analyse des Verkehrs zeigt Details, die Logs nicht liefern. Ein Mitschnitt macht Verbindungsaufbau, Antworten und Fehler sichtbar. Für die Sicherheit ist das wichtig, wenn ein Vorfall untersucht wird oder ein Verdacht geprüft werden soll.

Der Mitschnitt darf nur im eigenen Netz oder mit ausdrücklicher Genehmigung erfolgen. Er enthält unter Umständen personenbezogene Daten, deshalb gelten besondere Regeln für Speicherung, Zugriff und Löschung. Die Frage, wie lange Daten aufbewahrt werden dürfen, hängt von Zweck und Rechtsgrundlage ab und sollte mit der Datenschutzbeauftragten oder dem Datenschutzbeauftragten geklärt werden.

## 11.11 Wireshark für Sicherheitsanalysen

Wireshark zeigt die Pakete eines Mitschnitts und erlaubt die Filterung nach Adressen, Protokollen und Ports. Für Sicherheitsanalysen ist die Anzeige von Verbindungen, Flags und Wiederholungen besonders hilfreich. Eine ungewöhnlich hohe Zahl von Verbindungsversuchen zu vielen Ports, die nie beantwortet werden, zeigt zum Beispiel, dass ein Gerät ein Netz abtastet. Wie in Band 6 beschrieben, liefert ein Mitschnitt genaue Belege, wenn die Auswertung sauber dokumentiert wird.

Die Grenzen sind klar. Verschlüsselter Verkehr bleibt verschlüsselt, und ohne den Schlüssel ist er nicht lesbar. Wireshark zeigt, was im Netz stattfindet, aber nicht, wer es veranlasst hat. Diese Zuordnung braucht die Ergänzung durch Logs und Protokolle der Endgeräte.

## 11.12 Alarmierung und Eskalation

Ein Alarm ist nur nützlich, wenn jemand weiß, was zu tun ist. Eine Eskalationsstufe legt fest, wer bei welcher Schwere informiert wird, wie schnell reagiert werden muss und welche Schritte vorgesehen sind. Diese Regeln stehen in einer Verfahrensbeschreibung, die vorab abgestimmt und geübt wird.

Die Schwere eines Alarms richtet sich nach Schutzbedarf, Wahrscheinlichkeit und möglichem Schaden. Ein fehlgeschlagener Anmeldeversuch auf einem internen Testsystem ist anders zu bewerten als ein Datenabfluss aus einer Kundendatenbank. Für die kritischen Fälle braucht es eine Rufbereitschaft oder eine Vertretungsregel, damit auch außerhalb der Arbeitszeit reagiert werden kann.

## 11.13 False Positives und False Negatives

Ein Fehlalarm, ein False Positive, meldet einen Vorfall, der keiner ist. Ein verpasster Angriff, ein False Negative, bleibt unentdeckt. Beide Fehler kosten. Zu viele Fehlalarme führen dazu, dass Alarme ignoriert werden, und dann bleibt auch der echte Angriff unbemerkt. Zu wenige Alarme lassen Angriffe ungestört. Die Regeln werden deshalb mit der Zeit angepasst, und jeder Alarm wird danach eingeordnet.

Ein Verfahren hilft dabei: Jeder Alarm wird als echt, als Fehlalarm oder als ungeklärt markiert. Die Statistik zeigt, welche Regeln viele Fehlalarme erzeugen und angepasst werden sollten.

## 11.14 Dokumentation von Sicherheitsvorfällen

Ein Vorfall wird von der Meldung bis zum Abschluss festgehalten. Die Dokumentation enthält den Zeitpunkt der Entdeckung, die betroffenen Systeme, die getroffenen Maßnahmen, die Entscheidungen und die Ergebnisse. Eine Zeitleiste macht den Ablauf nachvollziehbar, und eine Auswertung nach dem Vorfall zeigt, was verbessert werden kann.

Die Dokumentation ist auch ein Werkzeug für die Zusammenarbeit. Sie hilft Kolleginnen und Kollegen, den Vorfall zu verstehen, und sie dient später als Nachweis gegenüber Kunden, Prüfern oder Behörden, wenn dies nötig ist.

## 11.15 Überblick über die Werkzeuge

Die folgende Tabelle ordnet die Werkzeuge ihren Einsatzbereichen zu.

| Werkzeug | Einsatzbereich |
|---|---|
| Syslog | zentrale Sammlung von Meldungen aus Geräten und Diensten |
| SNMP und Traps | Zustandswerte und Schwellenwerte für Geräte |
| NetFlow, IPFIX | Verbindungsmetadaten zur Erkennung ungewöhnlichen Verhaltens |
| IDS, IPS | Erkennung und Abwehr bekannter Angriffsmuster |
| SIEM | Korrelation und Alarmierung über viele Quellen |
| Wireshark | Detailanalyse einzelner Verbindungen im eigenen Netz |

**Tabelle 11.1.** Werkzeuge der Überwachung und ihr Einsatzbereich. Die Werkzeuge ergänzen sich und ersetzen einander nicht.

> **Merke**
>
> Überwachung macht Angriffe früher sichtbar. Syslog und Flows liefern die Spuren, IDS und IPS erkennen Muster, das SIEM verknüpft alles. Entscheidend sind die Regeln gegen Fehlalarme, eine klare Eskalation und eine sorgfältige Dokumentation.

## Zusammenfassung

Überwachung macht im Netz sichtbar, was geschieht. Die Werkzeuge reichen von Logs über Flows bis zu IDS und SIEM. Sie liefern nur dann Nutzen, wenn Zeit, Regeln, Eskalation und Dokumentation zusammenpassen.

## Kontrollfragen

1. Warum muss die Zeit auf allen Geräten synchronisiert sein, bevor Logs ausgewertet werden?
2. Welche Information liefert ein NetFlow-Datensatz, und welche nicht?
3. Worin unterscheidet sich ein IDS von einem IPS?
4. Warum ist die Korrelation im SIEM wichtiger als die einzelne Meldung?
5. Was bedeutet ein False Positive, und warum schadet eine hohe Zahl davon der Erkennung?

KAPITEL 12

# Sicherheitskonzepte für Unternehmen

**Lernziele.** Nach diesem Kapitel kannst du die Sicherheitsanforderungen eines Unternehmens ermitteln, den Schutzbedarf bestimmen, Netzwerkrisiken bewerten, ein Zonen-, Firewall- und VLAN-Konzept entwickeln, VPN-Zugänge und Benutzerrechte planen, Gastzugänge und Servernetze absichern, Backup, Updates und Notfallplanung einordnen und die Sicherheit regelmäßig überprüfen. Alle Teile werden an einem durchgängigen Beispiel umgesetzt.

**Das Beispielunternehmen.** Die Musterbau GmbH ist ein fiktives Unternehmen mit 35 Beschäftigten und einem Standort. Es fertigt Metallbauteile für Kunden in der Region. Im Büro arbeiten Verwaltung, Vertrieb und Geschäftsführung, in der Werkstatt Produktion und Lager. Kundendaten, Konstruktionszeichnungen und Lieferverträge sind die wichtigsten Informationen. Außerdem gibt es Maschinen mit Netzanschluss, einen Drucker-Park, Besuchende und mehrere Dienstleister, die über das Internet arbeiten. Die Zahlen sind Annahmen zur Veranschaulichung.

## 12.1 Sicherheitsanforderungen ermitteln

Ein Sicherheitskonzept beginnt mit der Frage, was geschützt werden muss und warum. Die Antwort kommt aus dem Geschäft und nicht aus der Technik. Bei der Musterbau GmbH ist klar: Ohne Kundendaten und Zeichnungen steht die Fertigung still, und ein abgeflossener Entwurf kann einem Kunden schaden. Diese Einsichten gehören in eine schriftliche Anforderungsliste, die von der Geschäftsführung bestätigt wird.

Die Anforderungen werden mit den Fachabteilungen abgestimmt. Die Werkstatt nennt andere Bedürfnisse als die Verwaltung, und die Geschäftsführung legt fest, welche Risiken das Unternehmen tragen will. Ein Konzept ohne diese Abstimmung wird später umgangen, weil es die Arbeit behindert.

## 12.2 Schutzbedarf bestimmen

Der Schutzbedarf beschreibt, wie stark ein Schaden an einer Information oder einem System ausfallen würde. Das BSI unterscheidet in seinem IT-Grundschutz üblicherweise die Stufen normal, hoch und sehr hoch, jeweils für die Schutzziele Vertraulichkeit, Integrität

und Verfügbarkeit aus Kapitel 1. Das Ergebnis bestimmt, wie aufwendig die Schutzmaßnahmen sein müssen.

Für die Musterbau GmbH ergibt sich folgende Einschätzung. Die Konstruktionsdaten haben einen hohen Schutzbedarf bei Vertraulichkeit, weil ihr Verlust Wettbewerbsvorteile kostet. Die Produktionssteuerung hat einen hohen Schutzbedarf bei Verfügbarkeit, weil ein Ausfall die Fertigung stoppt. Das allgemeine Büronetz hat einen normalen Schutzbedarf. Die Gastbereiche werden als eigene Kategorie behandelt, weil dort keine internen Informationen liegen dürfen.

| Ressource | Schutzbedarf | Begründung |
|---|---|---|
| Konstruktionsdaten | hoch (Vertraulichkeit) | Verlust führt zu Wettbewerbsnachteil |
| Produktionssteuerung | hoch (Verfügbarkeit) | Ausfall stoppt die Fertigung |
| Verwaltung und Buchhaltung | hoch (Integrität) | fehlerhafte Buchungen wirken rechtlich |
| Büro-Arbeitsplätze | normal | allgemeiner Arbeitsbetrieb |
| Gäste und Dienstleister | normal, getrennt | keine internen Daten erlaubt |

**Tabelle 12.1.** Schutzbedarf der wichtigsten Ressourcen der Musterbau GmbH. Die Einstufung ist ein Beispiel und muss im Einzelfall geprüft werden.

## 12.3 Netzwerkrisiken bewerten

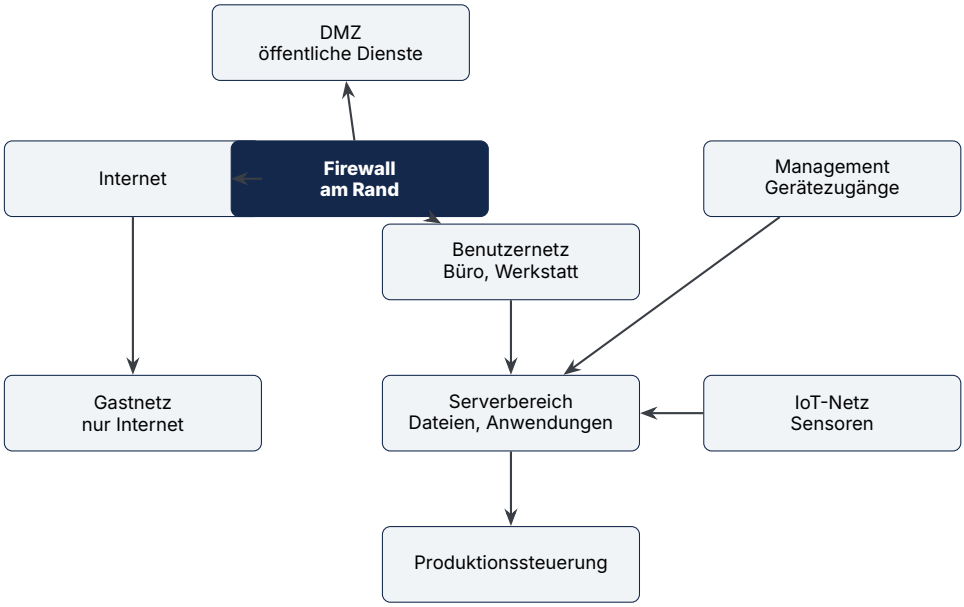
Ein Risiko entsteht, wie in Kapitel 1 beschrieben, aus Bedrohung, Schwachstelle und möglicher Auswirkung. Für die Bewertung hilft eine einfache Matrix mit Eintrittswahrscheinlichkeit und Schadenshöhe. Ein Risiko mit hoher Wahrscheinlichkeit und hohem Schaden braucht die sofortige Maßnahme. Ein Risiko mit geringer Wahrscheinlichkeit und geringem Schaden wird akzeptiert und dokumentiert.

Die Musterbau GmbH bewertet unter anderem folgende Risiken. Ein Ransomware-Befall über einen Arbeitsplatz ist wahrscheinlich und kann die Produktion lahmlegen, deshalb ist er ein Hauptrisiko. Ein unbefugter Zugriff auf Konstruktionsdaten aus dem Gastnetz ist unwahrscheinlich, wäre aber schwer, deshalb wird er durch Trennung ausgeschlossen. Ein Ausfall des Internetanschlusses ist wahrscheinlich, der Schaden ist aber begrenzt, weil Produktion und Vertrieb lokal weiterarbeiten können. Die Bewertung bleibt im Konzept als Grundlage für spätere Entscheidungen.

## 12.4 Sicherheitszonen planen

Das Zonenkonzept überträgt den Schutzbedarf auf die Netzstruktur. Jede Zone hat einen Zweck, eine Vertrauensannahme und klare Regeln für den Verkehr. Die Musterbau GmbH nutzt folgende Zonen: das Internet als unsicheren Bereich, die DMZ für öffentliche Dienste, das Benutzernetz für Büro und Werkstatt, den Serverbereich für Dateien und Anwendungen, den Bereich Produktionssteuerung als eigene Zone, das Management für die Geräte, das Gastnetz und das IoT-Netz für Maschinensensoren und Gebäudetechnik.

Die folgende Abbildung zeigt die Zonen und die wichtigsten Übergänge.




Schematische Darstellung. Die Pfeile zeigen erlaubte Richtungen, nicht den vollständigen Verkehr.

**Abbildung 12.1.** Sicherheitszonen der Musterbau GmbH. Die Gastzone hat nur einen Weg ins Internet. Schematische Darstellung.

Die Zonen werden über VLANs und Firewall-Regeln umgesetzt, wie in Kapitel 3 und 4 beschrieben. Die Produktionssteuerung ist zusätzlich vom Büronetz getrennt, damit ein Büroarbeitsplatz die Steuerung nicht erreicht. Dienste, die das Büro braucht, etwa Datei-Freigaben, laufen über den Serverbereich und nicht direkt.

## 12.5 Firewall- und VLAN-Konzept

Das Firewall-Konzept legt für jeden Übergang zwischen den Zonen die erlaubten Verbindungen fest. Die Grundregel ist Default Deny. Jede Freigabe braucht einen Zweck, einen Verantwortlichen und einen Überprüfungstermin. Die Musterbau GmbH führt eine Regelmatrix, die diese Angaben enthält, und die Änderungen laufen über einen dokumentierten Ablauf.

Das VLAN-Konzept folgt dem Zonenplan. Die Trunks tragen nur die VLANs, die am jeweiligen Switch gebraucht werden, das Native VLAN bleibt ungenutzt, und ungenutzte Ports sind abgeschaltet, wie in Kapitel 4 und 10 beschrieben. Die Werkstatt erhält Ports mit Port Security und DHCP Snooping, damit ein unbekannter Laptop keinen Zugang erhält.

## 12.6 VPN-Zugänge planen

Die Musterbau GmbH braucht Fernzugriff für Vertrieb und Geschäftsführung, die unterwegs arbeiten, und für einen externen Dienstleister, der die Maschinensteuerung betreut. Für den Fernzugriff der Beschäftigten wird ein Remote-Access-VPN geplant, das Full Tunneling nutzt, damit der gesamte Verkehr der Firmengeräte durch die Firewall läuft. Die Verbindung wird mit Benutzerkonten und Mehrfaktor-Authentifizierung abgesichert.

Die Wahl des Protokolls ist eine Abwägung. Das Unternehmen hat bereits eine Firewall mit IPsec-Unterstützung und ein Konzept für Zertifikate geplant, deshalb fällt die Entscheidung auf IPsec mit IKEv2. Für die kleine Anbindung eines Standorts ohne Gerät wäre WireGuard ebenfalls denkbar, wie in Kapitel 6 und 7 verglichen. Der Dienstleister erhält einen eigenen Zugang, der nur auf die Steuerungssoftware begrenzt ist und zeitlich befristet wird. Jeder Zugang wird protokolliert.

## 12.7 Benutzer- und Rechtekonzept

Das Rechtekonzept folgt den Grundsätzen aus Kapitel 9. Die Musterbau GmbH definiert Rollen wie Verwaltung, Vertrieb, Konstruktion, Werkstatt und Geschäftsführung. Jede Rolle erhält nur die Zugriffe, die sie für ihre Aufgabe braucht. Konstruktionsdaten sind nur für die Konstruktion lesbar, Buchhaltungsdaten nur für die Verwaltung.

Der Lebenszyklus der Konten wird geregelt. Ein neuer Mitarbeiter erhält sein Konto erst nach der Freigabe durch die Fachstelle. Bei einem Wechsel werden die alten Rechte entzogen, bevor die neuen gesetzt werden. Beim Austritt wird das Konto am letzten Arbeitstag gesperrt. Administrative Konten werden getrennt von den persönlichen Konten

angelegt und nur von der IT-Verantwortlichen und einer Vertretung genutzt.

## 12.8 Gastzugänge absichern

Besuchende und Dienstleister erhalten einen Zugang zum Gastnetz. Das Gastnetz hat eine eigene SSID, ein eigenes VLAN und keinen Weg in interne Systeme, wie in Kapitel 9 beschrieben. Das Passwort wird monatlich gewechselt und beim Empfang ausgegeben. Die Bandbreite wird begrenzt, damit ein Gast die Verbindung nicht für das Unternehmen blockiert.

Die Protokollierung erfasst Gastzugänge mit Zeitpunkt und Gerät, soweit das datenschutzrechtlich zulässig ist. Die Zulässigkeit der Speicherung personenbezogener Daten von Besuchenden sollte mit der Datenschutzbeauftragten oder dem Datenschutzbeauftragten geklärt werden.

## 12.9 Servernetz schützen

Der Serverbereich ist das Ziel vieler Angriffe, deshalb wird er besonders gehärtet. Die Server laufen nur mit den Diensten, die sie brauchen. Die Verwaltungszugänge sind auf das Management-Netz beschränkt, und die Protokolle gehen an einen zentralen Empfänger. Der Zugriff auf Freigaben folgt den Rollen. Die Mikrosegmentierung aus Kapitel 8 begrenzt zusätzlich, welche Systeme untereinander sprechen dürfen. Die Konstruktionsdaten liegen auf einem Server, der nur von der Konstruktion erreichbar ist.

## 12.10 Backup und Wiederherstellung

Die Musterbau GmbH folgt der Faustregel 3-2-1: drei Kopien der Daten, auf zwei unterschiedlichen Medien, davon eine außerhalb des Standorts. Ein Backup, das auf demselben Netz liegt, wird von Ransomware mitverschlüsselt, wie in Kapitel 2 beschrieben. Deshalb wird eine Kopie offline oder unveränderlich gespeichert, die von der Produktion aus nicht erreichbar ist.

Ein Backup gilt erst als gesichert, wenn die Wiederherstellung geübt wurde. Die Musterbau GmbH prüft vierteljährlich eine Wiederherstellung einer Stichprobe, und die Ergebnisse werden dokumentiert. Die Zeit, die für die Wiederherstellung benötigt wird, ist ein wichtiger Wert für die Notfallplanung.

## 12.11 Patch- und Update-Management

Updates schließen bekannte Lücken, und ein Plan regelt Zeitpunkt und Reihenfolge. Die Musterbau GmbH unterscheidet kritische Sicherheitsupdates, die innerhalb weniger Tage eingespielt werden, und reguläre Updates, die monatlich in einem Wartungsfenster erfolgen. Vor jedem größeren Update wird die Konfiguration gesichert, und die Produktionssteuerung wird nur in Abstimmung mit der Werkstatt aktualisiert, damit der Betrieb nicht unterbrochen wird.

Geräte, deren Hersteller keine Updates mehr liefert, stehen auf einer Ersatzliste. Der Ersatz wird eingeplant, bevor das Support-Ende eintritt.

## 12.12 Notfallplanung

Eine Notfallplanung beschreibt, was bei einem größeren Vorfall zu tun ist, etwa bei einem Ransomware-Befall oder dem Ausfall des Rechenzentrums. Die Musterbau GmbH erstellt ein Notfallhandbuch mit den wichtigsten Schritten. Es enthält Ansprechpartner, Kontaktwege zum Internetanbieter und zum IT-Dienstleister, eine Priorisierung der Systeme nach Wichtigkeit und einen Wiederanlaufplan mit Zeitzielen.

Die Schritte werden geübt. Eine Übung am Tisch, bei der die Beteiligten einen fiktiven Vorfall durchspielen, zeigt Lücken in der Planung. Danach wird das Handbuch angepasst. Die Übung findet mindestens einmal im Jahr statt.

Die Musterbau GmbH legt außerdem fest, wann die Geschäftsführung informiert wird, wann externe Stellen eingebunden werden und welche Meldepflichten bestehen. Gesetzliche Pflichten, etwa aus der NIS-2-Richtlinie, hängen von Branche und Größe ab und sind im Einzelfall zu prüfen. Dieses Kapitel gibt dazu keine verbindliche Auskunft.

## 12.13 Sicherheitsdokumentation

Die Dokumentation ist die Grundlage für alle Prüfungen und für den Notfall. Die Musterbau GmbH pflegt folgende Unterlagen: den Netzplan mit Zonen und Übergängen, den IP-Adressplan, die Regelmatrix der Firewall, die Liste der Konten und Rollen, die Gerätelisten mit Firmware-Stand, die Sicherungskonzepte, das Notfallhandbuch und das Verzeichnis der Ansprechpartner. Jede Unterlage hat einen Verantwortlichen und ein Datum der letzten Prüfung.

Eine Dokumentation, die nicht gepflegt wird, führt in die Irre. Deshalb gehört die Aktualisierung in den Ablauf von Änderungen: Wer eine Regel ändert, passt die Regelmatrix

an.

## 12.14 Regelmäßige Sicherheitsüberprüfungen

Sicherheit lässt sich nicht einmal herstellen und dann vergessen. Die Musterbau GmbH plant einen Kalender mit festen Terminen. Die Rechteüberprüfung findet jährlich statt, für privilegierte Konten halbjährlich. Die Konfiguration der Firewall und der Switches wird vierteljährlich gegen die Richtlinie geprüft. Einmal im Jahr wird ein Penetrationstest durch einen externen Dienstleister durchgeführt, dessen Umfang schriftlich vereinbart und von der Geschäftsführung freigegeben wird. Die Ergebnisse fließen in einen Maßnahmenplan mit Verantwortlichen und Terminen.

Die Überprüfung muss auch die Wirksamkeit der Maßnahmen messen. Die Zahl der Alarme, die Dauer bis zur Behebung kritischer Lücken und die Ergebnisse der Wiederherstellungsübungen zeigen, ob das Konzept greift.

## 12.15 Zusammenfassung des Beispiels

Die Musterbau GmbH verbindet alle Bausteine. Der Schutzbedarf bestimmt die Zonen, die Zonen bestimmen die Firewall- und VLAN-Regeln, die Rollen bestimmen die Zugriffe, und die Überwachung zeigt, ob alles wie geplant wirkt. Backup, Updates und Notfallplanung sichern den Betrieb, wenn doch etwas geschieht. Die Dokumentation hält alles nachvollziehbar, und die Überprüfung sorgt dafür, dass das Konzept nicht veraltet.

> **Merke**
>
> Ein Sicherheitskonzept beginnt bei den Anforderungen des Geschäfts und endet bei der Überprüfung. Zonen, Regeln, Rechte, Sicherungen, Notfallplanung und Dokumentation greifen ineinander. Ein Konzept, das nur auf dem Papier steht, schützt nicht, deshalb gehören Übungen und Prüfungen dazu.

## Zusammenfassung

Ein Unternehmenskonzept verbindet Schutzbedarf, Zonen, Netzregeln, Zugriffe, Sicherungen, Notfallplanung, Dokumentation und Überprüfung. Das Beispiel der Musterbau GmbH zeigt, wie diese Bausteine für ein kleines Unternehmen zusammenpassen, ohne zu groß zu werden.

## Kontrollfragen

1. Warum beginnt ein Sicherheitskonzept bei den Anforderungen des Geschäfts und nicht bei der Technik?
2. Welche Schutzbedarfsstufe hat die Produktionssteuerung der Musterbau GmbH, und welches Schutzziel steht im Vordergrund?
3. Warum reicht ein Backup im selben Netz nicht gegen Ransomware aus?
4. Warum wird die Produktionssteuerung nur in Abstimmung mit der Werkstatt aktualisiert?
5. Welche Unterlagen gehören zur Sicherheitsdokumentation, und warum muss jede einen Verantwortlichen haben?

KAPITEL 13

# Praxisprojekte und Übungen

**Lernziele.** Nach diesem Kapitel hast du in einem eigenen Laborumfeld Firewall-Regeln, VLAN-Segmentierung, eine DMZ, einen WireGuard-Tunnel und ein Site-to-Site-Konzept umgesetzt, ein Zero-Trust-Konzept entwickelt und Netzwerkereignisse mit Wireshark ausgewertet. Die Projekte bauen aufeinander auf, können aber einzeln bearbeitet werden.

**Geltungsbereich.** Alle Projekte finden in einem eigenen Labor aus virtuellen Maschinen statt. Die Adressen sind Testwerte aus den Dokumentationsbereichen nach RFC 5737 und aus dem privaten Adressraum. Schlüssel, Zertifikate und Passwörter sind Platzhalter, die für das Labor neu erzeugt werden. Angriffswerkzeuge gegen fremde Systeme werden nicht verwendet. Tests richten sich ausschließlich an Systeme des eigenen Labors.

## Gemeinsames Laborumfeld

Das Labor besteht aus drei Linux-Maschinen in einer Virtualisierungsumgebung: einem Gateway mit drei Netzwerkschnittstellen, einem Client im Netz A und einem Server im Netz B. Die Maschinen laufen auf einem eigenen virtuellen Switch, der vom Heimnetz getrennt ist. Für die Dokumentation wird jede Maschine mit Name, Schnittstelle und Adresse beschrieben.

| Gerät | Schnittstelle | Adresse und Rolle |
|---|---|---|
| gw01 | eth0 | 198.51.100.2/24, Verbindung zum Testinternet |
| gw01 | eth1 | 10.20.0.1/24, Netz A (Client) |
| gw01 | eth2 | 10.30.0.1/24, Netz B (Server) |
| client-a | eth0 | 10.20.0.10/24, Standardgateway 10.20.0.1 |
| srv-b | eth0 | 10.30.0.10/24, Standardgateway 10.30.0.1 |

**Tabelle 13.1.** Gemeinsames Laborumfeld mit Netzplan und IP-Adressplan. Das Testinternet wird durch ein weiteres virtuelles Netz nachgebildet.

Die Gateway-Maschine leitet Pakete zwischen den Netzen weiter, wenn die IP-

Weiterleitung aktiviert ist. Die Aktivierung erfolgt über den Kernel-Parameter für die Weiterleitung, und sie gehört zu jeder Routerkonfiguration im Labor.

## 13.1 Projekt 1: Eine Firewall für ein Testnetzwerk konfigurieren

### Lernziel

Du konfigurierst eine zustandsbehaftete Firewall mit Default Deny und prüfst jede Regel mit einem Test.

### Voraussetzungen

Das gemeinsame Laborumfeld mit gw01, client-a und srv-b. Grundkenntnisse aus Kapitel 3 und Kapitel 4.

### Hardware und Software

Drei virtuelle Maschinen mit Linux, nftables auf gw01, ein Terminal auf den Maschinen.

### Netzplan und IP-Adressplan

Siehe Tabelle im gemeinsamen Laborumfeld. Die Firewall läuft auf gw01 und trennt die Netze A und B sowie das Testinternet.

### Vorbereitung

Lege eine Regelmatrix an. Sie enthält für jede Verbindung Quelle, Ziel, Protokoll, Port und Zweck. Die Regelmatrix ist die Vorlage für die Konfiguration.

### Schritt für Schritt

1. Prüfe, dass Client und Server sich gegenseitig per Ping erreichen, bevor die Firewall aktiv ist. Diese Ausgangslage dokumentierst du.
2. Lege auf gw01 eine Regeldatei mit Default Deny für die Kette der Eingangspakete an und erlaube nur den Verkehr, den die Matrix vorsieht.

3. Erlaube Antworten über die Zustandstabelle, damit nicht jede Antwort einzeln geregelt werden muss.
4. Lade die Regeln und prüfe jede erlaubte Verbindung und jede verbotene Verbindung.
5. Dokumentiere Ergebnis und Abweichungen.

## Konfigurationsbeispiel

Das folgende Beispiel zeigt eine vereinfachte Regeldatei für die Eingangskette von gw01 im Labor.

```
table inet filter {
  chain input {
    type filter hook input priority 0; policy drop;
    ct state established,related accept
    iif lo accept
    iif eth1 tcp dport 22 accept
    iif eth1 icmp type echo-request accept
  }
  chain forward {
    type filter hook forward priority 0; policy drop;
    ct state established,related accept
    iif eth1 oif eth2 tcp dport 443 accept
    iif eth1 oif eth0 tcp dport { 80, 443 } accept
  }
}
```

Die Regeln erlauben SSH aus Netz A auf gw01, ICMP-Anfragen aus Netz A, HTTPS aus Netz A in Netz B und Web-Zugriffe aus Netz A ins Testinternet. Alles andere wird verworfen.

## Erwartetes Ergebnis

Client-a erreicht srv-b auf Port 443, aber nicht auf andere Ports. Ein Verbindungsversuch auf Port 23 wird verworfen. Die Rückpakete laufen über die Zustandstabelle.

### Sicherheitshinweise

Die Regeldatei gehört nur in das Labor. Bei Änderungen auf einer Maschine, die über das Netz erreichbar ist, muss der eigene Zugang vorher erhalten bleiben, sonst sperrt man sich selbst aus. Ein Notzugang über die Konsole der virtuellen Maschine ist deshalb einzurichten.

### Typische Fehler

Die Regeln werden ohne Zustandstabelle geschrieben, sodass Antworten fehlen. Die Richtung der Regel ist falsch gewählt. Oder die Standardrichtlinie wird auf Accept gesetzt und die Regeln wirken nicht.

### Kontrollfragen

Warum verhindert eine Standardrichtlinie auf Drop mehr Angriffe als eine Liste von Verboten? Welche Regel erlaubt die Antworten auf eine HTTPS-Verbindung aus Netz A?

### Lösung

Die Standardrichtlinie Drop bedeutet, dass nur ausdrücklich erlaubter Verkehr passiert. Die Zustandsregel lässt Antworten zu bestehenden Verbindungen durch, ohne dass eine Regel für die Gegenrichtung nötig ist. Die HTTPS-Antwort aus Netz B wird durch die Regel ct state established,related erlaubt.

## 13.2 Projekt 2: Ein Netzwerk mit mehreren VLANs segmentieren

### Lernziel

Du trennst ein Netz in zwei VLANs, verbindest sie über das Gateway und kontrollierst den Verkehr zwischen ihnen.

### Voraussetzungen

Das Laborumfeld aus Projekt 1. Die Virtualisierungsumgebung muss VLAN-Tagging auf dem virtuellen Switch erlauben.

## Hardware und Software

Drei virtuelle Maschinen mit Linux, das Werkzeug ip, ein virtueller Switch mit VLAN-Unterstützung.

## Netzplan und IP-Adressplan

Die Maschine client-a erhält eine Schnittstelle im VLAN 20, srv-b eine im VLAN 40. Die Gateway-Maschine hat für jedes VLAN eine Unterschnittstelle.

| Gerät | VLAN | Adresse |
|---|---|---|
| client-a | 20 | 10.20.0.10/24 |
| gw01 | 20 | 10.20.0.1/24 |
| gw01 | 40 | 10.40.0.1/24 |
| srv-b | 40 | 10.40.0.10/24 |

**Tabelle 13.2.** VLAN-Plan für das Projekt. Die Adresse von srv-b wechselt damit vom bisherigen Netz B in das VLAN 40.

## Vorbereitung

Lege die Zuordnung fest: Die Ports des virtuellen Switches für client-a und srv-b werden als Zugangsports für ihr VLAN konfiguriert, der Port zum Gateway als Trunk mit den Tags 20 und 40. Das Native VLAN bleibt ungenutzt.

## Schritt für Schritt

1. Konfiguriere die Switch-Ports entsprechend dem VLAN-Plan.
2. Lege auf gw01 die VLAN-Unterschnittstellen an und weise die Adressen zu.
3. Prüfe, dass client-a das Gateway im VLAN 20 erreicht und srv-b das Gateway im VLAN 40.
4. Teste die Verbindung zwischen den VLANs, bevor Regeln gesetzt sind. Ohne Regel sollte die Verbindung über das Gateway möglich sein.
5. Setze eine Regel, die nur HTTPS aus VLAN 20 nach VLAN 40 erlaubt, und teste erneut.

## Konfigurationsbeispiel

Die folgenden Befehle legen eine VLAN-Unterschnittstelle für VLAN 20 auf gw01 an.

```
ip link add link eth1 name eth1.20 type vlan id 20
ip addr add 10.20.0.1/24 dev eth1.20
ip link set eth1.20 up
```

Für VLAN 40 erfolgt die Anlage entsprechend mit der Kennung 40 und der Adresse 10.40.0.1/24.

## Erwartetes Ergebnis

Die beiden VLANs sind voneinander getrennt. Eine Verbindung von client-a zu srv-b ist nur über das Gateway möglich, und dort greift die Regel.

## Sicherheitshinweise

Kein Access-Port darf am Trunk hängen, und der Trunk darf nur die benötigten VLANs tragen. Die automatische Trunk-Aushandlung wird abgeschaltet, wenn die Virtualisierung sie anbietet.

## Typische Fehler

Die VLAN-Kennung wird am Port falsch gesetzt, sodass die Maschine im falschen Netz landet. Das Gateway hat die Adresse im falschen Netz. Oder der Trunk fehlt, sodass das Gateway kein Tag sieht.

## Kontrollfragen

Warum sollte das Native VLAN nicht für Benutzergeräte genutzt werden? Was passiert, wenn der Trunk nur VLAN 20 trägt?

## Lösung

Ohne Trunk für VLAN 40 erreicht das Gateway srv-b im VLAN 40 nicht, und die Verbindung scheitert. Die Native-VLAN-Regel verhindert, dass ungetaggte Frames unbeabsichtigt in einem Benutzernetz landen.

## 13.3 Projekt 3: Eine DMZ planen und umsetzen

### Lernziel

Du richtest eine DMZ ein, in der ein Webserver aus dem Testinternet erreichbar ist, während das Netz A keinen Zugriff auf die DMZ hat, der über die Freigabe hinausgeht.

### Voraussetzungen

Das Laborumfeld aus Projekt 1, ein weiterer Linux-Server als Webserver.

### Hardware und Software

Vier virtuelle Maschinen mit Linux, nftables, ein einfacher Webserver auf dem DMZ-Server.

### Netzplan und IP-Adressplan

Die DMZ wird als eigenes Netz 10.50.0.0/24 angelegt. Der Webserver erhält 10.50.0.10. Das Gateway bekommt auf dieser Seite die Adresse 10.50.0.1.

### Vorbereitung

Lege die Regelmatrix für drei Richtungen fest: aus dem Internet in die DMZ, aus der DMZ in das interne Netz und aus dem Netz A in die DMZ. Nur die erste Richtung ist für den Webverkehr auf Port 443 offen. Die zweite Richtung ist für den Webserver gesperrt, außer für eine Datenbankverbindung in ein Testnetz, falls im Projekt vorgesehen.

### Schritt für Schritt

1. Lege die DMZ an und verbinde den Webserver mit dem Gateway.
2. Konfiguriere die Regeln für die drei Richtungen.
3. Starte den Webserver und prüfe den Zugriff aus dem Testinternet auf Port 443.
4. Prüfe, dass der Webserver keinen Zugriff auf Netz A oder Netz B aufbauen kann.
5. Prüfe, dass Netz A nur die freigegebenen Dienste erreicht.

### Konfigurationsbeispiel

Der folgende Ausschnitt zeigt die Weiterleitung für den Webverkehr aus dem Testinternet in die DMZ.

```
table inet dmz {
  chain forward {
    type filter hook forward priority 0; policy drop;
    ct state established,related accept
    iif eth0 oif eth3 tcp dport 443 ip daddr 10.50.0.10 accept
    iif eth3 oif eth1 drop
    iif eth3 oif eth2 drop
  }
}
```

Die Schnittstelle eth3 gehört hier zur DMZ. Die letzten beiden Regeln verwerfen Verbindungen aus der DMZ in die internen Netze, auch wenn die Standardrichtlinie sie nicht erfasst.

### Erwartetes Ergebnis

Der Webserver ist aus dem Testinternet über Port 443 erreichbar. Aus der DMZ kann keine Verbindung in Netz A oder Netz B aufgebaut werden. Netz A erreicht den Webserver nur über die Freigabe.

### Sicherheitshinweise

Der Webserver ist die exponierteste Maschine im Labor. Er erhält nur die notwendigen Dienste und ein aktuelles System. Die Verwaltung erfolgt nur aus Netz A.

### Typische Fehler

Die DMZ erhält versehentlich Zugriff auf das interne Netz, weil eine allgemeine Freigabe zu weit gefasst ist. Der Rückweg aus der DMZ wird verworfen, weil die Zustandsregel fehlt. Oder der Webserver ist über die Verwaltungsschnittstelle erreichbar, die nicht gewollt ist.

### Kontrollfragen

Warum muss die Verbindung aus der DMZ ins interne Netz stärker eingeschränkt sein als die Verbindung aus dem Internet in die DMZ? Welche Regel verhindert, dass der Webserver eine Verbindung nach Netz A aufbauen kann?

### Lösung

Eine kompromittierte DMZ-Maschine darf keinen Weg ins interne Netz öffnen, deshalb sind die Regeln aus der DMZ in das interne Netz verboten. Die Regel mit dem Verwerfen von eth3 nach eth1 verhindert den Zugriff nach Netz A.

## 13.4 Projekt 4: Einen WireGuard-VPN-Tunnel einrichten

### Lernziel

Du richtest einen WireGuard-Tunnel zwischen client-a und gw01 ein, leitest das Testnetz über den Tunnel und prüfst den Handshake.

### Voraussetzungen

Das Laborumfeld aus Projekt 1, Kenntnis der Konfiguration aus Kapitel 6.

### Hardware und Software

Zwei Linux-Maschinen mit installiertem WireGuard, Werkzeug wg für die Steuerung.

### Netzplan und IP-Adressplan

Das Tunnelnetz ist 10.99.0.0/24. gw01 erhält 10.99.0.1, client-a erhält 10.99.0.2. Der Endpunkt von gw01 ist 10.20.0.1 im Laborumfeld, was als öffentlicher Endpunkt für den Test dient.

## Vorbereitung

Erzeuge auf beiden Maschinen ein Schlüsselpaar und trage die öffentlichen Schlüssel gegenseitig ein. Die Dateirechte der Konfiguration werden auf den Besitzer beschränkt.

## Schritt für Schritt

1. Erzeuge auf jedem Gerät ein Schlüsselpaar und notiere den öffentlichen Schlüssel.
2. Lege die Konfiguration für gw01 an, mit ListenPort 51820 und dem Peer client-a.
3. Lege die Konfiguration für client-a an, mit dem Endpunkt gw01 und dem Schlüssel von gw01.
4. Starte den Tunnel auf beiden Seiten und prüfe den Handshake mit wg show.
5. Prüfe die Erreichbarkeit des Tunnelnetzes und des Testnetzes.

## Konfigurationsbeispiel

Die Konfiguration für client-a im Labor. Die Schlüssel sind Platzhalter, die auf dem Gerät neu erzeugt werden.

```
[Interface]
Address = 10.99.0.2/24
PrivateKey = CLIENT_A_PRIVATKEY_PLATZHALTER

[Peer]
PublicKey = GW01_PUBLICKEY_PLATZHALTER
Endpoint = 10.20.0.1:51820
AllowedIPs = 10.99.0.0/24, 10.30.0.0/24
PersistentKeepalive = 25
```

## Erwartetes Ergebnis

Der Handshake ist nach dem Start aktuell, und client-a erreicht das Tunnelnetz und das Netz B über den Tunnel. Die Übertragungszähler in wg show steigen.

## Sicherheitshinweise

Private Schlüssel verlassen die Maschine nicht. Die Konfigurationsdatei wird nicht in Versionsverwaltungen gelegt. Die Schlüssel werden nach dem Projekt gelöscht.

### Typische Fehler

Die öffentlichen und privaten Schlüssel werden vertauscht. Der UDP-Port ist in der Firewall nicht freigegeben. AllowedIPs fehlt das Netz B, sodass Pakete nicht in den Tunnel geleitet werden.

### Kontrollfragen

Welche Angabe in wg show zeigt, dass der Tunnel steht? Welche Einstellung erlaubt client-a den Zugriff auf Netz B?

### Lösung

Der letzte erfolgreiche Handshake zeigt den aktiven Tunnel. Netz B ist über AllowedIPs geroutet, und die Gegenseite lässt nur Quelladressen aus dessen Liste zu.

## 13.5 Projekt 5: Eine Site-to-Site-VPN-Verbindung konzipieren

### Lernziel

Du entwirfst eine Site-to-Site-Verbindung zwischen zwei Standorten, ohne sie vollständig umzusetzen, und begründest die Entscheidungen.

### Voraussetzungen

Grundlagen aus Kapitel 5, 6 und 7. Ein Konzept wird am Schreibtisch erstellt.

### Hardware und Software

Ein Textverarbeitungsprogramm oder ein Tabellenkalkulationsprogramm für die Dokumentation, optional ein Diagrammwerkzeug.

### Netzplan und IP-Adressplan

Standort A hat das Netz 10.20.0.0/24, Standort B das Netz 10.30.0.0/24. Die Gateways haben die öffentlichen Testadressen 198.51.100.2 und 203.0.113.2. Das Tunnelnetz ist

nicht nötig, weil die Gateways direkt verbinden.

## Vorbereitung

Entscheide zwischen IPsec und WireGuard, begründe die Wahl mit Anforderungen, Geräten und Betrieb, und lege die Verwaltung der Schlüssel oder Zertifikate fest.

## Schritt für Schritt

1. Beschreibe beide Standorte mit Netzen, Gateways und Verantwortlichen.
2. Wähle das Protokoll und begründe die Wahl.
3. Lege die erlaubten Netze für den Tunnel fest, also die Traffic Selectors oder AllowedIPs.
4. Plane die Freigaben an den Firewalls beider Standorte.
5. Plane Schlüssel- oder Zertifikatsverwaltung, Erneuerung und Sperrung.
6. Plane die Überwachung und die Notfallschritte bei Ausfall.

## Erwartetes Ergebnis

Ein Konzept mit Netzplan, Adressplan, Protokollentscheidung, Freigabeliste, Verwaltungskonzept und Notfallplan. Jede Entscheidung ist begründet.

## Sicherheitshinweise

Das Konzept nennt keine echten Standortdaten. Die Adressen bleiben Testwerte, und die Verwaltungsdaten sind Platzhalter.

## Typische Fehler

Die Netze auf beiden Seiten passen nicht zueinander. Die Freigaben in den Firewalls fehlen. Die Schlüsselverwaltung bleibt ungeklärt. Der Ausfall des Tunnels ist nicht bedacht.

## Kontrollfragen

Welche Angaben gehören in die Freigabeliste? Warum muss die Verwaltung der Schlüssel im Konzept stehen?

### Lösung

Eine Musterlösung beschreibt beide Gateways, wählt ein Protokoll mit Begründung, legt die Netze für den Tunnel fest, plant die Freigaben UDP 500 und 4500 sowie das Protokoll 50 bei IPsec, und sieht eine Erneuerung der Zertifikate und einen Ersatzweg für den Ausfall vor.

## 13.6 Projekt 6: Ein Sicherheitskonzept nach Zero-Trust-Grundsätzen entwickeln

### Lernziel

Du übersetzt die Grundsätze aus Kapitel 8 in ein Konzept für ein kleines Unternehmen.

### Voraussetzungen

Kapitel 8 und 9. Das Beispiel der Musterbau GmbH aus Kapitel 12 kann verwendet werden.

### Hardware und Software

Ein Textverarbeitungs- oder Tabellenprogramm.

### Netzplan und IP-Adressplan

Der Netzplan folgt den Zonen aus Kapitel 12. Ein IP-Adressplan ist nicht zwingend, weil das Konzept auf Identität und Richtlinie beruht.

### Vorbereitung

Lege die Ressourcen fest, die geschützt werden sollen, und ordne jeder Ressource Identitäten und Gerätezustände zu.

### Schritt für Schritt

1. Liste die Ressourcen auf: Anwendungen, Dateien, Verwaltungszugänge.
2. Bestimme für jede Ressource, wer zugreifen darf, unter welchen Bedingungen und

mit welcher Authentifizierung.

3. Lege Anforderungen an das Gerät fest, etwa Betriebssystem, Verschlüsselung und Schutzsoftware.
4. Formuliere die Richtlinie für jeden Zugriff als Bedingung.
5. Plane die Überwachung und die Reaktion, wenn eine Bedingung nicht erfüllt ist.
6. Beschreibe den Übergang vom bisherigen Netzmodell.

## Erwartetes Ergebnis

Eine Tabelle mit Ressourcen, Zugriffsbedingungen und Gerätevoraussetzungen, dazu eine Beschreibung der Überwachung und des Übergangs.

## Sicherheitshinweise

Das Konzept gibt keine absolute Sicherheit. Notfallzugänge bleiben definiert und geschützt.

## Typische Fehler

Das Konzept beschreibt nur Technik und keine Bedingungen. Die Geräteanforderungen fehlen. Der Notfallzugang wird vergessen, sodass Administratoren ausgesperrt werden können.

## Kontrollfragen

Welche Bedingung würdest du für den Zugriff auf Konstruktionsdaten festlegen? Warum braucht das Konzept einen Notfallzugang?

## Lösung

Eine Musterlösung verlangt für Konstruktionsdaten ein verwaltetes Gerät, Mehrfaktor-Authentifizierung und Zugriff nur während der Arbeitszeit aus dem Büronetz. Der Notfallzugang läuft über einen getrennten Weg mit Protokollierung.

## 13.7 Projekt 7: Netzwerkereignisse mit Wireshark analysieren

### Lernziel

Du wertest einen Mitschnitt aus dem eigenen Labor aus, erkennst den Ablauf einer Verbindung und unterscheidest normalen Verkehr von auffälligem.

### Voraussetzungen

Das Laborumfeld mit Zugriff auf den Mitschnitt. Grundkenntnisse aus Band 6.

### Hardware und Software

Wireshark auf einer Analysemaschine, ein Mitschnitt im Format PCAP, den du im Labor erzeugt hast.

### Netzplan und IP-Adressplan

Der Mitschnitt stammt vom Gateway gw01 im Laborumfeld. Die Adressen entsprechen der Tabelle im gemeinsamen Laborumfeld.

### Vorbereitung

Erzeuge den Mitschnitt im Labor. Client-a sendet eine HTTPS-Anfrage an srv-b, eine DNS-Abfrage und einen Ping. Außerdem versucht client-a einen Verbindungsaufbau auf einen Port, der nicht erlaubt ist. Diese Verbindungsversuche gehen nur an srv-b im Labor.

### Schritt für Schritt

1. Öffne den Mitschnitt in Wireshark und verschaffe dir einen Überblick über die Protokolle.
2. Filtere den Verbindungsaufbau der HTTPS-Verbindung mit dem Filter für SYN-Pakete und prüfe das Dreifach-Handshake.
3. Suche die DNS-Abfrage mit dem Filter für DNS und ordne die Antwort zu.
4. Suche die ICMP-Pakete des Pings und prüfe Anfrage und Antwort.

5. Suche die abgelehnten Verbindungsversuche und unterscheide Verwerfen von Ablehnen.
6. Beschreibe in einem kurzen Bericht, was normal ist und was auffällig.

## Konfigurationsbeispiel

Die folgenden Filter sind Anzeigefilter in Wireshark.

```
tcp.flags.syn == 1 && tcp.flags.ack == 0
dns
icmp
tcp.port == 443
```

## Erwartetes Ergebnis

Die HTTPS-Verbindung zeigt den Dreifach-Handshake. Die DNS-Abfrage und ihre Antwort sind zugeordnet. Die Ping-Anfrage und die Antwort sind vorhanden. Die unerlaubten Verbindungsversuche erscheinen als Pakete ohne Antwort oder mit einer Ablehnung.

## Sicherheitshinweise

Der Mitschnitt enthält Daten des Labors. Er wird nach der Auswertung gelöscht. Auswertungen aus fremden Netzen sind nicht Teil des Projekts.

## Typische Fehler

Der Filter ist zu weit gefasst und zeigt zu viel. Die Richtung der Pakete wird verwechselt. Oder der Mitschnitt wird auf der falschen Schnittstelle erzeugt und enthält die Verbindung nicht.

## Kontrollfragen

Warum zeigt der SYN-Filter nur den Anfang einer Verbindung? Welche Angabe unterscheidet ein Verwerfen von einem Ablehnen?

### Lösung

Der SYN-Filter zeigt die erste Nachricht des Verbindungsaufbaus, die Antwort kommt im SYN-ACK. Ein verworfenes Paket erhält keine Antwort, eine Ablehnung wird mit einem Reset oder einer ICMP-Meldung beantwortet.

## Zusammenfassung

Die sieben Projekte führen durch Firewall, VLAN, DMZ, VPN, Konzept, Zero Trust und Analyse. Jedes Projekt lässt sich im Labor wiederholen, und die Musterlösungen zeigen eine Möglichkeit, nicht die einzige.

## Kontrollfragen

1. Welche Gemeinsamkeit haben Firewall und DMZ im Labor?
2. Welche Angabe in wg show zeigt einen funktionierenden Tunnel?
3. Warum ist die Analyse im Labor aussagekräftiger als die Auswertung eines unbekannten Mitschnitts?

KAPITEL 14

# Zusammenfassung und Ausblick

**Lernziele.** Nach diesem Kapitel kannst du die wichtigsten Erkenntnisse dieses Bandes wiedergeben, erklären, warum mehrschichtige Sicherheit und laufende Pflege zusammengehören, neue Entwicklungen einordnen und den Übergang zu Band 9 nachvollziehen.

## 14.1 Die wichtigsten Erkenntnisse

Dieser Band begann mit einer Grundfrage: Wie schützt man ein Netz, das nicht mehr an einem Gebäude endet? Die Antwort zieht sich durch alle Kapitel. Sicherheit beruht auf einer Reihe von Prüfungen, die jede Verbindung durchläuft, und nicht auf einer einzelnen Grenze. Die Schutzziele aus Kapitel 1 bilden dafür den Prüfmaßstab.

Die Bedrohungen aus Kapitel 2 zeigen, dass viele Schäden durch Lücken entstehen, die man hätte schließen können, und selten durch raffinierte Technik. Fehlkonfigurationen, veraltete Software und gestohlene Passwörter stehen am Anfang vieler Vorfälle. Die Abwehr beginnt deshalb bei der Planung und der Pflege, nicht erst beim Angriff.

Firewalls, Segmentierung und Zugriffskontrolle begrenzen die Wirkung, wenn ein Schutz versagt. Kapitel 3 und 4 haben gezeigt, dass Default Deny, klare Zonen und eine Kommunikationsmatrix die Grundlage sind. Kapitel 9 hat ergänzt, dass die Identität darüber entscheidet, wer welche Zugriffe erhält.

VPN-Verbindungen aus Kapitel 5 bis 7 schützen den Weg, nicht das Ziel. Ein Tunnel ist nur so sicher wie das Gateway, die Schlüssel und die Freigaben dahinter. Zero Trust in Kapitel 8 verschiebt deshalb den Fokus von der Netzgrenze auf jede einzelne Anfrage.

Die Härtung der Geräte in Kapitel 10 und die Überwachung in Kapitel 11 schließen den Kreis. Eine gehärtete Konfiguration zeigt ihre Wirkung erst, wenn Protokolle und Alarme sie überprüfen. Das Sicherheitskonzept aus Kapitel 12 verbindet alle Bausteine, und die Projekte aus Kapitel 13 zeigen, dass sich die Konzepte im Labor nachvollziehen lassen.

## 14.2 Mehrschichtige Netzwerksicherheit

Mehrschichtige Sicherheit bedeutet, dass mehrere unabhängige Schutzmaßnahmen einander ergänzen. Fällt eine aus, begrenzen die anderen den Schaden. Eine Firewall stoppt unerwünschten Verkehr, eine Segmentierung begrenzt die Ausbreitung, eine Authentifizierung prüft die Identität, eine Verschlüsselung schützt die Vertraulichkeit, und die Überwachung zeigt, wo etwas nicht stimmt.

Die Schichten sind nur wirksam, wenn sie zueinander passen. Eine Firewall-Regel, die einen Dienst freigibt, den die Segmentierung eigentlich sperrt, hebt die Trennung auf. Ein Monitoring, das nur Fehler zählt und keine Anomalien erkennt, sieht den Angriff nicht. Deshalb wird jedes Konzept als Ganzes geprüft.

## 14.3 Warum es keine einzelne perfekte Sicherheitslösung gibt

Keine Technik schützt vollständig. Jede Maßnahme hat Grenzen, und jede Verschlüsselung hängt von Schlüsseln ab, die verwaltet werden müssen. Eine Firewall sieht nur den Verkehr, den sie erreicht, und ein IDS erkennt nur bekannte oder auffällige Muster. Selbst ein gut gepflegtes System kann durch eine unbekannte Schwachstelle verwundbar werden.

Diese Einsicht ist keine Aufforderung zur Resignation. Sie begründet, warum Schutz auf mehreren Ebenen und auf Verantwortung in der Organisation beruht. Eine Lösung, die alles verspricht, verleitet dazu, die Pflege zu vernachlässigen.

## 14.4 Sicherheit als fortlaufender Prozess

Netzwerke verändern sich. Neue Geräte kommen hinzu, Mitarbeitende wechseln die Aufgabe, Software wird aktualisiert, und Angreifer passen ihre Methoden an. Ein Konzept, das einmal erstellt und dann nicht mehr geprüft wird, veraltet schnell. Die Rechteüberprüfung, die Regelprüfung, die Wiederherstellungsübung und die Notfallübung gehören deshalb in einen festen Kalender.

Der Prozess braucht auch Rückmeldung. Die Auswertung von Vorfällen und Fehlalarmen zeigt, welche Regeln zu eng oder zu weit gefasst sind. Jede Änderung im Netz sollte die Dokumentation mit berühren, sonst stimmt sie bald nicht mehr.

## 14.5 Bedeutung von Monitoring und Wartung

Monitoring macht sichtbar, was ohne Überwachung unbemerkt bliebe. Logs, Flows und Alarme liefern die Grundlage für Entscheidungen, aber nur, wenn jemand sie auswertet und reagiert. Ein SIEM mit tausend ungeprüften Alarmen schützt weniger als ein gut eingestelltes System mit wenigen, verlässlichen Meldungen.

Wartung schützt, was die Überwachung zeigt. Updates schließen Lücken, Sicherungen ermöglichen die Wiederherstellung, und der Ersatz alter Geräte beseitigt Risiken, die sich nicht mehr beheben lassen. Die Wartung ist unspektakulär, aber sie entscheidet oft darüber, ob ein Vorfall klein bleibt.

## 14.6 Neue Entwicklungen in der Netzwerksicherheit

Die Entwicklung der Netzwerksicherheit läuft in mehreren Richtungen gleichzeitig. Zero-Trust-Architekturen werden in vielen Organisationen schrittweise eingeführt, wie in Kapitel 8 beschrieben. Identitätsbasierte Zugriffe ersetzen zunehmend die reine Netzgrenze.

Bei der Kryptografie beschäftigt die Entwicklung leistungsfähiger Rechner die Fachwelt. Das amerikanische NIST hat 2024 erste Standards für quantenresistente Verfahren veröffentlicht. Ihre Einführung in Protokolle wie IPsec, WireGuard oder TLS befindet sich in einer Übergangsphase, und der genaue Zeitplan hängt von Herstellern und Behörden ab. Diese Angabe stammt aus dem Fachwissen und sollte vor einer Planung in den aktuellen Veröffentlichungen des NIST geprüft werden.

Außerdem wächst der Anteil von Geräten im Netz, die nicht von Menschen bedient werden. IoT-Geräte, Sensoren und Dienste, die untereinander kommunizieren, brauchen eigene Identitäten und Richtlinien. Die Konzepte aus Kapitel 9 und 10 gewinnen dadurch an Bedeutung.

## 14.7 Automatisierung und moderne Sicherheitsarchitekturen

Automatisierung hilft, Konfigurationen gleichmäßig zu halten. Konfiguration als Code, also das Beschreiben der Netzwerkgeräte und Regeln in Dateien, macht Änderungen nachvollziehbar, prüfbar und wiederholbar. Eine Regeländerung durchläuft dann dieselbe Prüfung wie jede andere Softwareänderung. Das verringert Fehler, die aus Handarbeit entstehen.

Automatisierung hat aber eigene Risiken. Ein fehlerhaftes Skript kann viele Geräte gle-

ichzeitig falsch konfigurieren, und die Zugangsdaten für die Automatisierung werden zu einem besonders wertvollen Ziel. Die Konfigurationsdateien und ihre Schlüssel brauchen deshalb denselben Schutz wie jede andere Verwaltungsfunktion.

## 14.8 Übergang zu Band 9: Netzwerke im Homelab

Band 9 setzt dort an, wo dieser Band praktisch endet. Er richtet sich an alle, die ein eigenes Netz planen und betreiben, etwa im Homelab oder in einer kleinen Werkstatt. Die Themen sind die Planung eines eigenen Netzes, die Virtualisierung mit Proxmox, Firewalls mit pfSense oder OPNsense, VLANs und Zonen im Heimnetz, DNS und DHCP mit Pi-hole, Firewall-Regeln, Monitoring und praktische Projekte.

Die Verbindung zu den bisherigen Bänden ist direkt. Die VLAN-Trennung aus Kapitel 4, die Firewall-Regeln aus Kapitel 3, die Härtung aus Kapitel 10 und die Überwachung aus Kapitel 11 werden dort in einem überschaubaren Netz umgesetzt. Band 9 zeigt, wie die Grundsätze dieser Reihe im eigenen Netz praktisch angewendet werden, ohne die Komplexität eines Unternehmens.

> **Merke**
>
> Sicherheit entsteht aus mehreren Schichten, die zueinander passen, und aus laufender Pflege. Keine Technik ersetzt das Konzept, und das Konzept ersetzt nicht die Überwachung. Band 9 überträgt diese Haltung auf das eigene Netz.

## Zusammenfassung

Dieser Band hat Netzwerksicherheit von den Grundlagen über Bedrohungen, Schutztechniken, Zugriffskontrolle, Härtung und Überwachung bis zum Unternehmenskonzept behandelt. Die Kernaussagen sind mehrschichtige Verteidigung, Zero Trust als Haltung, Härtung und Überwachung als laufende Aufgaben und die Notwendigkeit, alles als Prozess zu betreiben.

## Kontrollfragen

1. Warum bleibt ein gut konfiguriertes Netz angreifbar, wenn es nur eine einzige Schutzmaßnahme besitzt?
2. Welche Schutzmaßnahmen aus diesem Band begrenzen die Ausbreitung eines

Vorfalls?

3. Warum ist ein SIEM mit vielen ungeprüften Alarmen weniger wirksam als eines mit wenigen geprüften Meldungen?
4. Was verändert die Automatisierung der Konfiguration an den Risiken?
5. Welche Themen aus Band 9 greifen auf Kapitel 3, 4, 10 und 11 dieses Bandes zurück?

# Anhang

## Glossar

Die folgende Auswahl erklärt die wichtigsten Begriffe dieses Bandes. Die Erklärungen entsprechen der Verwendung im Text.

| Begriff | Erklärung |
|---|---|
| **Angriffsfläche** | Gesamtheit der Stellen, über die ein System angegriffen werden kann. |
| **Authentizität** | Schutzziel, das sicherstellt, dass Absender und Gegenstelle zweifelsfrei identifiziert sind. |
| **AllowedIPs** | Einstellung bei WireGuard, die festlegt, welche Adressen über einen Peer geroutet und von ihm akzeptiert werden. |
| **Baseline** | Grundlinie des normalen Verhaltens, mit der Anomalien verglichen werden. |
| **Conditional Access** | Zugriffsregeln, die an Bedingungen wie Gerätezustand, Standort oder Authentifizierung geknüpft sind. |
| **Defense in Depth** | Mehrschichtige Verteidigung, bei der mehrere unabhängige Schutzmaßnahmen einander ergänzen. |
| **DMZ** | Netzbereich für Dienste, die aus einem unsicheren Netz erreichbar sein müssen. |
| **Default Deny** | Grundhaltung, bei der alles verboten ist, was nicht ausdrücklich erlaubt wurde. |
| **Ingress-Filterung** | Prüfung eingehender Pakete am Netzrand, etwa auf unmögliche Quelladressen. |
| **Integrität** | Schutzziel, das sicherstellt, dass Daten unverändert bleiben oder Änderungen erkannt werden. |
| **IPS** | Intrusion Prevention System. Erkennt Angriffsmuster und greift aktiv ein. |
| **Least Privilege** | Grundsatz, dass jede Identität nur die Zugriffe erhält, die sie für ihre Aufgabe braucht. |
| **Mikrosegmentierung** | Feine Unterteilung des Netzes bis auf die einzelne Anwendung oder Maschine. |

| Begriff | Erklärung |
|---|---|
| **NAT-Traversal** | Verfahren, mit dem IPsec-Pakete hinter einer Adressumsetzung über UDP Port 4500 übertragen werden. |
| **Perfect Forward Secrecy** | Eigenschaft, bei der frühere Sitzungen geschützt bleiben, auch wenn ein langfristiger Schlüssel später bekannt wird. |
| **Policy Engine** | Komponente von Zero Trust, die Zugriffsentscheidungen anhand von Richtlinie und Signalen trifft. |
| **Policy Enforcement Point** | Komponente von Zero Trust, die eine Verbindung zulässt oder blockiert. |
| **Rolle (RBAC)** | Sammlung von Rechten, die einer Aufgabe zugeordnet und Personen zugewiesen wird. |
| **Security Association** | Vereinbarung über einen geschützten IPsec-Kanal in eine Richtung, mit Algorithmen und Schlüsseln. |
| **Split Tunneling** | Betriebsart eines VPN, bei der nur bestimmter Verkehr durch den Tunnel läuft. |
| **Full Tunneling** | Betriebsart eines VPN, bei der der gesamte Verkehr durch den Tunnel läuft. |
| **Stateful Inspection** | Filterung, die Verbindungszustände verfolgt und Antworten zu bestehenden Verbindungen zulässt. |
| **Trunk** | Verbindung, die mehrere VLANs über eine Leitung trägt. |
| **Verfügbarkeit** | Schutzziel, das sicherstellt, dass Dienste nutzbar sind, wenn sie gebraucht werden. |
| **Vertraulichkeit** | Schutzziel, das sicherstellt, dass nur Berechtigte Informationen lesen können. |
| **Zero Trust** | Sicherheitskonzept, das jede Anfrage prüft und keinem Netzbereich vertraut. |
| **Zustandstabelle** | Liste der aktiven Verbindungen, die eine Firewall zur Zuordnung von Paketen nutzt. |

## Abkürzungsverzeichnis

| Abkürzung | Bedeutung |
|---|---|
| **ABAC** | Attribute-Based Access Control |
| **ACL** | Access Control List |

| Abkürzung | Bedeutung |
|---|---|
| **AES** | Advanced Encryption Standard |
| **AH** | Authentication Header |
| **ALG** | Application Layer Gateway |
| **ARP** | Address Resolution Protocol |
| **BCP** | Best Current Practice |
| **BPDU** | Bridge Protocol Data Unit |
| **BSI** | Bundesamt für Sicherheit in der Informationstechnik |
| **CAPWAP** | Control and Provisioning of Wireless Access Points |
| **DAI** | Dynamic ARP Inspection |
| **DDoS** | Distributed Denial of Service |
| **DHCP** | Dynamic Host Configuration Protocol |
| **DMZ** | Demilitarisierte Zone |
| **DNS** | Domain Name System |
| **DNSSEC** | Domain Name System Security Extensions |
| **DoS** | Denial of Service |
| **EAP** | Extensible Authentication Protocol |
| **ESP** | Encapsulating Security Payload |
| **HSTS** | HTTP Strict Transport Security |
| **IAM** | Identity and Access Management |
| **IDS** | Intrusion Detection System |
| **IKE** | Internet Key Exchange |
| **IKEv2** | Internet Key Exchange, Version 2 |
| **IoT** | Internet of Things |
| **IPFIX** | IP Flow Information Export |
| **IPS** | Intrusion Prevention System |
| **IPsec** | Internet Protocol Security |
| **MFA** | Multi-Faktor-Authentifizierung |
| **MTU** | Maximum Transmission Unit |
| **NAC** | Network Access Control |
| **NAT** | Network Address Translation |
| **NGFW** | Next-Generation-Firewall |
| **NIST** | National Institute of Standards and Technology |
| **PFS** | Perfect Forward Secrecy |
| **PKI** | Public-Key-Infrastruktur |
| **RADIUS** | Remote Authentication Dial-In User Service |
| **RBAC** | Role-Based Access Control |
| **SA** | Security Association |
| **SIEM** | Security Information and Event Management |
| **SNMP** | Simple Network Management Protocol |
| **SPI** | Security Parameter Index |

| Abkürzung | Bedeutung |
|---|---|
| **SSH** | Secure Shell |
| **TACACS+** | Terminal Access Controller Access-Control System Plus |
| **TLS** | Transport Layer Security |
| **UDP** | User Datagram Protocol |
| **VLAN** | Virtual Local Area Network |
| **VPN** | Virtual Private Network |
| **WIPS** | Wireless Intrusion Prevention System |

# Quellen und Literatur

Die Quellen sind nach Themen gegliedert. Bei Online-Quellen steht das Abrufdatum. Der Vermerk *Abgerufen* bedeutet, dass die Quelle bei der Recherche zu diesem Band aufgerufen oder über die Suche ausgewertet wurde. Der Vermerk *Fachwissen* kennzeichnet Angaben, für die keine Quelle abgerufen wurde. Diese Angaben sind vor einer Verwendung in einer Prüfung, einem Projekt oder einem Konzept an der Originalquelle zu prüfen.

## Standards, Normen und RFCs


IETF RFC 7296: Internet Key Exchange Protocol Version 2 (IKEv2). *Fachwissen.*

IETF RFC 4303: IP Encapsulating Security Payload (ESP). *Fachwissen.*

IETF RFC 4302: IP Authentication Header (AH). *Fachwissen.*

IETF RFC 5737: IPv4 Address Blocks Reserved for Documentation. *Fachwissen.* Die Testadressen des Bandes stammen aus diesen Bereichen.

IETF RFC 2827 und BCP 38: Network Ingress Filtering. *Fachwissen.*

IETF RFC 7664: Dragonfly Key Exchange. Abgerufen über die Suche unter `https://tools.ietf.org/html/rfc7664`, Abrufdatum 09.11.2026.

IETF RFC 5415: Control and Provisioning of Wireless Access Points (CAPWAP). *Fachwissen.*

IETF RFC 7011: Specification of the IP Flow Information Export (IPFIX) Protocol. *Fachwissen.*

IEEE 802.1X und IEEE 802.1Q. *Fachwissen.* Die Norm ist kostenpflichtig, die Beschreibungen folgen den allgemein dokumentierten Verfahren.

NIST Special Publication 800-207: Zero Trust Architecture, August 2020. Abgerufen über die Suche unter `https://isms.online/nist/nist-sp-800-207` und Sekundärbeschreibungen. Abrufdatum 09.11.2026. Hinweis: Die Komponenten Policy Engine, Policy Administrator und Policy Enforcement Point stammen aus der Publikation, das Original sollte für die Einzelheiten herangezogen werden.

## Behörden und Verbände

Bundesamt für Sicherheit in der Informationstechnik: IT-Grundschutz, Schutzbedarfsfeststellung und Empfehlungen zu Passwörtern. *Fachwissen.* Die aktuellen Fassungen sind auf der Website des BSI zu prüfen.

Bundesamt für Sicherheit in der Informationstechnik: Technische Richtlinie TR-02102, Kryptographische Verfahren. *Fachwissen.*

Europäische Union: Richtlinie (EU) 2022/2555 über Maßnahmen für ein hohes gemeinsames Cybersicherheitsniveau (NIS-2-Richtlinie). *Fachwissen.* Die Anwendung hängt von Branche und Größe ab und ist im Einzelfall zu prüfen.

## Quellen zu WireGuard und Linux

Jason A. Donenfeld: WireGuard: Next Generation Kernel Network Tunnel. Abgerufen unter `https://gorbe.io/docs/wireguard/whitepaper`, Abrufdatum 09.11.2026. Hinweis: Spiegel des Originals, die Angaben zu Cryptokey Routing und zum Handshake stammen aus dem Dokument.

Jason A. Donenfeld: RFC-Diskussion auf der Linux-Netzwerkliste zu WireGuard, Juni 2016. Abgerufen über die Suche unter `https://lore.kernel.org/all/5776827F.8010306@nod.at/t/`, Abrufdatum 09.11.2026.

Linux-Kernel 5.6: Aufnahme von WireGuard am 29. März 2020. Abgerufen über eine Enzyklopädie unter `https://cavac.at/cavacopedia/WireGuard`, Abrufdatum 09.11.2026. Hinweis: Sekundärquelle, das Datum ist mit dem Kernel-Changelog abzugleichen.

## Herstellerdokumentation und Fachartikel

Cisco Systems: Voice over Wireless LAN 4.1 Design Guide. *Fachwissen,* aus Band 7 übernommen, dort abgerufen und älter als 802.11ax.

Strongswan-Projekt: Dokumentation der Konfigurationsdatei swanctl.conf. *Fachwissen.* Die Beispielstruktur ist vereinfacht und ersetzt nicht die Dokumentation der aktuellen Version.

Fachwissen zu pfSense, OPNsense und vergleichbaren Firewalls, zu nftables und zu den Befehlen von Linux, Windows und Netzgeräten in den Kapiteln 3, 4, 10, 13. *Fachwissen.* Die Befehle wurden im Labor nicht geprüft und sind vor einer Verwendung zu testen.

## Hinweis zur Quellenlage

Die Angaben dieses Bandes stützen sich auf die oben genannten Quellen und auf allgemeines Fachwissen. Für Verfahren, Normen und Befehle gilt die jeweils aktuelle Fassung der Quelle. Vor einer verbindlichen Entscheidung, etwa bei der Planung eines Netzes, bei einer Prüfung oder bei Angaben in einem Angebot, ist die Originalquelle zu prüfen.

NETZWERK VERSTEHEN • BAND 8

# Netzwerksicherheit

Ein Netz ist nur so sicher wie seine schwächste Stelle, und diese Stelle liegt selten dort, wo man sie vermutet. Dieser Band zeigt, wie man Netzwerke mit mehreren Schichten schützt, die zueinander passen.

Die Themen reichen von den Schutzzielen und Bedrohungen über Firewalls, Segmentierung und VLANs bis zu VPN mit WireGuard und IPsec. Dazu kommen Zero Trust, Zugriffskontrolle, die Härtung von Netzwerkgeräten, Überwachung und Erkennung sowie ein Sicherheitskonzept für ein Unternehmen.

Die Konfigurationsbeispiele verwenden ausschließlich Testwerte und sind für ein eigenes Labor gedacht. Sieben Praxisprojekte und Übungen mit Lösungen festigen das Gelernte. Angriffe werden nur zur Abwehr beschrieben.

Das Buch richtet sich an Auszubildende, Umschüler, Netzwerkadministratoren und Homelab-Betreiber. Es bereitet auf Band 9 vor, der den Aufbau eines eigenen Netzes behandelt.

**Eugen Becker**